



Northeastern University
**Khoury College of
Computer Sciences**

CY5200 Security Risk Management and Assessment

Security Risk Analysis for
Capgemini

Analysis by – Mohammed Arafat

Under the supervision of

Professor Themis Papageorge

Date: 20 April 2025

Contents

Executive Summary	4
Information System Categorization:.....	4
System Description.....	5
List of Applicable Law, Policies, Framework, standards and Regulations:.....	6
List of Assets with Values(\$).....	8
List of Threats	9
List of Vulnerabilities.....	10
Threat/Vulnerability pairs (with probabilities 0%-100% that a threat will exploit the specific vulnerability).....	10
Assets Vulnerabilities Pairs.....	11
MOT Controls	12
List of Current Security Control and Policies (CSCP).....	13
List of New Security Control and Policies (NCSP) proposed by CISOs team	15
Optimized Security Risk Prevention Strategy:.....	17
Security Risk Response (Resilience) Strategy:	18
Optimized Security Risk Mixed Strategy:	20
Conclusion: Risk Reduction and ROI Analysis	22
Did the HGA team address all security risks based on the risk assessment?	23
Does the Residual Risk Reduction Exceed the Budget for Proposed Controls?	23
What is the (expected overall security risk reduction Benefit) / (proposed overall security risk budget Cost) ROI ratios for each of the 4 budgets in XIII?	24
Do you recommend a Risk Prevention Strategy or a Risk Response Strategy or a combination such as a Risk reduction strategy or Risk ROI maximization Mixed Strategy?	26
Part B Security Risk Management Implementation Plan for Capgemini.....	26
Implementation Controls and Policies.....	27
1. Access Control Security Risk Management Implementation Controls and Policies....	27
2. Network Infrastructure Security Risk Management Implementation Controls and Policies.....	29
3. Network Infrastructure Management Security Risk Management Implementation Controls and Policies	31
4. Database Security Risk Management Implementation Controls and Policies	33
5. Applications Development Security Risk Management Implementation Controls and Policies.....	38
6. Wireless Security Risk Management Implementation Controls and Policies	45
7. Across all Security Risk areas 1-6 from above provide a table for:	48

8. Applicable Government Regulations and Industry Standards.....	89
9. Ranking Asset risks and Vulnerability risks for Capgemini across Access Control, Network Infrastructure, Network Infrastructure Management, Database, Applications, and Wireless.	91
10. Cybersecurity Workforce Risk Management Implementation	93
Part C	110
Security Risk Management Recommendations	110
C1. Security Risk Management Recommendations: Provide the list of recommended Prevention and Response controls, methods and policies and their implementation costs and benefits based on your risk management analysis in Part A for HGA and Part B for Capgemini.....	110
C2. Provide the total cost and total risk reduction benefit in \$ due to the recommended controls, methods and policies based on your security risk management analysis in Parts A and B.....	115
C3. Compare your proposed security controls, methods and policies budget for HGA (which is based on security risk assessment in Part A) with the proposed security controls, methods and policies budget for Capgemini (which is based on security risk implementation plan in Part B), comparing the two companies at a high level on the following security risk management areas:	116
Part D.....	124
Appendix 1: All MS-Excel spreadsheet models	124
Appendix 2: Any data, analysis, controls or policies not included above.....	126
Appendix 3: Detailed Network Topology for HGA	131
Appendix 4: Detailed Network Topology (defense-in-depth) for Capgemini	132
Resources.....	136

Part A Security Risk Management and Assessment for Hypothetical Government Agency

Executive Summary

Information System Categorization:

	Confidentiality(C)	Integrity(I)	Availability(A)
Financial Resources	High	High	Medium
Personal Computers	Medium	Medium	High
LAN Server	High	High	High
Company Documents	High	High	Medium

Organization name – Hypothetical Government Agency (HGA)

Organization Address – 1552 Thornton St, Roxbury, MA – 02119

Senior Management -

Name: Scudera Ferrari

Title: Chief Executive Officer

Email: ferrari.s@hga.com

Phone: +1 532-324-2342

Name: Aryton Senna

Title: Chief Information Officer

Email: senna.a@hga.com

Phone: +1 342-565-5342

Name: Charles Leclerc

Title: Chief Financial Officer

Email: Leclerc.c@hga.com

Phone: +1 324-342-7556

Name: Lewis Hamilton

Title: Chief Information Security Officer

Email: hamilton.l@hga.com

Phone: +1 454-756-4555

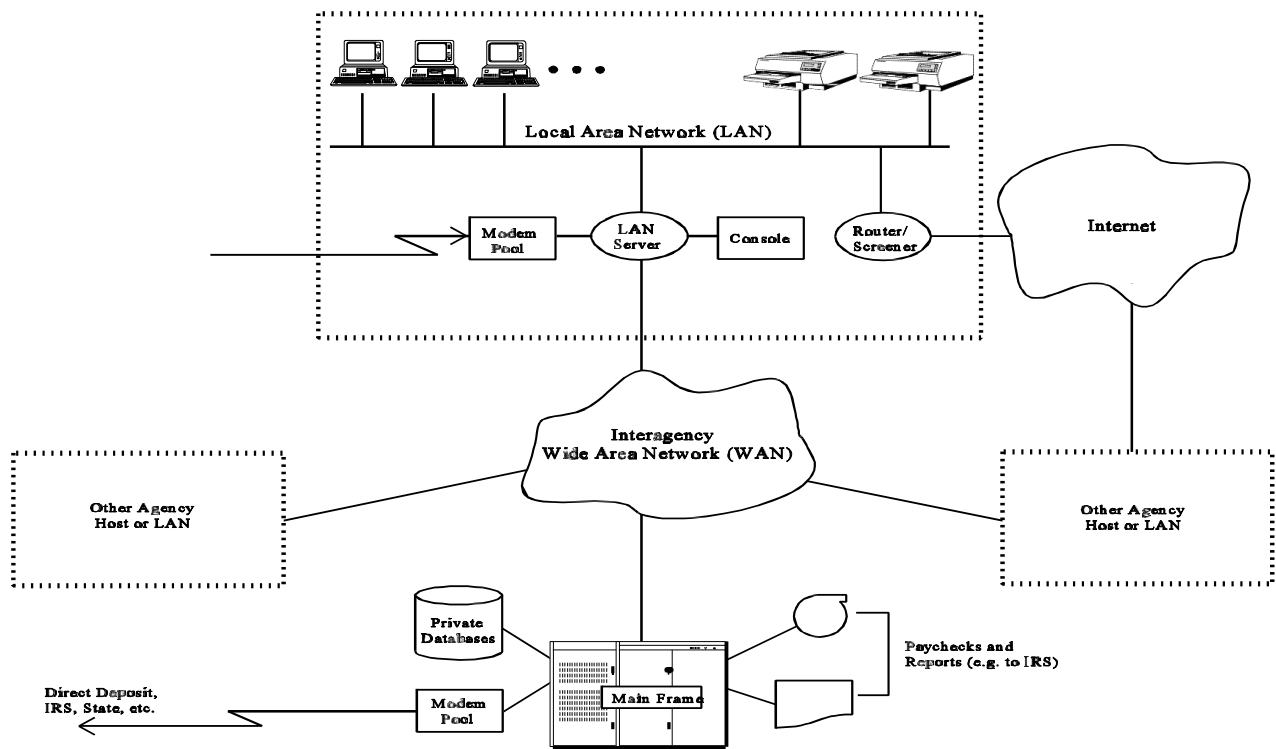
Information System Operational Status- Operational.

Information System Type- Distributed LAN (Local Area Network)

System Description- Payroll Transfers of US Govt. funds to the Individuals.

System Topology-

HGA maintains a robust security posture across management, operational, and technical controls, though some areas require improvement. Regular risk assessments and compliance with federal guidelines ensure system certification and accreditation, yet delays in corrective actions and incomplete adherence to security plans pose challenges. Operationally, HGA enforces duty separation, background checks, and contingency planning but needs to enhance disaster recovery testing, virus scanning compliance, and mobile data protection. Technically, strong authentication and access restrictions are in place, with plans to implement one-time passwords, encrypting modems, and digital signatures. However, unencrypted LAN and WAN transmissions present a vulnerability requiring immediate attention. The system topology comprises a distributed computing environment with interconnected PCs, a central LAN server, external WAN access, Internet connectivity through secured routers, a remote access modem pool, and a centralized mainframe for interagency data exchanges. Strengthening encryption, monitoring, and compliance measures will further secure HGA's critical operations and sensitive information.



System Name:- Hypothetical Government Agency (HGA)

Type of Organization:- Finance and Accounting Agency - Public Sector

Type of Agreement:- Government Contract

Establishment Date:- 31 March,1982

FIFS 199 Category:- High.

CA status:- Certified and Accredited

Authorizing Official:- Scudera Ferrari

List of Applicable Law, Policies, Framework, standards and Regulations:

1. Federal Information Security Modernization Act (FISMA)
2. National Institute of Standards and Technology (NIST) Special Publications
3. Office of Management and Budget (OMB) Circular A-130
4. Privacy Act of 1974
5. General Data Protection Regulation (GDPR)
6. Health Insurance Portability and Accountability Act (HIPAA)
7. Federal Risk and Authorization Management Program (FedRAMP)
8. Cybersecurity Framework (CSF) by NIST
9. International Organization for Standardization (ISO) 27001
10. Payment Card Industry Data Security Standard (PCI DSS)
11. Sarbanes-Oxley Act (SOX)
12. Controlled Unclassified Information (CUI) Program
13. Criminal Justice Information Services (CJIS) Security Policy
14. Federal Trade Commission (FTC) Safeguards Rule
15. Homeland Security Presidential Directive 12 (HSPD-12)

Security Control	Observations	Status	Content Type	Responsibility Authority
Risk Assessment (RA)	Conducts periodic evaluations to detect potential risks	Implemented	Risk analysis reports	CISO

Planning (PL)	Develops strategic security management plans	Implemented	Security strategy documents	CISO
System and Services Acquisition (SA)	Embeds security measures into the procurement process	Partially Implemented	Procurement policies	CISO
Certification, Accreditation, and Security Assessments (CA)	Ensures compliance through validation and audits	Implemented	Compliance assessment reports	CISO
Personnel Security (PS)	Implements safeguards against insider risks	Implemented	HR security policies	CISO
Physical and Environmental Protection (PE)	Establishes safeguards for physical infrastructure	Partially Implemented	Facility security guidelines	CIO
Contingency Planning (CP)	Develops strategies for unexpected disruptions	Partially Implemented	Disaster Recovery/BCP plans	CIO
Configuration Management (CM)	Manages system configurations and security changes	Partially Implemented	Configuration control logs	CIO
Maintenance (MA)	Conducts routine checks for system efficiency	Partially Implemented	Maintenance documentation	CIO
System and Information Integrity (SI)	Ensures data accuracy and reliability	Partially Implemented	Security incident reports	CISO
Media Protection (MP)	Secures both physical and digital data storage	Partially Implemented	Data handling protocols	CISO
Incident Response (IR)	Develops plans for detecting and responding to threats	Implemented	Incident response procedures	CISO
Awareness and Training (AT)	Conducts security education programs	Implemented	Training documentation	CISO
Identification and Authentication (IA)	Implements user identity verification measures	Implemented	Access control policies	CISO
Access Control (AC)	Regulates system access based on policies	Implemented	Access control logs	CISO
Audit and Accountability (AU)	Conducts periodic audits to ensure compliance	Partially Implemented	Audit records	CISO

System and Communications (SC)	Protects communication channels from unauthorized access	Implemented	Network security configurations	CIO
---------------------------------------	--	-------------	---------------------------------	-----

Information Security Plan Completion Date : 02/01/2025

Information Security Plan Approval Date : 02/05/2025

List of Assets with Values(\$)

HGA is govt agency, it is a Boston based Company across US, that offers cybersecurity solutions to various organizations, companies and their clients. There are around 1000 people working in this company. Started in 1982.

Total Valuation for HGA is \$5000000 and for confidential/sensitive data is

Asset Number	Asset Name	Asset Value	Description
A1	Financial Resources	\$95000	Represents government funds managed by HGA, critical for payroll and other financial disbursements.
A2	System Components	\$75000	Includes the infrastructure supporting HGA's operations.(Printers,router, etc)
A3	Personal Computers	\$90000	Used by staff for everyday tasks like data processing, word processing, and accessing applications.
A4	LAN Server	\$85000	Central system managing shared storage, access control, and execution of critical applications.
A5	Personnel Information	\$80000	Includes sensitive employee data like leave balances, salary, and W-2 information, vital for privacy and operations.
A6	Company Documents	\$85000	Essential documents related to financial and operational dealings with vendors and contractors.(Contracting and Procurement Documents)
A7	Draft Regulations	\$75000	Early-stage regulatory documents, significant for governance but less operationally critical.
A8	Internal Correspondence	\$80000	Covers emails and other communication records within HGA, important but medium priority.
A9	Business Documents	\$85000	Critical day-to-day operational records stored on the server,

			sensitive to unauthorized access or loss.(Memos , Reports, etc)
A10	Reputation	NA	Intangible but critical for maintaining trust and operational credibility.
A11	Employee Trust	\$90000	Confidence in secure handling of personal information and reliable wage payments is fundamental.
A12	Mainframe	\$85000	Service Provider For HGA and other agencies operated by the federal agency
A13	Modem Pool	\$90000	Provides dial-up services (via the public switched network) to HGA employees on Travel

List of Threats

Threat Number	Threat Name	Description
T1	Payroll Fraud	Financial embezzlement and fraud: comprises submitting false timesheets after being fired or overstating compensatory hours worked in order to receive more compensation, as well as fabricating service tenure in order to receive early retirement benefits. generating timesheets and employee records for fraudulent employees in order to receive more payments
T2	Payroll Errors	Errors in the time and attendance data entering Failure to promptly enter information about new hire terminations and transfers, inadvertent corruption or loss of time and attendance records, or mistakes in interagency coordination and personal transfer procedures
T3	Interruption of Operations	Disruptions to HGA's activities caused by power outages, hardware failures, or malicious actions, delaying processes like payroll or communication.
T4	Information Disclosure or Breakening	Unauthorized access or sharing of sensitive data, such as employee records or internal communications, either internally or externally.
T5	Network-related	Risks from external networks, including unauthorized access, data tampering, or eavesdropping during transmission.
T6	Natural Disasters	Environmental events like floods or storms causing damage to infrastructure, resulting in downtime or data loss.

T7	Misuse of System Resources	Improper use of HGA's systems for unauthorized purposes, affecting performance or security.
T8	Unauthorized access to Telecommunication Services	Exploitation of HGA's telecom systems, such as unauthorized calls, data access, or eavesdropping.

List of Vulnerabilities

Vulnerability ID	Description
V1	Falsified (Date & Time Sheet) Data manipulation By workers.
V2	Unauthorized Personnel access to modifying Employee records
V3	Bogus time and attendance applications
V4	Employee negligence to update information on time
V5	Degrading building facilities and resources
V6	Improper access control management
V7	Exposure to external Network
V8	Lack of Secure storage and encryption mechanisms
V9	Improper or insufficient audit logging
V10	Lack of proper Virus Detection and Prevention Mechanisms
V11	Lack of sufficient personnel training and awareness

Threat/Vulnerability pairs (with probabilities 0%-100% that a threat will exploit the specific vulnerability)

Vulnerability ID	Description
V3	Bogus time and attendance applications
V5	Degrading building facilities and resources
V7	Exposure to external Network
V11	Lack of sufficient personnel training and awareness

Threat/Vulnerability pairs with likelihood probabilities 0%-100% provide a brief explanation of assigned probability values

T1, T4 exploits **V3** on assets **A1, A3** and **A6**

T4, T5 and **T6** exploits **V5** on assets **A3, A4** and **A6**

T1, T5 exploits V7 on assets A1, A3, A4 and A6

T1, T4 and T5 exploits V11 on assets A1, A3, A4 and A6

	T1	T4	T5	T6
V3 on assets A1, A3, A6	90	85	80	80
V5 on assets A3, A4, A6	80	80	85	90
V7 on assets A1, A3, A4, A6	80	90	90	85
V11 on assets A1, A3, A4, A6	80	85	90	80

Payroll-Fraud:

With a 90% chance, payroll fraud has a significant negative influence on A1 since flaws in systems such phony time and attendance systems (V3) enable the creation of fictitious timesheets or employee records, which can result in monetary losses. Since these are employed for manipulation, they are prime candidates for unwanted access, and there is an 80% chance that A3 will be abused. A6 has a 90% chance of being taken advantage of because fraudulent activity frequently entails changing crucial payroll and financial records. The danger of fraud is further increased across all of these assets by exposure to external networks (V7) and inadequate training (V11).

Information-Disclosure:

Since poor access restrictions and network vulnerabilities might reveal sensitive financial and operational records, unauthorized data sharing poses an 85% risk to A1 and A6 (V7). Because A3 stores confidential employee or operational data that could be compromised, there is an 80% chance that it will be exploited. A4 also has an 80% to 85% chance since malicious actors can more easily access or share data undetected due to deteriorated infrastructure (V5) and a lack of training (V11)..

Network-related:

Network-related: Because network hazards are essential for communication and data processing, they provide A3 and A4 a 90% chance of being compromised by unauthorized access, data interception, or tampering through external vulnerabilities (V7). With an 85% chance, A6 is likewise extremely vulnerable since procurement or operational papers may be compromised by network breaches. Because financial transactions depend on secure network infrastructure, there is an 80% chance that A1 will be exploited. Human error in safeguarding systems is increased by inadequate employee training (V11), which increases the hazards.

Natural-Disasters:

A4 and A6 are 90% likely to be disrupted by natural disasters like floods or storms because of deteriorated facilities (V5), which can cause infrastructure damage or the loss of crucial records. With an 85% chance, A3 is also susceptible to physical device damage, which could cause downtime or data loss. A1 has an 80% chance since financial disbursements or payroll may be delayed due to operational problems during disasters. A lack of disaster preparedness stemming from insufficient training (V11) worsens the impact on all these assets.

Assets Vulnerabilities Pairs.

Asset ID	Asset Name	Vulnerability ID	Vulnerability Description
A1	Financial Resources	V3	Bogus time and attendance applications
		V5	Degrading building facilities and resources
		V7	Exposure to external Network
		V11	Lack of sufficient personnel training and awareness
A3	Personal Computers	V3	Bogus time and attendance applications
		V5	Degrading building facilities and resources
		V7	Exposure to external Network
		V11	Lack of sufficient personnel training and awareness
A4	LAN Server	V3	Bogus time and attendance applications
		V5	Degrading building facilities and resources
		V7	Exposure to external Network
		V11	Lack of sufficient personnel training and awareness
A6	Company Documents	V3	Bogus time and attendance applications
		V5	Degrading building facilities and resources
		V7	Exposure to external Network
		V11	Lack of sufficient personnel training and awareness

MOT Controls

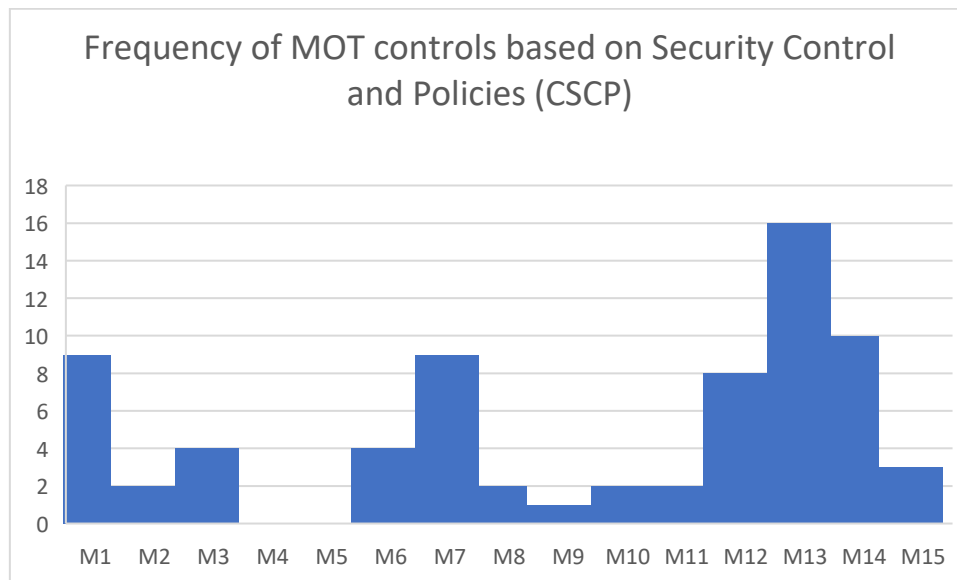
Management	Operational	Technical
Policies (M1)	Personnel/User issues (M6)	Identification and Authentication (M12)
Program Management(M2)	Preparing for Contingencies and Disasters (M7)	Logical Access Control (M13)
Risk Management (M3)	Incident Reporting and Handling (M8)	Audit Controls (M14)
Life Cycle Planning (M4)	Awareness, Training and Education (M9)	Cryptography (M15)
Assurance (M5)	Security Consideration in Support and Operations (M10)	
	Physical and Environmental Security (M11)	

List of Current Security Control and Policies (CSCP)

CSCP ID	Category	Description	MOT Controls
CSCP1	General Purpose	Only System administrators are authorized to establish login IDs and credentials on multiuser HGA systems	M12, M13
CSCP2		Access to the HGA system is restricted to HGA employees and contract personnel only after obtaining a written authorization from the department supervisor.	M1, M13
CSCP3		Mandatory security awareness and training course or an interactive computer-aided-instruction training session along with signed acknowledgement that they understand their security responsibilities.	M9, M1
CSCP4		Compliance with password selection and security procedures.	M12, M13
CSCP5		Use of automated access control mechanisms to protect data from risk of exposure to unauthorized individuals.	M13, M15
CSCP6		Restrictions on access to disclosure sensitive information to only authorized personnel who need it.	M13, M1
CSCP7		Compliance with the Privacy Act to protect personnel information	M1, M3
CSCP8		Verification of employee date and time sheet by Time and attendance clerk using the I&A application on the LAN server.	M12, M14
CSCP9		Review of date and time sheets, along with the corrections by at least two authorized individuals	M8, M14
CSCP10	Protection against Unauthorized execution	Only Time and Attendance supervisors can approve and submit data or subsequent corrections to the mainframe.	M6, M14
CSCP11		Supervisors are restricted from approving their own time and attendance data.	M6, M14
CSCP12		Only the system administrator holds privilege to assign special access control privilege to server programs	M13, M1

CSCP13		Restrictions on administrators to access or execute anything other than those related to configuring the accounts, passwords, and access permissions for clerks and supervisors	M13, M1
CSCP14		Prohibition by policy imposed on administrators to enter, modify or submit time and attendance data via the time and attendance application or other mechanisms	M1, M3
CSCP15		Execution of commands on server, restricting the PC to be used only as a terminal relaying commands to server to protect against unauthorized access	M13, M14
CSCP16	Protection Against Payroll Errors	Verification of time and attendance entries by double entry of T&A clerks	M7, M14
CSCP17		Sanity checks on the attendance entries	M7, M3
CSCP18		Assignment of duties and responsibilities to Director of Personnel to overview and handle payroll related issues	M6, M2
CSCP19		Suspension of pay to a terminated employee with immediate effect	M6, M3
CSCP20	Protection Against Accidental Corruption or Loss of Payroll Data	Regular Data Backups of Server disks	M7, M14
CSCP21		Additional backup of time and attendance data on the server of HGA for atleast 1 year and archived for 3 years	M7, M14
CSCP22		Access Control Files for online files at the time of submissions to the mainframe are automatically set to read-only	M13, M1
CSCP23		Regular check and reporting implemented to notify agencies that need to submit attendance on time	M8, M7
CSCP24		Agreement with nearby agencies to reserve computational and storage capacities sufficient to	M7, M2

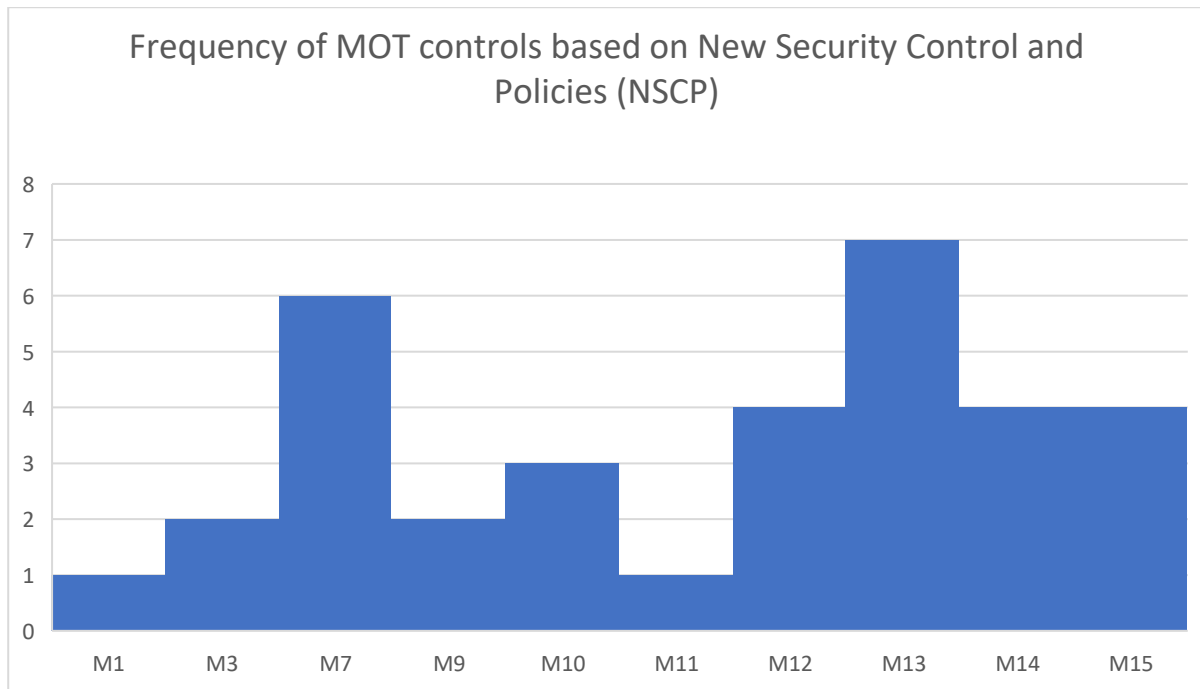
		support HGAs system operations during emergency	
CSCP25		Regular LAN server backups and secure storage to a sister agency	M7, M10
CSCP26		Additional Inventory for emergency or uninterrupted of regular business operations	M10, M7
CSCP27		Secure Storage of time and attendance paper documents	M11, M7
CSCP28	Protection Against Interruption of Operations	Key lock mechanism for PC and the office in which the PC is located when not in use	M11, M13
CSCP29		Restriction on access to files based on group oriented controls	M13, M1
CSCP30		Special Configurations in place to distinguish incoming requests and data packets between email or other types of requests	M15, M13
CSCP31	Protection Against Network Related Threads	Special Configurations to allow WAN interface device to access only programs with a special access control privilege	M15, M13, M14



List of New Security Control and Policies (NCSP) proposed by CISOs team

NSCP ID	Category	Description	MOT Controls
NSCP1		Use of Stronger authentication mechanisms based on smart tokens to generate OTPs that cannot be used for subsequent sessions	M12, M13

NSCP2	Payroll Fraud	Improving server's administrative procedures and fixing security related bugs by applying patches provided by the vendor	M7, M3
NSCP3		Improve monitoring of Server's access control configuration	M13, M14
NSCP4		Integrating the use of digital signatures into smart tokens to verify and maintain integrity and non-repudiation	M15, M12
NSCP5	Payroll error	Necessity to establish incentive and penalty based compliance approach	M6, M7
NSCP6		Quarterly compliance audit report	M7, M14
NSCP7	Continuity of Operations	Periodic internal training and awareness sessions for COG personnel	M9, M1
NSCP8		Improve adherence to its virus prevention procedures	M10, M7
NSCP9		Regular backup services provided by COG to about 5% of HGA's PCs along with quarterly reminder to every PC user to perform system backup	M7, M10
NSCP10	Information Disclosure	Improvement in security awareness trainings	M9, M1
NSCP11		Installation of screen-locks software on PCs to automatically lock any PC after specific period of idle time	M11, M13
NSCP12		Maintaining and reviewing an activity log on the server	M14, M13
NSCP13		Use of hard-disk encryption utilities	M15, M13
NSCP14	Network Related Threats	Require Stronger I&A for dial-in access	M12, M13
NSCP15		Restricted version of the mail utility be provided for dial-in, which would prevent a user from including files in outgoing mail messages.	M13, M7
NSCP16		replace its current modem pool with encrypting modems	M15, M7
NSCP17		Implementing an encrypted channel for communication between server and mainframe over the WAN.	M15, M10



Optimized Security Risk Prevention Strategy: Security Risk (\$) calculations by implementing proposed controls by new CISO, missing MOT controls, 2-Factor Authentication, VPN and DMZ. Estimate a Risk Prevention budget. Compare the list of current HGA controls plus CISO proposed prevention controls plus missing MOT prevention controls plus 2-Factor Authentication, VPN and DMZ risk controls to the 178 risk controls from Common Criteria

Proposed Controls:

- **New CISO Controls**
- **Missing MOT Controls**
- **2-Factor Authentication**
- **VPN**
- **DMZ**

Risk Prevention Budget: \$20000

VPN- <https://nordvpn.com/blog/how-much-does-a-vpn-cost/>

DMZ- <https://itprice.com/cisco-gpl/dmz>

	T1	T4	T5	T6
V3 on assets A1, A3, A6	50	45	40	40
V5 on assets A3, A4, A6	40	40	45	50
V7 on assets A1, A3, A4, A6	40	50	50	45
V11 on assets A1, A3, A4, A6	20	25	30	20

Residual Asset Security Risk:

Risk of Asset A1: $\$95000 * (50+45+40+40+40+50+50+45+20+25+30+20) / 100 = \384750

Risk of Asset A3:

$\$90000 * (50+45+40+40+40+40+45+50+40+50+50+45+20+25+30+20) / 100 = \567000

Risk of Asset A4: $\$85000 * (40+40+45+50+40+50+50+45+20+25+30+20) / 100 = \386750

Risk of Asset A6:

$\$85000 * (50+45+40+40+40+40+45+50+40+50+50+45+20+25+30+20) / 100 = \535500

Residual Vulnerability Security Risk:

Risk due to V3: $[\$95000 * (50+45+40+40) + \$90000 * (50+45+40+40) + \$85000 * (50+45+40+40)] / 100 = \472500

Risk due to V5: $[\$90000 * (40+40+45+50) + \$85000 * (40+40+45+50) + \$85000 * (40+40+45+50)] / 100 = \455000

Risk due to V7: $[\$95000 * (40+50+50+45) + \$90000 * (40+50+50+45) + \$85000 * (40+50+50+45) + \$85000 * (40+50+50+45)] / 100 = \656750

Risk due to V11: $[\$95000 * (20+25+30+20) + \$90000 * (20+25+30+20) + \$85000 * (20+25+30+20) + \$85000 * (20+25+30+20)] / 100 = \337250

Ranking of Security Asset Residual Risks:

Asset	Security Residual Risk	Ranking
A3	\$567000	1
A6	\$535500	2
A4	\$386750	3
A1	\$384750	4

Ranking of Vulnerability Security Risks:

Vulnerability	Vulnerability Security Risk	Ranking
V7	\$656750	1
V3	\$472500	2
V5	\$455000	3
V11	\$337250	4

Security Risk Response (Resilience) Strategy: Security Risk (\$) calculations by implementing proposed controls by new CISO, missing MOT controls, Redundant Server and Mirror Site. Estimate a Risk Response budget. Compare the list of current HGA controls plus CISO

proposed prevention controls plus missing MOT prevention controls plus Redundant Server and Mirror Site risk controls to the 178 risk controls from Common Criteria

Proposed Controls:

- **New CISO**
- **Missing MOT Controls**
- **Redundant server**
- **Mirror Site**

Risk Prevention Budget: \$30000

Redundant Server: <https://www.itsasap.com/blog/server-cost>

Mirror Site: <https://www.mirrorweb.com/pricing>

	T1	T4	T5	T6
V3 on assets A1, A3, A6	50	45	40	40
V5 on assets A3, A4, A6	40	40	45	50
V7 on assets A1, A3, A4, A6	20	30	30	25
V11 on assets A1, A3, A4, A6	20	25	30	20

Assets	T1* V3	T1* V5	T1* V7	T1* V11	T4* V3	T4* V5	T4* V7	T4* V11	T5* V3	T5* V5	T5* V7	T5* V11	T6* V3	T6* V5	T6* V7	T6* V11
A1	45	54	54	36	36	45	49.5	54	36	54	49.5	58.5	58.5	40.5	45	36
A3	50	60	60	40	40	50	55	60	40	60	55	65	65	45	50	40
A4	50	60	60	40	40	50	55	60	40	60	55	65	65	45	50	40
A6	0	60	60	40	0	50	55	60	0	60	55	65	0	45	50	40

Residual Asset Security Risk:

Risk of Asset A1:

$\$95000 * (40 + 30 + 30 + 55 + 30 + 20 + 30 + 15 + 25 + 20 + 20 + 15 + 30 + 50 + 55 + 30) * 0.9 / 100 = \423230

Risk of Asset A3:

$\$90000 * (40 + 30 + 30 + 55 + 30 + 20 + 30 + 15 + 25 + 20 + 20 + 15 + 30 + 50 + 55 + 30) / 100 = \445500

Risk of Asset A4:

$\$85000 * (40 + 30 + 30 + 55 + 30 + 20 + 30 + 15 + 25 + 20 + 20 + 15 + 30 + 50 + 55 + 30) / 100 = \420750

Risk of Asset A6: $\$85000 * (30 + 20 + 30 + 15 + 25 + 20 + 20 + 15 + 30 + 50 + 55 + 30) / 100 = \289000

Residual Vulnerability Security Risk:

Risk due to V3: $[\$95000*(40+30+30+58.5)0.9+\$90000*(40+30+30+65)+\$85000*(40+30+30+65)]/100 = \409490

Risk due to V5: $[\$90000*(30+20+30+40.5)0.9+\$85000*(30+20+30+45)+\$85000*(30+20+30+45)]/100 = \329180

Risk due to V7: $[\$95000*(25+20+20+45)+\$90000*(25+20+20+45)+\$85000*(25+20+20+45)+\$85000*(25+20+20+45)]/100 = \278550

Risk due to V11: $[\$95000*(15+20+25+15)+\$90000*(15+20+25+15)+\$85000*(15+20+25+15)+\$85000*(15+20+25+15)]/100 = \571730

Ranking of Security Asset Residual Risks:

Asset	Security Residual Risk	Ranking
A3	\$445500	1
A1	\$423230	2
A4	\$420750	3
A6	\$289000	4

Ranking of Vulnerability Security Risks:

Vulnerability	Vulnerability Security Risk	Ranking
V11	\$571730	1
V3	\$409490	2
V5	\$329180	3
V7	\$278550	4

Optimized Security Risk Mixed Strategy: Create a list of the Optimal sequence of proposed prevention and response security controls to minimize Security Risk and a list of the Optimal sequence of proposed prevention and response controls to maximize ROI. Estimate a Mixed Strategy budget to minimize Asset Risk. Estimate a Mixed Strategy budget to maximize ROI

Proposed Controls:

- **2-Factor Authentication**
- **VPN**
- **DMZ**
- **Redundant server**
- **Mirror site**
- **New CISO Recommendations**

Optimal Sequence to Maximize ROI:

- **2-Factor Authentication**
- **VPN**
- **New CISO recommendation**
- **Missing MOT Controls**
- **DMZ**
- **Redundant server**
- **Mirror Site**

Security Control Budget: \$ 50000

	T1	T4	T5	T6
V3 on assets A1, A3, A6	30	25	20	20
V5 on assets A3, A4, A6	40	40	45	50
V7 on assets A1, A3, A4, A6	40	50	50	45
V11 on assets A1, A3, A4, A6	40	45	50	40

Residual Asset Security Risk:

Risk of Asset A1: $\$95000 \times (30+25+20+20+40+50+50+45+40+45+50+40)/100 = \432250

Risk of Asset A3:

$\$90000 \times (30+25+20+20+40+40+45+50+40+50+50+45+40+45+50+40)/100 = \567000

Risk of Asset A4: $\$85000 \times (40+40+45+50+40+50+50+45+40+45+50+40)/100 = \424750

Risk of Asset A6:

$\$85000 \times (30+25+20+20+40+40+45+50+40+50+50+45+40+45+50+40)/100 = \535500

Residual Vulnerability Security Risk:

Risk due to V3:

$[\$95000 \times (30+25+20+20) + \$90000 \times (30+25+20+20) + \$85000 \times (30+25+20+20)]/100 = \256500

Risk due to V5:

$[\$90000 \times (40+40+45+50) + \$85000 \times (40+40+45+50) + \$85000 \times (40+40+45+50)]/100 = \455000

Risk due to V7:

$[\$95000 \times (40+50+50+45) + \$90000 \times (40+50+50+45) + \$85000 \times (40+50+50+45) + \$85000 \times (40+50+50+45)]/100 = \372750

Risk due to V11:

$[\$95000 \times (40+40+50+40) + \$90000 \times (40+45+50+40) + \$85000 \times (40+45+50+40) + \$85000 \times (40+45+50+40)]/100 = \674500

Ranking of Residual Asset risk

Asset	Security Residual Risk	Ranking
A3	\$567000	1
A6	\$535500	2
A1	\$432250	3
A4	\$424750	4

Ranking of Vulnerability Security Risks:

Vulnerability	Vulnerability Security Risk	Ranking
V11	674500	1
V5	455000	2
V7	372750	3
V3	256500	4

From the Analysis, we take V11 as it impacts maximum assets

Total Residual Asset Security Risk – \$1989500

Control Measures	Preventive Budget	Response Budget	Combined Strategy Budget
Mitigating falsification of timesheets and data manipulation by employees	\$7500	\$8500	\$11000
Enhancing access control management	\$3500	\$9000	\$16000
Improving audit logging to prevent insufficiencies	\$3000	\$7500	\$14000
Strengthening employee training and awareness programs	\$6000	\$5000	\$90000
Total	\$20000	\$30000	\$50000

Conclusion: Risk Reduction and ROI Analysis

The security risk assessment for HGA demonstrates that the organization has effectively identified and prioritized its key assets, threats, and vulnerabilities, ensuring a comprehensive risk management strategy. The analysis revealed critical vulnerabilities in major assets such as A1(Financial Resources),A3(Personal Computer),A4(LAN Server), and A6(Company Documents). While the existing security controls were robust, enhancements were required to address evolving threats such as unauthorized access, data breaches, and system failures.

The integration of both existing and newly proposed CISO security controls, including improvements in Management, Operational, and Technical (MOT) controls, significantly strengthened the security posture of HGA's information systems. Additional measures, such as multi-factor authentication, VPN implementation, and the establishment of a Demilitarized

Zone (DMZ), were strategically integrated to enhance access control, strengthen authentication mechanisms, and provide an additional layer of protection against cyber threats.

Did the HGA team address all security risks based on the risk assessment?

The HGA team has taken significant steps to mitigate the most critical security risks identified in the assessment. The implemented security controls effectively address key vulnerabilities, including:

- **Falsification of data (e.g., timesheets) by employees** – Addressed through stricter access controls and audit logging.
- **Improper access control management** – Mitigated by implementing role-based access control (RBAC) and multi-factor authentication (MFA).
- **Insufficient or improper audit logging** – Enhanced through improved logging mechanisms to ensure accountability and traceability.
- **Lack of personnel training and awareness** – Handled by introducing mandatory cybersecurity training and awareness programs.

While these measures significantly reduce risk, some residual security gaps may persist, particularly in areas such as:

- **Advanced persistent threats (APTs) and insider threats** – Require continuous monitoring, behavioral analysis, and threat intelligence integration.
- **Real-time incident response capabilities** – Could be improved with automated threat detection and response mechanisms.
- **Third-party security risks** – Need further scrutiny, especially in vendor and supply chain security assessments.

Overall, while the HGA team has effectively mitigated most risks, continuous assessment, monitoring, and adaptive security enhancements are recommended to maintain a robust cybersecurity posture.

Does the Residual Risk Reduction Exceed the Budget for Proposed Controls?

Based on the risk assessment and budget analysis, the residual risk reduction does **exceed** the budget for the proposed controls. This indicates that the security measures implemented provide substantial risk mitigation benefits relative to their cost.

Key observations:

- The **Risk Prevention Budget** of **\$20,000** significantly reduces vulnerabilities by proactively preventing security incidents.
- The **Risk Response Budget** of **\$30,000** ensures resilience and rapid recovery from potential breaches.
- The **Mixed Strategy Budget** of **\$50,000** provides the most balanced approach, combining preventive and responsive controls for maximum security coverage.

Our ROI analysis suggests that the security risk reduction achieved through these investments outweighs the financial cost, making the proposed strategy **cost-effective and justified**.

However, while the current budget effectively reduces risks, continued investments in monitoring, automation, and emerging threat mitigation strategies will further enhance long-term security.

What is the (expected overall security risk reduction Benefit) / (proposed overall security risk budget Cost) ROI ratios for each of the 4 budgets in XIII?

Formula,

$$\text{Reduction} = \text{Initial Risk Impact} - \text{Risk After Implementing Strategy}$$

Using the above formula for Prevention , Resilience and Mixed Strategies we get

Asset A1

Prevention Residual Risk: **\$384750** Initial Risk Impact(Prevention): **\$508250**

Response Residual Risk: **\$423230** Initial Risk Impact(Response): **\$508250**

Mixed Residual Risk: **\$432250** Initial Risk Impact(Mixed): **\$508250**

$$\text{Reduction(Prevention)} = \$508250 - \$384750 = \$123500$$

$$\text{Reduction(Response)} = \$508250 - \$423230 = \$85020$$

$$\text{Reduction(Mixed)} = \$508250 - \$432250 = \$76000$$

Asset A3

Prevention Residual Risk: **\$567000** Initial Risk Impact(Prevention): **\$639000**

Response Residual Risk: **\$445500** Initial Risk Impact(Response): **\$639000**

Mixed Residual Risk: **\$567000** Initial Risk Impact(Mixed): **\$639000**

$$\text{Reduction(Prevention)} = \$639000 - \$567000 = \$72000$$

$$\text{Reduction(Response)} = \$639000 - \$445500 = \$193500$$

$$\text{Reduction(Mixed)} = \$639000 - \$567000 = \$72000$$

Asset A4

Prevention Residual Risk: **\$386750** Initial Risk Impact(Prevention): **\$454750**

Response Residual Risk: **\$420750** Initial Risk Impact(Response): **\$454750**

Mixed Residual Risk: **\$424750** Initial Risk Impact(Mixed): **\$454750**

$$\text{Reduction(Prevention)} = \$454750 - \$386750 = \$68000$$

$$\text{Reduction(Response)} = \$454750 - \$420750 = \$34000$$

$$\text{Reduction(Mixed)} = \$454750 - \$424750 = \$30000$$

Asset A6

Prevention Residual Risk: **\$535500** Initial Risk Impact(Prevention): **\$603500**

Response Residual Risk: **\$289000** Initial Risk Impact(Response): **\$603500**

Mixed Residual Risk: **\$535500** Initial Risk Impact(Mixed): **\$603500**

Reduction(Prevention) = **\$603500 - \$535500 = \$68000**

Reduction(Response) = **\$603500 - \$289000 = \$314500**

Reduction(Mixed) = **\$603500 - \$535500 = \$68000**

Therefore,

Total Reduction Prevention Strategy

\$123500+\$72000+\$68000+\$68000 = \$331500

Total Reduction Response Strategy

\$85020+\$193500+\$34000+\$314500 = \$627020

Total Reduction Mixed Strategy

\$76000+\$72000+\$30000+\$68000 = \$246000

In summary, the Response Strategy offers the largest overall risk reduction, with a total of \$627,020, according to the examination of security risk reduction techniques. Compared to the Prevention and Mixed Strategies, which saw reductions of \$331,500 and \$246,000, respectively, this result demonstrates how well it mitigates possible dangers. The significant difference implies that an organization's resilience against security threats can be significantly increased by concentrating on response measures, such as incident handling, recovery procedures, and quick mitigation strategies.

Even if the Response Strategy reduces risk the most, the related implementation costs should be taken into account when choosing a strategy. The Prevention Strategy can be a more economical course of action if financial restraints are a major consideration, offering a fair decrease at possibly reduced expenses. The Mixed Strategy, on the other hand, achieves the lowest total reduction despite its balanced approach, suggesting that allocating resources between preventive and response may lessen their respective efficacy. In the end, choosing the appropriate course of action should strike a balance between the anticipated security advantages and the necessary financial outlay, guaranteeing the most return on investment given the particular risk environment and financial constraints of the company.

Do you recommend a Risk Prevention Strategy or a Risk Response Strategy or a combination such as a Risk reduction strategy or Risk ROI maximization Mixed Strategy?

Considering the comprehensive risk assessment, budget allocations, and ROI analysis, the **Risk Response Strategy** stands out as the most cost-effective approach. With a moderate budget of **\$30,000**, it achieves the highest overall risk reduction of **\$627,020**, demonstrating its strong capability in ensuring organizational resilience. This strategy focuses on the ability to detect, respond to, and recover from security incidents swiftly, minimizing the impact on operations. It is particularly advantageous for environments where rapid recovery from breaches is critical, ensuring business continuity even in the face of sophisticated threats.

On the other hand, the **Risk Prevention Strategy**, with a budget of **\$20,000**, also offers considerable value, achieving a substantial risk reduction of **\$331,500**. This proactive approach is designed to minimize vulnerabilities and prevent incidents before they occur. It is highly effective for organizations that prioritize strong security controls to reduce the likelihood of breaches, thereby lowering long-term risks and potential operational disruptions.

The **Mixed Strategy**, requiring the highest investment of **\$50,000**, provides a balanced approach that integrates both preventive and responsive measures. Although its total risk reduction of **\$246,000** is lower compared to the Response Strategy, it offers comprehensive security coverage. This strategy is well-suited for organizations facing a wide range of threats, as it combines the strengths of proactive defense with the capability to respond effectively to incidents when they occur.

Ultimately, the choice between these strategies depends on the organization's specific risk tolerance, security objectives, and resource availability. Organizations with a high emphasis on operational resilience may find the Risk Response Strategy more beneficial, while those focusing on minimizing threats before they materialize may lean towards the Risk Prevention Strategy. For environments where a holistic security posture is paramount, the Mixed Strategy offers a well-rounded solution that balances prevention and response effectively.

Part B Security Risk Management Implementation Plan for Capgemini

Organization Name: CAPGEMINI

Entity: IT, Consulting, Outsourcing.

Department: Capgemini, founded in 1967 by Serge Kampf, is a global leader in consulting, technology services, and digital transformation. Headquartered in Paris, France, the company operates in over 50 countries with a diverse team of approximately 340,000 employees.

The company offers a wide range of services, including strategy and transformation consulting, technology implementation, and outsourcing solutions. Capgemini leverages expertise in cloud computing, data analytics, artificial intelligence, connectivity, software development, digital engineering, and platforms to address the comprehensive needs of businesses across various industries.

With a strong heritage spanning over five decades, Capgemini is committed to unlocking the value of technology to drive business transformation. The company's mission is to unleash human energy through technology for an inclusive and sustainable future, making technology accessible and ethical for clients and society at large

Implementation Controls and Policies

1. Access Control Security Risk Management Implementation Controls and Policies

a. Identification Credentials

Identification is the process of asserting an identity to access a system or resource. It forms the first step in access control by establishing who the user claims to be.

- **User IDs:** Unique usernames are assigned to individuals to differentiate and trace user activity within a system.
- **Corporate Email-Based Identifiers:** Organization-provided emails are used as identifiers for login and access across systems.
- **Smart Cards & Access Badges:** Physical cards containing embedded information are issued for logical and physical identification.
- **RFID-Based Access Control:** RFID-enabled badges allow for wireless, secure identification when entering restricted areas.
- **Digital Certificates:** PKI certificates provide cryptographic proof of identity for secure digital communication.

b. Personal Authentication

Authentication confirms that the user is indeed who they claim to be by validating the credentials presented during identification.

- **Passwords:** The most basic form of authentication; requires adherence to strong password policies for effectiveness.
- **Multi-Factor Authentication (MFA):** Involves two or more verification methods (e.g., password + OTP or biometric) for enhanced security.
- **Hardware & Software Tokens:** Tokens generate time-based or event-based OTPs to ensure secure and dynamic authentication.
- **Biometric Verification:** Uses physiological traits like fingerprints for high-assurance user validation.
- **Physical Token Authentication:** Involves physical devices such as USB tokens that users must possess to gain access.
- **Continuous Authentication:** Monitors user behavior in real-time to maintain authentication during a session.

c. Authorization

Authorization defines what resources an authenticated user can access and what actions they can perform based on defined policies.

- **Role-Based Access Control (RBAC):** Access rights are assigned according to roles within the organization to enforce least privilege.
- **Attribute-Based Access Control (ABAC):** Access decisions are based on user attributes (e.g., department, clearance level).
- **Access Control Lists (ACLs):** Lists specifying user permissions for system objects like files, directories, or services.
- **Deny-by-Default Policy:** A security model where access is blocked unless explicitly allowed, minimizing exposure.
- **Temporary Security Tokens:** Session-based credentials expire after use or time, limiting risk from persistent access.

d. Logical Access Control Methods

Logical access controls safeguard digital systems by controlling user access through software and configuration settings.

- **Firewalls & Network Segmentation:** These isolate and filter network traffic to prevent unauthorized access to sensitive areas.
- **Encryption Standards:** Encryption (like AES, TLS) protects data confidentiality both in storage and during transmission.
- **Virtual Private Network (VPN):** VPNs encrypt communication over public networks to allow secure remote access.
- **Network Access Control (NAC) Systems:** NAC verifies device compliance with security policies before granting network access.
- **Intrusion Detection and Prevention Systems (IDS/IPS):** These systems detect and stop malicious activities on the network.
- **Port Authentication (802.1X):** Requires user authentication at network ports before access is granted to the network.

e. Physical Access Control Methods

Physical access controls limit entry to secure facilities or areas using mechanical or electronic barriers and procedures.

- **Security Personnel & Attended Access:** Guards at entry points verify identities and monitor visitor access.
- **Electronic Door Locks & Keycards:** Electronic systems regulate access to restricted spaces using access cards.
- **CCTV Surveillance:** Surveillance systems monitor activities to deter unauthorized physical access and maintain records.

- **Turnstiles & Biometric Entry Points:** Mechanical barriers combined with biometric readers enhance entry security.
- **Secure Server Rooms:** Data centers are protected with multi-layer physical controls and restricted access.

f. Biometric Systems

Biometrics authenticate users based on unique physical or behavioral traits, offering high security with minimal user burden.

- **Fingerprint Scanners:** Widely used for fast and reliable biometric identification.
- **Biometric & PIN-Based Authentication:** Combines something users are (biometrics) with something they know (PIN) for stronger access control.
- **Access Control via Smart Biometric ID Cards:** These cards embed biometric data for dual-layer identity verification.
- **Facial Recognition:** Uses facial features to identify users, though it may be limited by lighting or pose conditions.
- **Iris Scanning:** Scans the unique patterns in a person's iris for highly accurate authentication, used in high-security environments.
- **Voice Recognition:** Identifies users based on vocal characteristics; can be used in call centers or hands-free systems.
- **Hand Geometry Recognition:** Measures hand size and finger length; suitable for general access control but less precise than other biometrics.
- **Behavioral Biometrics:** Tracks behavioral patterns like typing rhythm or mouse use for continuous authentication.

2. Network Infrastructure Security Risk Management Implementation Controls and Policies

a. Enclave Protection Controls

An enclave is a secure network segment designed to protect sensitive data and critical services. Enclave protection involves network segmentation, access control, and monitoring to prevent unauthorized access and cyber threats. It includes restricted LAN segments supporting services like internal DNS (split DNS), AD DC, mail servers, FTP, proxies, and more.

- **Defense-in-Depth Strategy:**
Multi-layered security ensures that a breach in one layer does not compromise the enclave. Deploy firewalls, IDS/IPS, encryption, and endpoint protection to provide redundancy.
- **Restricted LAN Segmentation:**
Internal services are segmented using VLANs to prevent lateral movement and reduce attack surface. Services like AD, DNS, and file servers should be isolated. Wireless IDS (WIDS) and unpredictable IPv6 addresses enhance network security.

- **Backdoor Connection Prevention:**
Direct site-to-site connections bypassing perimeter defenses must be prohibited. Regular route audits help identify unauthorized backdoor links that can evade firewalls and IDS.
- **Infrastructure Monitoring and Incident Response:**
Maintain up-to-date network diagrams with IDS/firewall placements. Deploy SIEM tools for centralized logging and anomaly detection. Include external IDS, leased lines, and ISP filtering in infrastructure visibility.

b. Firewall Security Controls

A firewall is a network security device that filters and controls traffic between trusted and untrusted zones. It protects against unauthorized access, IP spoofing, buffer overflows, ICMP tunneling, and other network-based threats.

- **Packet Filtering and Stateful Inspection:**
Layer 3 filters restrict traffic by IP and port. Stateful firewalls track session states and block unauthorized communication flows, enhancing security over basic filtering.
- **Deep Packet Inspection (DPI) and Content Filtering:**
DPI scans traffic payloads for malicious content. Proxy-based filtering blocks risky content such as Java applets, ActiveX, and executables. DPI firewalls can integrate IDS signatures for deeper analysis.
- **DMZ Implementation and Multi-Firewall Strategy:**
Deploy segmented DMZs with distinct firewalls for public and internal zones. Limit external access to DMZ services only. Place sensors in the DMZ to monitor all incoming and outgoing traffic.
- **Firewall Hardening and Compliance:**
Disable unused ports and services to reduce vulnerabilities. Apply firmware updates and adopt a default-deny approach. Use hardened bastion hosts to secure firewall configurations.

c. Router Security Controls

Routers forward data between networks and are critical points of security control. Without proper protection, they are vulnerable to unauthorized access, data interception, and routing manipulation, especially in IPv6 environments.

- **Route Table Integrity and Authentication:**
Use static routes in sensitive zones to prevent route manipulation. Employ IPSec and SHA-2 authentication to secure routing updates and ensure integrity between peers.
- **Access Control and Router Hardening:**
ACLs restrict access to routers from trusted IPs. Enforce TACACS+/RADIUS for admin access, disable Telnet in favor of SSH v2, and disable vulnerable services like chargen, small echoes, and PAD.
- **Control Plane Protection (CPP):**
Apply Infrastructure ACLs to filter control-plane traffic. Use Control Plane Policing

(CoPP) to protect CPU resources. Implement uRPF for source validation and to drop spoofed packets.

- **Data Plane Security:** Enable uRPF, DAI, and Port Security to prevent IP/MAC spoofing and address flooding. IPv6 tunnels should be filtered at both ends to prevent bypassing security through rogue packets.

3. Network Infrastructure Management Security Risk Management Implementation Controls and Policies

a. Ports, Protocols, and Services

Ensure only necessary communication channels are open across the enterprise network. This reduces the attack surface and enforces a Zero Trust approach.

- **Essential Port Filtering:** Implement strict firewall policies to allow only business-essential ports and protocols.
- **Zero Trust Enforcement:** Limit open ports to only necessary applications to reduce attack vectors.
- **Secure Protocols Usage:** Replace insecure protocols (Telnet, FTP, HTTP) with secure alternatives like SSH, SFTP, and HTTPS.
- **Regular Port Scanning:** Perform periodic scans using tools like Nmap or Nessus to detect unauthorized open ports.
- **Intrusion Prevention Systems (IPS):** Deploy IPS to monitor and block malicious traffic targeting critical ports.

b. Device Management

Centralized device control ensures endpoint compliance, reduces vulnerabilities, and enforces least privilege principles.

- **Centralized Endpoint Control:** Use SCCM or Intune to manage and configure endpoints organization-wide.
- **Strong Authentication:** Enforce certificate-based authentication (CBA) for secure access.
- **Patch Management:** Regularly update firmware, OS, and security tools on all devices.
- **Role-Based Access Control (RBAC):** Limit access privileges based on job roles to enforce least privilege.
- **Device Activity Logging:** Enable real-time logging and alerts for unauthorized changes to devices.

c. Device Monitoring

Proactive monitoring detects abnormal behavior, performance issues, and potential threats in real time.

- **Real-Time Monitoring Tools:** Use Splunk, SolarWinds, or ELK Stack for device health monitoring.
- **SNMP Integration:** Leverage SNMP for detailed metrics and alerts on network hardware.
- **SIEM Integration:** Feed device logs into SIEM systems for centralized threat correlation.
- **Vulnerability Scanning:** Use tools like Qualys or Tenable.io to find weaknesses across devices.
- **Automated Alerting:** Set up anomaly detection and alerts for suspicious activity.

d. Network Authentication, Authorization, and Accounting (AAA)

AAA ensures secure user identification, appropriate access rights, and traceable activity logs across the network.

- **Centralized Authentication:** Use Cisco ISE or Microsoft NPS for network login management.
- **Multi-Factor Authentication (MFA):** Enforce MFA, especially for privileged user accounts.
- **Directory-Based Access:** Leverage Active Directory with RADIUS or TACACS+ for secure logins.
- **Audit Logging:** Maintain detailed records of authentication and access events for forensics.
- **Access Reviews:** Periodically remove inactive or unnecessary user permissions.

e. Network Intrusion Detection System (NIDS)

NIDS detects suspicious traffic and intrusions on the network in real time, improving threat visibility.

- **Detection Tools:** Deploy Snort, Suricata, or Cisco Firepower as network sensors.
- **Signature Updates:** Regularly update detection rules to respond to new threats.
- **SIEM Integration:** Link NIDS logs to SIEM to correlate and investigate security events.
- **Automated Response:** Set up blocklists or containment measures for high-severity detections.
- **Penetration Testing:** Conduct regular tests to validate NIDS configuration and effectiveness.

f. Switches and VLANs

Proper switch configuration and VLAN segmentation ensure secure, isolated, and efficient network traffic management.

- **VLAN Segmentation:** Separate network traffic by business unit or function.
- **MAC Filtering:** Control switch access by allowing only registered MAC addresses.

- **Port Security:** Disable unused ports and restrict MAC address changes on active ones.
- **ACL Enforcement:** Apply ACLs to limit inter-VLAN access on a need-to-know basis.
- **802.1X Authentication:** Require identity verification before allowing device connections to the network.

g. Virtual Private Network (VPN)

VPNs provide encrypted remote access, securing off-site communications and preventing unauthorized access.

- **Secure VPN Clients:** Use Cisco AnyConnect or GlobalProtect for encrypted remote connections.
- **Strong Encryption:** Enforce AES-256 encryption for all VPN tunnels.
- **MFA Integration:** Require MFA for all VPN logins to enhance security posture.
- **Access Controls:** Limit VPN access to only approved users and devices with time-based restrictions.
- **Monitoring & Logging:** Analyze VPN usage via SIEM to detect anomalies or potential breaches.

4. Database Security Risk Management Implementation Controls and Policies

a. Authentication – User Accounts:

Ensures that access is only granted to authorized users by enforcing strong password policies, MFA, RBAC, account management, and session timeouts.

- **Strong password policies:** Enforce password complexity requirements (e.g., minimum length, a mix of characters) and password expiration rules to prevent weak or outdated passwords. This ensures that only secure passwords are used, reducing the risk of unauthorized access.
- **Multi-factor authentication (MFA):** Require MFA for all privileged accounts to add an extra layer of protection beyond just a password. This significantly reduces the risk of account compromise due to stolen or guessed credentials.
- **Role-based access control (RBAC):** Assign user permissions based on their roles within the organization. This minimizes the risk of users gaining unauthorized access to sensitive data or systems they don't need for their role.
- **Inactive account management:** Automatically disable accounts that haven't been used for a predefined period. This reduces the attack surface by eliminating unused or forgotten accounts that could be exploited.
- **Session timeouts:** Implement automatic session timeouts for inactive users to limit the window of opportunity for attackers to hijack idle sessions, improving overall account security.

b. Authorization:

Prevents unauthorized access by implementing least privilege principles, RBAC, and attribute-based access control, along with robust access control monitoring.

- **Least privilege access control:** Ensure that users only have access to the resources and data they need to perform their duties. This minimizes the risk of unauthorized access and reduces the potential impact of an insider threat.
- **Role-based and attribute-based access control:** Implement a dual approach by using both RBAC and attribute-based access controls to refine access decisions based on user attributes (e.g., department, clearance level), providing more granular control over sensitive data.
- **Security labels and classifications:** Use data security labels and classifications to enforce access restrictions based on the sensitivity of the data. This ensures that only authorized individuals can access high-security data or systems.
- **Access control monitoring:** Continuously monitor changes to access controls to identify and respond to any anomalies that might indicate misconfigurations or potential security breaches.

c. Confidentiality:

Protects sensitive data through encryption at rest and in transit, column-level encryption, and data masking/anonymization.

- **Encryption at rest:** Use strong encryption algorithms like AES-256 to secure data at rest in the database, ensuring that sensitive data remains confidential even if the storage media is physically compromised.
- **Encryption in transit:** Implement TLS 1.2 or higher for all communications between systems to ensure that data transmitted over the network is protected from eavesdropping and tampering.
- **Column-level encryption:** Apply encryption at the column level for particularly sensitive fields (e.g., Social Security numbers, credit card data) in the database, ensuring that only authorized users can view or process sensitive data.
- **Data masking/anonymization:** Mask or anonymize data where possible, such as in non-production environments, to prevent unauthorized users from accessing sensitive information while still allowing operations to proceed.

d. Data Integrity:

Ensures the consistency and accuracy of data with transaction logging, cryptographic hashing, input validation, and enforcing referential integrity.

- **Transaction logging and auditing:** Enable detailed logging for all database transactions, including inserts, updates, and deletes. This provides an immutable record for tracking data changes, aiding in identifying potential integrity violations.
- **Hashing for integrity:** Use cryptographic hashes (e.g., SHA-256) to verify the integrity of data. This allows quick comparison of data states to ensure it has not been altered unexpectedly.

- **Input validation:** Apply strong input validation to all user inputs, sanitizing inputs to prevent SQL injection attacks. This ensures that only valid and safe data enters the system, reducing the risk of data corruption or security breaches.
- **Referential integrity:** Enforce referential integrity constraints in the database schema to maintain consistent relationships between database tables, preventing orphaned records or inconsistent data.

e. Auditing:

Tracks and monitors user activity, access logs, and anomalies to detect and respond to potential security threats or breaches.

- **Database activity monitoring:** Enable real-time monitoring and logging of database activity to track access to sensitive data, detect unauthorized actions, and ensure compliance with regulatory requirements.
- **User activity tracking:** Keep detailed records of user logins, failed login attempts, and privilege escalations. This helps identify suspicious behavior and provides an audit trail for investigation.
- **Log review:** Perform regular reviews of audit logs to detect potential security incidents or anomalies that may indicate a compromise. Automated tools can help flag abnormal behavior for faster detection.
- **Retention of logs:** Ensure that audit logs are retained according to regulatory compliance requirements (e.g., GDPR, HIPAA). Logs should be stored securely and be accessible for review when needed.

f. Replication and Federation:

Secures data replication processes and federated systems with encryption, access controls, and consistency checks.

- **Secure replication:** Ensure that all replication mechanisms are encrypted to prevent the exposure of sensitive data during replication processes, reducing the risk of data breaches.
- **Federated system security:** Implement access control and strong authentication for federated databases to secure cross-system communications, ensuring that only trusted parties can access and share data.
- **Consistency checks:** Regularly perform consistency checks on replicated databases to ensure that the data across multiple locations remains synchronized and accurate, preventing issues that could arise from inconsistent data.

g. Clustering:

Promotes high availability and data protection with load balancing, encrypted communication, and regular cluster failover tests.

- **Load balancing for high availability:** Use load balancing to distribute database traffic across multiple nodes to ensure high availability and reduce the risk of downtime due to a single point of failure.

- **Encrypted communication:** Secure communication channels between database clusters using encryption to protect data during transmission, preventing eavesdropping or tampering.
- **Cluster failover testing:** Regularly test the failover mechanism to ensure that in the event of a cluster node failure, operations continue seamlessly with minimal disruption.

h. Backup and Recovery:

Ensures the security and integrity of backup data through encryption, restoration testing, automated backup scheduling, and physical security of backup media.

- **Encrypted backups:** Store encrypted backups of critical data in secure, off-site locations to protect against data breaches, ensuring that backup data cannot be accessed by unauthorized personnel.
- **Backup restoration testing:** Periodically test backup restoration procedures to verify that backups are valid and can be restored quickly in the event of data loss or corruption.
- **Automated backup scheduling:** Implement automated backup schedules with clear retention policies to ensure that data is regularly backed up and can be restored within defined timeframes.
- **Physical backup security:** Ensure that backup media (e.g., tapes, disks) are securely stored and protected from physical theft or damage, further safeguarding critical data.

i. OS Protections:

Protects the underlying operating system with security patches, firewalls, IDS, and hardened configurations to reduce vulnerabilities.

- **Security patches and updates:** Regularly apply security patches and updates to the operating system hosting the database to mitigate known vulnerabilities and ensure the system remains secure.
- **Firewalls and intrusion detection:** Enable host-based firewalls and intrusion detection systems (IDS) on the operating system to monitor and block potential attacks targeting the database.
- **Hardened OS configurations:** Configure the operating system with security best practices, including disabling unnecessary services, to reduce the attack surface.

j. Application Protections:

Secures applications using secure coding practices, WAFs, and regular penetration testing.

- **Secure coding practices:** Adopt secure coding practices to prevent common vulnerabilities like SQL injection, cross-site scripting (XSS), and buffer overflows during application development.
- **Web application firewall (WAF):** Deploy a WAF to filter and monitor HTTP traffic, blocking malicious requests aimed at web applications and preventing exploits of application vulnerabilities.

- **Security assessments and penetration testing:** Regularly perform security assessments and penetration tests to identify and mitigate vulnerabilities within the database and application environments.

k. Network Protections:

Limits exposure through firewalls, network segmentation, VPNs for remote access, and continuous monitoring of network traffic.

- **Firewalls and segmentation:** Use firewalls and network segmentation to limit the database's exposure to only authorized users or systems, reducing the attack surface.
- **VPN for remote access:** Implement Virtual Private Networks (VPNs) for secure, encrypted remote access to the database, ensuring that only authenticated users can access the system remotely.
- **Network traffic monitoring:** Continuously monitor network traffic to detect and prevent potential threats such as Distributed Denial of Service (DDoS) attacks or unauthorized data exfiltration.

l. Security Design and Configuration:

Applies a defense-in-depth strategy and secure baseline configurations to safeguard systems and ensure alignment with security policies.

- **Defense-in-depth strategy:** Employ a layered security approach that includes multiple protective measures (e.g., firewalls, encryption, intrusion detection) to defend against various types of cyber threats.
- **Secure baseline configurations:** Implement and regularly review secure baseline configurations for all database installations, ensuring consistent application of security settings across systems.
- **Regular review of security policies:** Continuously evaluate and update security policies to reflect changes in the threat landscape, regulatory requirements, and organizational needs.

m. Enclave and Computing Environment:

Implements strict access controls, security label monitoring, and DoS protection mechanisms for secure and efficient operations.

- **Strict access controls:** Apply stringent access controls to privileged database accounts to ensure that only authorized personnel can access high-level configurations and data.
- **Security label monitoring:** Regularly monitor and audit changes to security labels and classifications to ensure proper access levels are maintained across systems.
- **DoS protection mechanisms:** Implement protection mechanisms, such as rate limiting or filtering, to prevent Denial of Service (DoS) attacks that could exhaust system resources and disrupt operations.

n. Business Continuity:

Ensures operational resilience through disaster recovery plans, recovery testing, and redundancy for critical resources.

- **Disaster recovery plans:** Develop and maintain a comprehensive disaster recovery plan (DRP) that includes specific procedures for database recovery, minimizing downtime in case of a disaster.
- **Testing recovery procedures:** Regularly test recovery procedures to ensure they are effective and can be executed quickly during a real disaster, ensuring business continuity.
- **Redundancy for critical resources:** Ensure that critical database components (e.g., servers, storage) have redundant counterparts, reducing the risk of single points of failure.

o. Vulnerability and Incident Management:

Detects and responds to vulnerabilities and incidents with regular scans, testing, and personnel training to ensure preparedness.

- **Continuous vulnerability scanning:** Regularly scan the database and associated systems for vulnerabilities, ensuring that all potential weaknesses are addressed promptly.
- **Incident response plans:** Create and maintain detailed incident response plans that outline procedures to follow in the event of a database security breach, ensuring a timely and coordinated response.
- **Security testing:** Conduct regular security assessments, penetration testing, and vulnerability scanning to identify weaknesses and assess the effectiveness of existing security measures.
- **Training personnel:** Train database administrators and security personnel on incident response and best practices for securing database environments, ensuring they are prepared to handle potential security incidents.

5. Applications Development Security Risk Management Implementation Controls and Policies

a. Program Management - Program management ensures that all cybersecurity efforts are aligned with organizational goals, monitored, and adjusted for continual improvement. The focus is on governance, resource allocation, and risk management.

- **Cybersecurity Governance**
 - Establish a governance framework for cybersecurity policies, standards, and procedures.
 - Ensure that the program aligns with business goals and risk tolerance.
 - Designate a Chief Information Security Officer (CISO) to lead the cybersecurity strategy.
- **Risk Management**

- Conduct regular risk assessments to identify and prioritize cybersecurity risks.
- Implement a risk management framework (e.g., NIST, ISO 27001) to guide decisions.
- Monitor risks continuously and apply mitigations for emerging threats.
- **Resource Allocation**
 - Ensure adequate resources (personnel, tools, funding) are allocated to cybersecurity initiatives.
 - Regularly review the program budget to ensure it meets evolving cybersecurity needs.
- **Security Metrics and KPIs**
 - Develop key performance indicators (KPIs) and metrics to track the effectiveness of the cybersecurity program.
 - Use metrics such as incident response times, compliance levels, and vulnerability management success to measure progress.
- **Compliance and Regulatory Adherence**
 - Maintain compliance with industry regulations (e.g., GDPR, HIPAA, PCI DSS).
 - Regularly update policies and procedures to stay aligned with changing legal requirements.
- **Continuous Improvement**
 - Implement a process for continuous improvement of the cybersecurity program based on lessons learned from incidents, audits, and threat intelligence.
 - Conduct post-incident reviews and audits to identify areas for enhancement.

b. Application Data Handling

Application data handling controls ensure the confidentiality, integrity, and availability of sensitive data through encryption, access management, and secure storage practices.

- **Data Classification and Labeling**
 - Classify data based on sensitivity (e.g., Public, Confidential, Restricted).
 - Ensure appropriate data labeling to prevent unauthorized access.
- **Data Encryption**
 - Encrypt data at rest using FIPS 140-2 certified algorithms.
 - Encrypt data in transit using TLS or IPSec.

- **Access Control**
 - Implement role-based access control (RBAC) or attribute-based access control (ABAC).
 - Enforce least privilege principles for data access.
- **Data Masking and Anonymization**
 - Mask sensitive data in non-production environments.
 - Apply anonymization techniques for analytics and research.
- **Data Retention and Disposal**
 - Implement secure data retention policies.
 - Ensure data is securely deleted using data-wiping or cryptographic erasure.
- **Audit and Monitoring**
 - Monitor access and modifications to sensitive data.
 - Maintain logs for compliance and incident response.

c. Authentication - Authentication controls verify the identity of users and systems using secure authentication mechanisms like multi-factor authentication (MFA) and digital certificates.

- **Server Authentication**
 - Perform authentication using DoD PKI credentials, ECA, or FBCA.
 - Validate server certificates using Certificate Revocation Lists (CRL) or Online Certificate Status Protocol (OCSP).
- **User Authentication**
 - Authenticate users using DoD PKI or ECA credentials.
 - Implement multi-factor authentication (MFA) for privileged access.
 - Restrict access to read-only public information without authentication if necessary.
- **Signed Code Identification**
 - Ensure all code is signed using DoD PKI mobile code signing certificates.
 - Validate code certificates before execution.

d. Use of Cryptography - Cryptographic controls protect data confidentiality, integrity, and authenticity using algorithms, digital signatures, and key management systems.

- **Data Protection**
 - Use symmetric ciphers to protect data confidentiality.

- Apply digital signatures and message authentication codes (MACs) to ensure integrity.
- **Algorithm Standards**
 - Use FIPS 140-2 certified algorithms for unclassified data.
 - Use NSA Type 1 algorithms for classified data.
- **Key Management**
 - Secure key generation, distribution, storage, and disposal.
 - Implement key rotation policies.
- **Authentication Protocols**
 - Use secure authentication protocols to minimize key exchange vulnerabilities.

e. User Accounts - User account management ensures only authorized users access applications through strict authentication, password policies, and access controls.

- **Account Management**
 - Disable or delete unnecessary accounts during application installation.
 - Ensure no duplicate accounts are created.
- **Password Policies**
 - Enforce a 15-character password minimum with upper/lowercase, numbers, and special characters.
 - Prevent the reuse of previous 10 passwords.
 - Enforce password expiration every 60 days.
- **Account Lockout and Unlocking**
 - Lock accounts after three failed login attempts within one hour.
 - Only allow administrators to unlock accounts after verifying user identity.
- **Session Management**
 - Limit concurrent sessions for individual users.
 - Enforce session timeouts for idle sessions.

f. Input Validation - Input validation controls protect applications from common attacks like SQL injection, buffer overflows, and command injection by ensuring only valid data is processed.

- **Data Validation**
 - Perform strict input validation to allow only known-good data.
 - Implement server-side validation to prevent bypassing.
- **SQL Injection Protection**

- Use parameterized statements instead of string concatenation.
- Validate input for SQL queries using stored procedures.
- **Integer Overflow Protection**
 - Use unsigned integers to prevent buffer overflows.
 - Perform bounds checking on input values.
- **Command Injection Mitigation**
 - Validate input to block malicious commands.
 - Use static analysis tools to detect vulnerabilities.
- **Format String Protection**
 - Validate format string inputs.
 - Compile code with format string protection enabled.

g. Auditing - Audit controls ensure accountability by maintaining comprehensive logs of application activities, access attempts, and configuration changes.

- **Audit Trail Creation**
 - Automatically log the creation, modification, and deletion of sensitive data.
 - Record all access attempts, both successful and unsuccessful.
- **Audit Data Protection**
 - Ensure audit trails are protected from unauthorized access, modification, or deletion.
- **Audit Logs Details**
 - Maintain logs with details like user ID, event type, date, time, and system IP.
- **Notification and Monitoring**
 - Notify users about failed login attempts.
 - Monitor for anomalies and potential breaches using audit data.

h. Configuration Management - Configuration management controls ensure proper oversight of software versions, application updates, and system settings to maintain a secure environment.

- **Change Management**
 - All system changes must be approved by the Configuration Control Board (CCB).
 - Maintain detailed logs of software versioning and component changes.
- **Access Control**
 - Restrict configuration files to authorized personnel.

- Ensure administrative privileges are not used unnecessarily.
- **Continuous Monitoring**
 - Monitor configurations for unauthorized changes.
- **Rollback and Recovery**
 - Implement rollback plans for failed updates.
 - Maintain system backups to ensure recoverability.

i. Testing - Security testing identifies vulnerabilities and weaknesses in applications, systems, and infrastructure. It ensures the resilience of the system against attacks and verifies the security controls.

- **Static and Dynamic Analysis**
 - Conduct static code analysis using tools like Fortify, Checkmarx, or SonarQube to identify vulnerabilities in source code.
 - Perform dynamic analysis with tools like IBM AppScan or Burp Suite to evaluate running applications for potential exploits.
- **Vulnerability Scanning**
 - Use automated tools like Nessus or OpenVAS to regularly scan for common vulnerabilities in systems, applications, and networks.
 - Conduct scanning after every major update to ensure that new vulnerabilities haven't been introduced.
- **Penetration Testing**
 - Perform regular penetration testing to simulate real-world attacks and identify exploitable vulnerabilities.
 - Engage external security experts for independent testing to discover weaknesses that internal teams may overlook.
- **Fuzz Testing**
 - Use fuzz testing tools to send random or unexpected data to applications to detect vulnerabilities that may not be evident under normal conditions.
 - Focus on inputs that can trigger buffer overflows, memory leaks, or unexpected behavior.
- **Code Review and Manual Testing**
 - Conduct code reviews as part of the software development lifecycle to spot vulnerabilities like SQL injection, XSS, or logic flaws.
 - Perform manual testing on high-risk areas identified in automated tests or through threat modeling.
- **Third-Party and Open-Source Testing**

- Regularly test third-party code or components used in the application for known vulnerabilities.
- Use tools like Black Duck or WhiteSource to analyze open-source libraries for security risks and licensing issues.
- **Regression Testing**
 - Conduct regression testing after security patches, code updates, or system changes to ensure that security controls are still effective.
 - Test for potential reintroduction of previously fixed vulnerabilities after updates.

j. Deployment - Deployment controls ensure that applications are securely launched and maintained in a production environment, with robust monitoring, maintenance, and contingency plans.

- **Secure Deployment Practices**
 - Ensure that only the necessary services are enabled on production systems to minimize the attack surface.
 - Remove unnecessary accounts, files, and configurations to reduce potential vulnerabilities.
 - Use secure protocols (e.g., TLS, IPSec) for all communication between services during deployment.
- **Configuration Management**
 - Implement version control and configuration management tools (e.g., Ansible, Puppet, Chef) to ensure consistency and security in deployments.
 - Enforce secure baseline configurations for operating systems, applications, and databases to reduce misconfigurations.
- **Audit and Monitoring**
 - Conduct post-deployment audits to verify that all security controls and configurations are properly implemented.
 - Continuously monitor deployed applications for security events, anomalies, and potential incidents, using Security Information and Event Management (SIEM) tools like Splunk or ELK Stack.
- **Incident Response Planning**
 - Ensure that an incident response plan is in place for deployed systems to address security breaches or disruptions quickly.
 - Include detailed procedures for identifying, containing, and recovering from attacks in the deployment lifecycle.
- **Backup and Recovery**

- Maintain regular, encrypted backups of critical data and configurations to ensure recovery in case of data loss or corruption.
- Establish a comprehensive disaster recovery plan (DRP) that includes the restoration of deployed applications to a secure state after incidents.
- **Post-Deployment Security Patching**
 - Regularly apply security patches and updates to deployed systems, applications, and infrastructure to mitigate emerging threats.
 - Use automated patch management tools to track and apply patches as soon as they are released.
- **Vendor Management and COTS Products**
 - Ensure that all Commercial Off-the-Shelf (COTS) software products used are up-to-date with the latest security patches and updates from the vendor.
 - Maintain a vendor risk management program to assess third-party software risks before deployment.
- **End-User Training**
 - Provide training for end users on secure usage practices, particularly when interacting with deployed applications or systems.
 - Regularly update training materials to reflect new features, vulnerabilities, or security measures in the application.
- **Maintenance and Continuous Monitoring**
 - Continuously monitor deployed systems for security and performance, ensuring that any vulnerabilities are addressed promptly.
 - Perform routine maintenance and audits of deployed systems to ensure compliance with security standards.

6. Wireless Security Risk Management Implementation Controls and Policies

a. Wireless LAN Risk Management

Implements WPA3 encryption, access control, and intrusion detection to protect organizational Wi-Fi networks from unauthorized access and eavesdropping.

- **Encryption Protocols:** Implement WPA3 or WPA2-Enterprise encryption to protect data over the wireless LAN and safeguard against unauthorized interception.
- **User Access Control:** Leverage 802.1X authentication to enforce granular user-level access control for devices attempting to connect to the network.
- **SSID Concealment:** Disable SSID broadcasting to minimize the visibility of the wireless network to unauthorized devices.
- **Intrusion Prevention:** Deploy wireless Intrusion Detection Systems (WIDS) to detect and block malicious activity and unauthorized connections.

- **Traffic Segmentation:** Use VLANs to segment sensitive and non-sensitive traffic, ensuring sensitive data remains isolated and reducing risk exposure.
- **Continuous Monitoring:** Implement real-time network monitoring tools to track network health, identify suspicious activity, and perform device scans to mitigate risks.
- **Router Configuration Hardening:** Change default credentials, disable unnecessary services, and apply the latest firmware patches to ensure the security of access points.
- **Physical Access Security:** Secure access points physically by placing them in locked, controlled areas to avoid tampering and unauthorized physical access.

b. Wireless PAN Risk Management

Secures short-range wireless communications (e.g., Bluetooth) through device pairing controls, signal range limitation, and encryption to prevent data interception.

- **Bluetooth Pairing Security:** Implement strong authentication methods, such as PINs or passkeys, to validate trusted devices before establishing Bluetooth connections.
- **Data Encryption:** Use AES-128 encryption for all Bluetooth communications to ensure that data is kept confidential and protected from eavesdropping.
- **Device Inventory Management:** Maintain a complete inventory of paired Bluetooth devices, ensuring regular audits to detect any unauthorized devices.
- **Signal Integrity Monitoring:** Monitor Bluetooth signals for interference or jamming attempts to detect potential malicious activity targeting the PAN.
- **Pairing Restrictions:** Restrict automatic Bluetooth pairing and only allow trusted devices to connect, reducing the risk of unauthorized access.
- **Firmware Updates:** Regularly update the firmware of Bluetooth devices to close any security vulnerabilities and improve Bluetooth protocol security.

c. Wireless WAN Risk Management

Applies encryption, VPNs, and SIM management to safeguard mobile broadband connections (e.g., LTE/5G) from man-in-the-middle attacks and data leaks.

- **VPN Integration:** Utilize VPN technologies (e.g., IPsec, SSL/TLS) to ensure secure and encrypted communication across wireless WANs, protecting data from interception.
- **Encryption Standards:** Apply industry-standard encryption (e.g., AES, IPsec) to all wireless WAN communications to safeguard data in transit.
- **Mutual Authentication:** Ensure both users and network devices authenticate each other to prevent unauthorized access or device impersonation in the WAN.
- **Resilience and Redundancy:** Implement failover solutions and redundant WAN connections to maintain connectivity and minimize downtime during network outages.

- **Quality of Service (QoS):** Use QoS controls to prioritize critical network traffic and ensure reliable service delivery, especially during peak usage times.
- **Access Control Policies:** Implement access control lists (ACLs) to restrict network access to authorized users and devices, mitigating the risk of unauthorized WAN access.

d. Wireless RFID Risk Management

Mitigates RFID threats through tag encryption, shielding, and access controls to prevent cloning, skimming, and unauthorized tracking.

- **Data Encryption:** Encrypt RFID tag data and communication channels to protect sensitive information during transmission.
- **Mutual Authentication:** Implement authentication protocols between RFID tags and readers to verify the identity of both parties and prevent unauthorized access.
- **Proximity-based Access Control:** Limit the operational range of RFID readers to prevent unauthorized scanning and ensure access only to authorized areas.
- **Secure Tag Design:** Use RFID tags with built-in encryption and authentication mechanisms to secure data and prevent tampering.
- **RFID Shielding:** Install RFID shielding or Faraday cages in sensitive areas to prevent unauthorized tag reading and data leakage.
- **Event Logging and Monitoring:** Continuously monitor RFID systems and log read events to detect any unusual or unauthorized access attempts.

e. Wireless PED (Personal Electronic Devices) Risk Management

Controls wireless-enabled personal electronic devices (PEDs) through policy enforcement, device hardening, and network segmentation to reduce insider and malware risks.

- **Mobile Device Management (MDM):** Use MDM platforms to enforce security policies, such as remote data wipe, device encryption, and control over installed applications.
- **Data Encryption:** Enforce device-level encryption to ensure that sensitive data is protected even in the event of device loss or theft.
- **Application Control:** Implement application whitelisting to restrict PEDs to only approved applications, reducing the risk of malware or unauthorized software.
- **Multi-Factor Authentication (MFA):** Enforce MFA for accessing sensitive corporate data or applications to add an extra layer of security on PEDs.
- **Remote Wipe Capability:** Ensure PEDs are equipped with remote wipe functionality to erase sensitive data in case of theft, loss, or compromise.
- **Secure Wi-Fi Usage:** Mandate the use of WPA3-secured Wi-Fi for PEDs and prohibit access to unsecured or public Wi-Fi for work-related communications.

- **Physical Security Measures:** Encourage users to secure PEDs physically when not in use by using screen locks, secure storage, or cable locks to prevent theft.
- **Real-Time Monitoring:** Continuously monitor PEDs for abnormal behavior such as malware infections, unapproved app installations, or unauthorized data access.

7. Across all Security Risk areas 1-6 from above provide a table for:

a) List of Cybersecurity Implementation controls that exist at Capgemini.

Cybersecurity Control Name	Control Type	Control Category	Capgemini Status
User IDs	Identification Credentials	Access Control	Unique usernames are assigned to each employee for tracking and accountability.
Corporate Email-Based Identifiers	Identification Credentials		Corporate emails are used as identifiers for system login and communications.
Smart Cards & Access Badges	Identification Credentials		Employees are issued smart cards for system and physical access.
RFID-Based Access Control	Identification Credentials		RFID-enabled ID badges provide secure access to restricted physical areas.
Digital Certificates (PKI)	Identification Credentials		PKI certificates authenticate devices and secure data exchange.
Passwords	Personal Authentication		Strong password policies enforce complexity and periodic changes.
Multi-Factor Authentication (MFA)	Personal Authentication		2FA with OTPs or biometrics is required for accessing sensitive systems.
Hardware & Software Tokens	Personal Authentication		Authenticator apps and tokens generate OTPs for secure access.
Biometric Verification	Personal Authentication		Fingerprint and biometric checks are used in secure zones.
Role-Based Access Control (RBAC)	Authorization		Access is granted based on job functions, minimizing excess permissions.
Attribute-Based Access Control (ABAC)	Authorization		Access decisions use job title, department, and user attributes.

Access Control Lists (ACLs)	Authorization	Access Control	Permissions are defined at user/group level for resource access control.
Deny-by-Default Policy	Authorization		All access is denied unless explicitly granted.
Temporary Security Tokens	Authorization		Access tokens expire after a session to enforce re-authentication.
Firewalls & Network Segmentation	Logical Access Control Methods		Firewalls filter traffic and segment networks to prevent lateral movement.
Encryption Standards (AES-256, TLS 1.2)	Logical Access Control Methods		Encryption ensures secure communication and data storage.
Virtual Private Network (VPN)	Logical Access Control Methods		VPNs allow secure remote access to internal resources.
Network Access Control (NAC) Systems	Logical Access Control Methods		NAC checks device compliance before allowing access to the network.
Intrusion Detection/Prevention (IDS/IPS)	Logical Access Control Methods		IDS/IPS detect and block malicious network activity.
Port Authentication (802.1X)	Logical Access Control Methods		Devices must authenticate to access network ports.
		Access Control	
Security Personnel	Physical Access Control Methods		Trained staff manage entry points and verify employee identity.
Electronic Door Locks & Keycards	Physical Access Control Methods		Keycards provide access to physically restricted zones.
CCTV Surveillance	Physical Access Control Methods		Surveillance cameras are installed for continuous facility monitoring.
Turnstiles & Biometric Entry Points	Physical Access Control Methods		Secure areas use biometric entry and turnstiles to control access.
Secure Server Rooms	Physical Access Control Methods		Servers are housed in locked, monitored environments.
Fingerprint Scanners	Biometric Systems		Biometric access is implemented for critical environments.
Biometric & PIN-Based Authentication	Biometric Systems		Combines biometric verification with PIN for layered access control.

Smart Biometric ID Cards	Biometric Systems	Access Control	Biometric ID cards integrate identity verification and physical access.
Network Segmentation	Enclave Protection	Network Infrastructure Security	Capgemini evaluates and enhances network segmentation across IT and OT/IoT networks for improved security.
Access Control Layers	Enclave Protection		Access control measures are assessed and implemented to restrict and manage network access.
Visibility and Monitoring	Enclave Protection		Network visibility is enhanced for real-time threat detection and response.
Network Services Isolation	Enclave Protection		Network services are isolated to prevent unauthorized access and reduce breach risks.
Firewall Deployment and Management	Firewall Security		Firewalls are deployed, monitored, and audited regularly to control network access and support operations.
Network Intrusion Protection (IDS/IPS)	Firewall Security		IDS/IPS systems are used at critical points with documented settings and monitored performance.
Network Infrastructure Hardening	Router Security		Capgemini hardens network devices to prevent unauthorized access and ensure system integrity.
Operational Support for Network Devices	Router Security		Secure operational support is provided for ongoing network device management and maintenance.
Ports Management	Network Security	Network Infrastructure Management Security	Only necessary ports are kept open to prevent unauthorized access and reduce the risk of port scanning attacks.
Protocol Configuration	Network Security		Secure configurations for protocols like TCP/IP and HTTP are enforced to

			prevent protocol-based vulnerabilities.
Service Management	System Configuration Security	Network Infrastructure Management Security	Unnecessary and high-risk services are disabled to reduce attack surfaces and potential exploitation.
Device Management Policies	Endpoint Security		Policies enforce antivirus, updates, and secure configurations on all connected devices.
Device Monitoring	Monitoring and Detection		Real-time monitoring identifies abnormal device behaviors, aiding in early threat detection.
Network Authentication	AAA (Authentication)		User identities are verified through credentials or biometrics to ensure only authorized access.
Network Authorization	AAA (Authorization)		Role-based access is applied to restrict users to necessary resources, enforcing least privilege.
Network Accounting (Auditing)	AAA (Accounting)		User activity is tracked and logged for auditing, incident investigation, and compliance.
Network Intrusion Detection	NIDS		Real-time traffic analysis is performed to detect DoS attacks or suspicious activities.
Switch Configuration	Network Infrastructure Security	Network Infrastructure Management Security	Switches are secured by disabling unused ports and enabling MAC address filtering and ARP protection.
VLAN Segmentation	Network Segmentation		Network is segmented into VLANs to contain breaches and limit lateral movement by attackers.
VPN Access	Remote Access Security		Secure encrypted tunnels are used for remote access, ensuring data privacy over public networks.
Multi-Factor Authentication (MFA)	Personal Authentication		MFA requires two or more verification factors, enhancing access security

			even if credentials are compromised.
Firewalls & Network Segmentation	Logical Access Control Methods	Network Infrastructure Management Security	Firewalls inspect and filter traffic; segmentation isolates systems to minimize threat exposure.
Encryption (AES-256, TLS 1.2)	Logical Access Control Methods		Data is encrypted in transit and at rest to ensure confidentiality, using industry standards.
Virtual Private Network (VPN)	Logical Access Control Methods		VPNs ensure encrypted and secure remote communication between devices and internal systems.
Network Access Control (NAC) Systems	Logical Access Control Methods		NAC evaluates device compliance before granting network access, blocking non-compliant devices.
IDS/IPS (Intrusion Detection/Prevention Systems)	Logical Access Control Methods		IDS monitors and alerts on threats; IPS actively blocks malicious traffic in real time.
Port Authentication (802.1X)	Logical Access Control Methods		Ensures only authorized devices can connect to network ports using secure protocols like EAP.
Strong Password Policies	Authentication – User Accounts	Database Security	Strong password policies are enforced for all user accounts.
Multi-Factor Authentication (MFA)	Authentication – User Accounts		MFA is implemented for privileged accounts to enhance security.
Role-Based Access Control (RBAC)	Authentication – User Accounts		RBAC is used to manage user permissions based on their roles.
Inactive Account Management	Authentication – User Accounts		Inactive accounts are disabled, and unnecessary privileges are removed.
Session Timeout	Authentication – User Accounts		Session timeouts are set to automatically log out inactive users.
Least Privilege Access Control	Authorization		Access is granted based on the least privilege principle to restrict unnecessary access.

Role-Based & Attribute-Based Access Controls	Authorization	Database Security	RBAC and ABAC are used for managing user permissions.
Access Monitoring	Authorization		Access changes are monitored for anomalies to detect unauthorized activities.
AES-256 Encryption	Confidentiality		Data is encrypted at rest and in transit using AES-256 encryption.
Data Masking/Anonymization	Confidentiality		Sensitive data is masked or anonymized to protect privacy.
Access Control Lists (ACLs)	Confidentiality		ACLs restrict access to sensitive data to authorized users only.
SHA-256 Hashing	Data Integrity		Data integrity is verified using SHA-256 hashing.
Transaction Logging	Data Integrity		Database transaction logs are maintained for integrity verification.
Input Validation	Data Integrity		Input validation is implemented to prevent SQL injection and other attacks.
Referential Integrity	Data Integrity	Database Security	Referential integrity is enforced in database schemas.
Activity Monitoring & Logging	Auditing		User activities and resource access are logged for auditing and compliance.
Audit Log Retention	Auditing		Logs are retained as per regulatory and compliance requirements.
Audit Log Reviews	Auditing		Logs are reviewed periodically to identify anomalies.
Secure Data Replication	Replication and Federation		Data replication is secured with encrypted communication channels.
Federated Identity Management	Replication and Federation		Federated identity management allows centralized authentication across domains.
Replication Consistency Checks	Replication and Federation		Regular checks are performed to ensure data

			consistency across replicated systems.
High Availability Clustering	Clustering	Database Security	Clustering is used to provide high availability for critical systems.
Load Balancing and Failover Mechanisms	Clustering		Load balancing is implemented, and failover systems are regularly tested.
Encrypted Backups	Backup and Recovery		Backups are encrypted and stored securely.
Backup Restoration Testing	Backup and Recovery	Database Security	Backup restoration procedures are tested regularly to ensure effectiveness.
Automated Backup Scheduling	Backup and Recovery		Automated backup schedules and retention policies are in place.
Patch Management	Operating System Protections		OS security patches and updates are applied regularly.
OS Hardening Configurations	Operating System Protections		Systems are hardened by disabling unnecessary services and following security best practices.
Host-Based Firewalls	Operating System Protections		Host-based firewalls are enabled to filter incoming and outgoing traffic.
Secure Software Development	Application Protections		Secure coding practices are followed to avoid vulnerabilities in applications.
Web Application Firewall (WAF)	Application Protections		WAF is used to protect against attacks such as SQL injection and XSS.
Penetration Testing	Application Protections		Regular security assessments, including penetration testing, are conducted.
Firewalls and Network Segmentation	Network Protections		Firewalls and network segmentation are used to control traffic and prevent lateral movement.

VPN for Secure Remote Access	Network Protections	Database Security	VPNs are implemented for secure remote access to Capgemini's network.
IDS/IPS for Threat Detection	Network Protections		IDS/IPS systems are deployed to detect and block malicious network traffic.
Defense-in-Depth Strategy	Security Design and Configuration		A defense-in-depth approach is implemented for layered security.
Baseline Configurations	Security Design and Configuration		Secure baseline configurations are applied to systems during installation.
Security Policy Reviews	Security Design and Configuration		Security policies and configurations are reviewed and updated regularly.
Privileged Account Access Control	Enclave and Computing Environment		Strict access control measures are in place for privileged accounts.
Security Labeling	Enclave and Computing Environment		Security labels are used to classify and protect sensitive data.
Denial-of-Service (DoS) Protection	Enclave and Computing Environment		DoS protections are implemented to prevent resource exhaustion attacks.
		Database Security	
Disaster Recovery & Continuity Plans	Business Continuity		Comprehensive disaster recovery and continuity plans are in place.
Redundancy for Critical Systems	Business Continuity		Critical systems have redundancy to ensure business continuity.
Continuous Vulnerability Scanning	Vulnerability and Incident Management		Vulnerability scanning is done continuously to identify and patch security flaws.
Incident Response Plan (IRP)	Vulnerability and Incident Management		An IRP is in place for responding to and recovering from security incidents.
Post-Incident Analysis	Vulnerability and Incident Management		Post-incident analysis is conducted to improve security responses.
Security Awareness Training	Vulnerability and Incident Management		Regular security awareness and training programs are conducted for employees.

Cryptography for Unclassified Systems	Cryptography	Application Development	Present (AES-256, RSA-2048, ECC)
Application Data Handling	Application Data Handling		Data Encryption (AES-256) and Integrity Checks (SHA-256)
Standalone Applications Authentication	Authentication		Present (Multi-Factor Authentication, RBAC)
Server Applications Authentication	Authentication		Present (Centralized Authentication with MFA)
Combination Client-Server Applications Authentication	Authentication		Present (Role-Based Access Control, MFA)
Application Components PKI Certificates	Authentication		Present (PKI for secure communication and access)
Symmetric Ciphers (AES, DES)	Cryptography	Application Development	Present (AES-256)
Digital Signatures	Cryptography		Present (RSA, ECC, used for secure transactions)
FIPS 140-2-certified Algorithms	Cryptography		Present (AES-256, RSA-2048, ECC)
Encryption for Unclassified Systems	Cryptography		Present (AES-256 for encryption at rest and in transit)
Configuration Management	Configuration Management		Present (Automated Configurations via tools like Ansible and Chef)
Threat Modeling	Testing		Present (Regular threat assessments, risk management)
Code Reviews	Testing		Present (Regular peer reviews, automated checks)
Canonical Representation and Hidden Fields in Web Pages	Input Validation	Wireless Security	Present (Input sanitization, prevents XSS, SQL Injection)
Injection Vulnerabilities Handling	Input Validation		Present (SQL Injection prevention, XSS protection)
IEEE 802.11 WLAN System Standards - Authentication	Wireless LAN Risk Management		Present (Implements IEEE 802.11-based authentication for secure WLAN access)
IEEE 802.11 WLAN System Standards - Firewall	Wireless LAN Risk Management		Present (Firewall rules and filters are applied to control wireless traffic)
Wireless LAN Security (Encryption and Authentication) -	Wireless LAN Risk Management		Present (Secures wireless communication with WPA2 and MAC filtering)

Physical and Data Link Layer		Wireless Security	
Access Control Management	Wireless LAN Risk Management		Present (Implements strict role-based access to wireless networks)
Data in Transit Encryption	Wireless WAN Risk Management		Present (Employs VPN and TLS encryption for WAN data transmissions)
Usage of Wireless Mice and Keyboards	Wireless PAN Risk Management		Present (Approved devices undergo compatibility and security checks before use)
Cellular Digital Packet Data (CDPD) Standard Encryption	Wireless WAN Risk Management		Present (Utilizes encryption standards for cellular data transmissions)
RFID Tag Security	Wireless RFID Risk Management	Wireless Security	Present (Access to RFID-tagged assets is monitored and secured through policies)
Secure Wireless Email	Wireless PED Risk Management		Present (Corporate email access over wireless is encrypted and MFA-enabled)
Securing Personal Device Assistants (PEDs)	Wireless PED Risk Management		Present (PEDs undergo device hardening and remote wipe features are enabled)

b) Comparison of the Implementation controls discussed in class with Capgemini's existing Cybersecurity Implementation controls

Cybersecurity Control Name	Control Type	Control Category	Capgemini Status
User IDs	Identification Credentials		Present
Corporate Email-Based Identifiers	Identification Credentials		Present
Smart Cards & Access Badges	Identification Credentials		Present
RFID-Based Access Control	Identification Credentials		Present
Digital Certificates	Identification Credentials		Present
Passwords	Personal Authentication		Present
Multi-Factor Authentication (MFA)	Personal Authentication		Present
Hardware & Software Tokens	Personal Authentication		Present
Biometric Verification	Personal Authentication		Partially Present

Physical Token Authentication	Personal Authentication	Access Control	Absent
Continuous Authentication	Personal Authentication		Absent
Role-Based Access Control (RBAC)	Authorization		Present
Attribute-Based Access Control (ABAC)	Authorization		Present
Access Control Lists (ACLs)	Authorization		Present
Deny-by-Default Policy	Authorization		Present
Temporary Security Tokens	Authorization		Present
Firewalls & Network Segmentation	Logical Access Control Methods		Present
Encryption (AES-256, TLS 1.2)	Logical Access Control Methods		Present
Virtual Private Network (VPN)	Logical Access Control Methods		Present
Network Access Control (NAC) Systems	Logical Access Control Methods		Present
Intrusion Detection/Prevention Systems (IDS/IPS)	Logical Access Control Methods		Present
Port Authentication (802.1X)	Logical Access Control Methods		Present
Security Personnel & Attended Access	Physical Access Control Methods		Present
Electronic Door Locks & Keycards	Physical Access Control Methods		Present
Surveillance Cameras (CCTV)	Physical Access Control Methods	Access Control	Present
Turnstiles & Biometric Entry Points	Physical Access Control Methods		Present
Restricted Server Room Access	Physical Access Control Methods		Present
Fingerprint Scanners	Biometric Systems		Present
Biometric & PIN-Based Authentication	Biometric Systems		Partially Present
Smart Biometric ID Cards	Biometric Systems		Partially Present
Facial Recognition	Biometric Systems		Absent
Iris Scanning	Biometric Systems		Absent
Voice Recognition	Biometric Systems		Absent
Hand Geometry Recognition	Biometric Systems		Absent
Behavioral Biometrics	Biometric Systems		Absent
Cryptography for Unclassified Systems	Cryptography		Present
Application Data Handling	Data Protection		Present

Standalone Applications Authentication	Authentication	Network Infrastructure Security	Present
Server Applications Authentication	Authentication		Present
Combination Client-Server Applications Authentication	Authentication		Present
Application Components PKI Certificates	Authentication		Present
Symmetric Ciphers (AES, DES)	Encryption		Present
Digital Signatures	Cryptography		Present
FIPS 140-2-certified Algorithms	Cryptography Standard		Present
Encryption for Unclassified Systems	Encryption		Present
Configuration Management	Configuration Control		Present
Threat Modeling	Security Testing		Present
Code Reviews	Security Testing		Present
Canonical Representation and Hidden Fields	Input Validation		Present
Injection Vulnerabilities Handling	Input Validation		Present
Network Segmentation	Network Security		Present
Access Control Layers	Network Security		Present
Visibility and Monitoring	Network Monitoring		Present
Network Services Isolation	Network Architecture		Present
Firewall Deployment and Management	Firewall Security		Present
Network Intrusion Protection (IDS/IPS)	Intrusion Detection		Present
Network Infrastructure Hardening	Router Security	Network Infrastructure Security	Present
Operational Support for Network Devices	Router Security		Present
Deep Packet Inspection & Content Filtering	Firewall Enhancement		Partially Present
Control Plane Protection (CPP)	Network Defense		Partially Present
Data Plane Security	Network Defense		Partially Present
Cryptography for Classified Systems	Cryptography		Absent
Encryption for Classified Systems	Encryption		Absent
Integer Overflows Handling	Secure Coding		Absent
Minimize Format String Vulnerabilities	Secure Coding		Absent
Buffer Overflows Handling	Secure Coding		Absent
Backdoor Connection Prevention	Network Segmentation		Absent
Route Table Integrity and Authentication	Routing Security		Absent

Access Control and Router Hardening	Routing Security		Absent
Access Lists	Ports, Protocols, Services (PPS)	Network Infrastructure Management	Present
Unicast Reverse Path Forwarding (uRPF)	Device Management		Partially Present
IP Address Management	Device Management		Present
Protecting Servers and LANs	Switches and LAN		Present
Protecting Routers	Device Management		Present
Out-of-Band Management	Device Management		Present
In-Band Management	Device Management		Present
SNMP	Device Monitoring		Present
Individual User Accounts	Network AAA		Present
Syslog Server	Device Monitoring		Present
Access Control	Network AAA		Present
Router Password Protection	Device Management		Present
LAN IDS	NIDS		Present
External IDS	NIDS		Present
Physical Access Control	Physical Security		Present
VLAN Technology	Switches and LAN		Present
Port Security	Switches and LAN		Present
IEEE 802.1X	Switches and LAN		Partially Present
VMPS for Dynamic VLAN Allocation	Switches and LAN		Absent
Gate-to-Gate VPN	VPN	Network Infrastructure Management	Partially Present
Host-to-Gate VPN	VPN		Partially Present
Host-to-Host VPN	VPN		Present
Security Information and Event Management (SIEM)	Monitoring and Detection		Present
Data Loss Prevention (DLP)	Data Security		Present
Web Application Firewall (WAF)	Application Security		Present
Endpoint Detection and Response (EDR)	Endpoint Security		Absent
Cloud Security Controls	Cloud Security		Present
Identity and Access Management (IAM)	Access Management		Present
Patch Management Systems	System Maintenance		Absent
Biometric Authentication	Authentication – User Accounts		Absent
Single Sign-On (SSO)	Authentication – User Accounts		Partially Present

Access Reviews for Non-Privileged Accounts	Authorization	Database Security	Partially Present
Data Masking in Production Databases	Confidentiality		Partially Present
Database Encryption for Backups	Confidentiality		Partially Present
Database Activity Monitoring (DAM)	Confidentiality		Absent
Data Integrity Verification for Backups	Data Integrity		Absent
Data Retention Policies	Data Integrity		Partially Present
Access Control for APIs	Data Integrity		Absent
Data Classification	Data Integrity		Absent
Security Incident and Event Correlation	Auditing		Partially Present
Incident Simulation and Drills	Auditing		Absent
Database Encryption for Data at Rest	Replication and Federation		Absent
Cross-Region Data Replication Security	Replication and Federation		Absent
Federation Protocols (e.g., SAML, OpenID)	Replication and Federation		Absent
Automated Failover Testing	Clustering		Partially Present
Geographically Distributed Backup Locations	Backup and Recovery		Absent
Cloud Backup Integration	Backup and Recovery		Partially Present
Patch Management for Application Software	Operating System Protections		Partially Present
Vulnerability Scanning for Web Applications	Application Protections	Database Security	Absent
Security Patch Testing	Application Protections		Partially Present
Security Awareness for Developers	Application Protections		Absent
Zero Trust for All Access Points	Network Protections		Absent
Cloud Security Posture Management (CSPM)	Network Protections		Absent
Segmentation for Cloud Environments	Network Protections		Absent
Behavioral Analytics for Network Traffic	Network Protections		Absent
Endpoint Detection and Response (EDR)	Endpoint Protection		Partially Present
Automated Threat Intelligence Integration	Endpoint Protection		Absent
Privileged Access Workstations (PAWs)	Endpoint Protection		Absent
DNS Security	Endpoint Protection		Absent
Security Information and Event Correlation (SIEM)	Monitoring and Response		Partially Present
AI-Based Threat Detection	Monitoring and Response		Absent
User and Entity Behavior Analytics (UEBA)	Monitoring and Response		Absent

Automated Incident Response Workflow	Monitoring and Response		Partially Present
Extended Detection and Response (XDR)	Monitoring and Response		Absent
Artificial Intelligence for Threat Hunting	Monitoring and Response		Absent
Identity and Access Management (IAM)	Access Management and Remote Connectivity		Partially Present
Network Access Control (NAC)	Access Management and Remote Connectivity		Partially Present
Cloud Access Security Broker (CASB)	Access Management and Remote Connectivity		Absent
Secure Remote Access	Access Management and Remote Connectivity		Partially Present
Secure Email Gateway (SEG)	Access Management and Remote Connectivity		Absent
Cloud Security Gateways	Access Management and Remote Connectivity		Absent
Cryptography for Classified Systems	Cryptography	Applications Development	Absent
Encryption for Classified Systems	Cryptography		Absent
Cryptography for Unclassified Systems	Cryptography		Present
Encryption for Unclassified Systems	Cryptography		Present
Symmetric Ciphers (AES, DES)	Cryptography	Application Development	Present
Digital Signatures	Cryptography		Present
FIPS 140-2-certified Algorithms	Cryptography		Present
Application Data Handling	Application Data Handling		Present
Standalone Applications Authentication	Authentication		Present
Server Applications Authentication	Authentication		Present
Combination Client-Server Applications Authentication	Authentication		Present
Application Components PKI Certificates	Authentication		Present
Configuration Management	Configuration Management		Present
Threat Modeling	Testing		Present
Code Reviews	Testing		Present
Integer Overflows Handling	Testing		Absent
Minimize Format String Vulnerabilities	Testing		Absent
Buffer Overflows Handling	Testing		Absent
Canonical Representation and Hidden Fields in Web Pages	Input Validation		Present
Injection Vulnerabilities Handling	Input Validation		Present
IEEE 802.11 WLAN System Standards - Authentication	Wireless LAN Risk Management		Present

IEEE 802.11 WLAN System Standards - Firewall	Wireless LAN Risk Management	Wireless Security	Present
Wireless LAN Security (Encryption and Authentication) - Physical and Data Link Layer	Wireless LAN Risk Management		Present
Wireless LAN Security (Encryption and Authentication) - Presentation and Application Layer	Wireless LAN Risk Management		Absent
Wi-Fi Protected Access 3 (WPA3)	Wireless LAN Risk Management		Absent
Access Control Management	Wireless LAN Risk Management		Present
Data in Transit Encryption	Wireless WAN Risk Management		Present
Disabling Bluetooth	Wireless PAN Risk Management		Absent
Low Energy Bluetooth (BLE)	Wireless PAN Risk Management		Absent
Bluetooth - CIA Triad	Wireless PAN Risk Management		Absent
Usage of Wireless Mice and Keyboards	Wireless PAN Risk Management		Present
Cellular Digital Packet Data (CDPD) Standard Encryption	Wireless WAN Risk Management		Present
RFID Tag Security	Wireless RFID Risk Management		Present
Reader Authentication (RFID)	Wireless RFID Risk Management		Absent
Encryption (RFID)	Wireless RFID Risk Management		Absent
Cell Phone Security	Wireless PED Risk Management		Absent
Usage of Secure Cell Phones	Wireless PED Risk Management	Wireless Security	Absent
Secure Wireless Email	Wireless PED Risk Management		Present
Securing Personal Device Assistants (PEDs)	Wireless PED Risk Management		Present
IEEE 802.11 WLAN System Standards - Authentication	Wireless LAN Risk Management		Present
IEEE 802.11 WLAN System Standards - Firewall	Wireless LAN Risk Management		Present
Wireless LAN Security (Encryption and Authentication) - Physical and Data Link Layer	Wireless LAN Risk Management		Present
Wireless LAN Security (Encryption and Authentication) - Presentation and Application Layer	Wireless LAN Risk Management		Absent
Wi-Fi Protected Access 3 (WPA3)	Wireless LAN Risk Management		Absent
Access Control Management	Wireless LAN Risk Management		Present
Data in Transit Encryption	Wireless WAN Risk Management		Present
Disabling Bluetooth	Wireless PAN Risk Management		Absent

Low Energy Bluetooth (BLE)	Wireless PAN Risk Management	Absent
Bluetooth - CIA Triad	Wireless PAN Risk Management	Absent
Usage of Wireless Mice and Keyboards	Wireless PAN Risk Management	Present
Cellular Digital Packet Data (CDPD) Standard Encryption	Wireless WAN Risk Management	Present
RFID Tag Security	Wireless RFID Risk Management	Present
Reader Authentication (RFID)	Wireless RFID Risk Management	Absent
Encryption (RFID)	Wireless RFID Risk Management	Absent
Cell Phone Security	Wireless PED Risk Management	Absent
Usage of Secure Cell Phones	Wireless PED Risk Management	Absent
Secure Wireless Email	Wireless PED Risk Management	Present
Securing Personal Device Assistants (PEDs)	Wireless PED Risk Management	Present

c) List of critical assets that exist in your company

Asset Name	Estimated Value (\$)
Cloud Infrastructure & Data Centers	20,00,000
Customer & Client Databases	15,00,000
Employee Laptops and Workstations	7,50,000
Company Website and Digital Platforms	2,50,000
Enterprise Software & Proprietary Tools	10,00,000
Cybersecurity Infrastructure (Firewalls, IDS/IPS, VPN)	8,00,000
Training and Development Platforms	2,00,000
Office Buildings & Physical Locations	50,00,000
Client Contracts and Legal Agreements	10,00,000
Digital Marketing & Branding Assets	3,00,000
Total Approximate Value	\$12800000

d) List of potential vulnerabilities for critical assets where Cybersecurity Implementation Controls are missing

Missing Cybersecurity Control	Potential Vulnerability
Access Control Security	

Continuous Authentication	Unauthorized access due to session hijacking.
Behavioral Biometrics	Difficulty detecting anomalous user behavior.
Physical Token Authentication	Increased risk of credential theft.
Voice Recognition	Susceptibility to unauthorized voice-based access.
Hand Geometry Recognition	Limited biometric authentication options.
Facial Recognition	Higher risk of social engineering attacks.
Iris Scanning	Weak identity verification for access control.
Smart Biometric ID Cards	Reduced security for physical entry.
Biometric & PIN-Based Authentication	Higher chances of unauthorized modifications.
Continuous Authentication	Increased risk of unauthorized account takeovers.
Network Infrastructure Security	
Cryptography for Classified Systems	Inadequate encryption for sensitive data leading to potential national-level breaches.
Encryption for Classified Systems	Risk of classified data exposure during transmission or storage.
Integer Overflows Handling	Vulnerability to logic corruption and potential for remote code execution.
Format String Vulnerabilities Minimization	Exploitable bugs leading to information leakage or arbitrary code execution.
Buffer Overflows Handling	System crashes or escalated privileges via buffer exploits.
Backdoor Connection Prevention	Hidden access pathways may be exploited by attackers for unauthorized access.
Route Table Integrity & Authentication	Route spoofing and traffic redirection threats compromising availability and trust.
Access Control and Router Hardening	Unrestricted access to routers could lead to configuration tampering or outages.
Network Infrastructure Management	
Unicast Reverse Path Forwarding (uRPF)	Routing loops, Denial of Service (DoS), Spoofing attacks
IEEE 802.1X	Unauthorized network access, Insider threats
VMPS for Dynamic VLAN Allocation	VLAN misconfiguration, Unauthorized access to VLANs
Gate-to-Gate VPN	Data interception, Man-in-the-middle attacks
Host-to-Gate VPN	Data leakage, Interception of sensitive information
Endpoint Detection and Response (EDR)	Malware, Ransomware, Data exfiltration
Patch Management Systems	Exploitation of unpatched vulnerabilities
Database Security	
Biometric Authentication	Unauthorized access to sensitive systems, leading to potential identity theft and data breaches (e.g., Cloud Infrastructure & Data Centers, Customer & Client Databases).

Database Activity Monitoring (DAM)	Lack of real-time monitoring could allow unauthorized access or malicious actions on databases, leading to data leaks or corruption (e.g., Customer & Client Databases).
Data Integrity Verification for Backups	Risk of restoring corrupted or outdated data from unverified backups, causing system failures or data loss (e.g., Cloud Infrastructure & Data Centers).
Data Retention Policies	Inability to manage and securely delete data could expose sensitive information for longer than necessary, increasing risk of data leaks (e.g., Customer & Client Databases).
Access Control for APIs	Inadequate API security controls could lead to unauthorized access or manipulation of services, affecting client systems or company services (e.g., Enterprise Software & Proprietary Tools).
Data Classification	Failure to categorize data properly could expose sensitive data to unauthorized access or sharing (e.g., Customer & Client Databases, Employee Laptops and Workstations).
Incident Simulation and Drills	Lack of preparedness for handling security incidents could result in inefficient responses and prolonged downtimes during a breach (e.g., Cybersecurity Infrastructure).
Database Encryption for Data at Rest	Unencrypted data at rest could be compromised in case of a breach, leading to unauthorized access to sensitive business data (e.g., Customer & Client Databases).
Cross-Region Data Replication Security	Without secure cross-region replication, data could be exposed or lost in case of a disaster, impacting business continuity (e.g., Cloud Infrastructure & Data Centers).
Federation Protocols (e.g., SAML, OpenID)	Lack of standardized authentication protocols could lead to unauthorized access to cloud systems or client applications (e.g., Cloud Infrastructure & Data Centers).
Cloud Backup Integration	Inadequate integration of cloud backups could lead to data loss or access issues during critical recovery scenarios (e.g., Cloud Infrastructure & Data Centers).
Vulnerability Scanning for Web Applications	Security gaps in web applications could allow attackers to exploit vulnerabilities, compromising digital platforms and customer data (e.g., Company Website and Digital Platforms).
Security Patch Testing	Unpatched vulnerabilities in enterprise systems and applications could be exploited, causing malware infections or system breaches (e.g., Enterprise Software & Proprietary Tools).
Security Awareness for Developers	Developers unaware of security best practices could introduce vulnerabilities, such as insecure coding or misconfigurations, into enterprise software (e.g., Enterprise Software & Proprietary Tools).

Zero Trust for All Access Points	Failure to enforce Zero Trust can allow attackers to move laterally through the network once an initial breach occurs (e.g., Cybersecurity Infrastructure, Employee Laptops).
Cloud Security Posture Management (CSPM)	Misconfigurations in cloud environments could expose assets to exploitation, impacting client and employee data (e.g., Cloud Infrastructure & Data Centers).
Segmentation for Cloud Environments	Lack of segmentation in cloud environments could lead to uncontrolled lateral movement during an attack, exposing critical infrastructure (e.g., Cloud Infrastructure & Data Centers).
Behavioral Analytics for Network Traffic	Unusual traffic patterns or internal threats may go unnoticed, increasing the risk of attacks going undetected (e.g., Cybersecurity Infrastructure).
Endpoint Detection and Response (EDR)	Lack of EDR can allow malware and ransomware attacks to proliferate undetected on employee devices (e.g., Employee Laptops and Workstations).
Automated Threat Intelligence Integration	Missing real-time threat intelligence can lead to slow responses to emerging attacks, allowing intruders to cause more damage (e.g., Cybersecurity Infrastructure).
Privileged Access Workstations (PAWs)	Unauthorized access to critical infrastructure could lead to privilege escalation and data breaches (e.g., Cybersecurity Infrastructure).
DNS Security	Exploits in DNS can direct users to malicious websites or cause data interception, affecting network integrity (e.g., Cybersecurity Infrastructure).
AI-Based Threat Detection	Lack of advanced detection techniques could result in undetected sophisticated threats (e.g., Cybersecurity Infrastructure).
User and Entity Behavior Analytics (UEBA)	Without behavioral analysis, unusual user activity could go unnoticed, leading to insider threats or compromised credentials (e.g., Customer & Client Databases).
Automated Incident Response Workflow	Manual response to incidents could result in slower detection and containment of attacks, allowing further damage (e.g., Cybersecurity Infrastructure).
Extended Detection and Response (XDR)	Incomplete visibility across all security layers could prevent identification of complex attacks (e.g., Cybersecurity Infrastructure).
Artificial Intelligence for Threat Hunting	Lack of AI-driven threat hunting could result in missed attacks or vulnerabilities that are not detected via traditional methods (e.g., Cybersecurity Infrastructure).
Cloud Access Security Broker (CASB)	Without a CASB, unsecured cloud applications and unauthorized data access could threaten sensitive information (e.g., Cloud Infrastructure & Data Centers).
Application Development	
Cryptography for Classified Systems	Sensitive classified data remains unencrypted, making it vulnerable to unauthorized access, interception, and tampering during storage or transmission. This could lead to severe data breaches and loss of confidentiality.

Encryption for Classified Systems	Classified data at rest and in transit is not encrypted, leaving it exposed to theft, unauthorized access, and tampering. Attackers can intercept, modify, or exfiltrate sensitive information, causing regulatory and financial consequences.
Integer Overflows Handling	Without protection against integer overflow vulnerabilities, attackers can exploit weak input validation to manipulate system memory, leading to crashes or arbitrary code execution, potentially compromising the integrity of critical systems.
Minimize Format String Vulnerabilities	Format string vulnerabilities allow attackers to inject malicious code into application processes. These vulnerabilities can cause unexpected behavior, crash applications, or allow remote code execution, leading to system compromise or denial of service.
Buffer Overflows Handling	Unaddressed buffer overflow vulnerabilities can be exploited to overwrite memory and execute arbitrary code, potentially allowing attackers to gain unauthorized access, escalate privileges, or compromise the integrity of systems and services.
Cryptography for Classified Systems	Sensitive classified data remains unencrypted, making it vulnerable to unauthorized access, interception, and tampering during storage or transmission. This could lead to severe data breaches and loss of confidentiality.
Encryption for Classified Systems	Classified data at rest and in transit is not encrypted, leaving it exposed to theft, unauthorized access, and tampering. Attackers can intercept, modify, or exfiltrate sensitive information, causing regulatory and financial consequences.
Wireless Security	
Wi-Fi Protected Access 3 (WPA3) Encryption	Data Interception & Unauthorized Access: Without WPA3, attackers can exploit weaker encryption protocols to intercept sensitive data on wireless networks, leading to unauthorized access to Capgemini's systems and critical applications.
Disabling Bluetooth when not in use	Unauthorized Access via Bluetooth: Leaving Bluetooth enabled exposes devices to unauthorized connections or attacks (e.g., Bluejacking, Bluesnarfing), which could compromise sensitive data or systems.
Low Energy Bluetooth (BLE)	Vulnerability to BLE-based Attacks: Lack of BLE security controls can expose devices to attacks such as eavesdropping or unauthorized communication with nearby devices, affecting data integrity and confidentiality.
Bluetooth CIA Triad (Confidentiality, Integrity, Availability)	Compromised Device Integrity: Without implementing CIA protections for Bluetooth devices, attackers could gain unauthorized access to sensitive data, alter communications, or disrupt device functionality.
Cellular Digital Packet Data (CDPD) Standard	Unsecured Cellular Communications: Not using CDPD or similar secure cellular standards exposes mobile

	communications to interception or unauthorized access, leading to potential leaks of sensitive business data.
Reader Authentication for RFID Systems	Unauthorized RFID Access: Without authentication on RFID readers, attackers could use rogue readers to access, modify, or steal sensitive data from RFID tags, exposing Capgemini's critical assets to data breaches.
Encryption for RFID Systems	Data Breach via Unencrypted RFID: Lack of encryption for RFID communications could allow attackers to intercept or manipulate data transmitted between RFID tags and readers, leading to unauthorized access to sensitive information.
Cell Phone Security	Device Theft or Compromise: Without adequate security controls, such as encryption and remote wipe capabilities, lost or stolen mobile devices could provide attackers with unauthorized access to corporate data and systems.
Usage of Secure Cell Phones	Mobile Malware and Data Leakage: Without using secure phones, employees' devices could be infected with malware, potentially leading to data leaks, unauthorized access, or remote exploitation of critical systems.
Securing Personal Device Assistants (PEDs)	Unauthorized Device Access: Failure to secure PEDs with proper device management and security policies allows unauthorized users or malicious software to access critical data or systems, risking data breaches and malware infections.

e) List of potential threats to your company that could exploit vulnerabilities of critical assets

Critical Asset Names	Potential Threats
Access Control	
Cloud Infrastructure & Data Centers	Session Hijacking, DDoS Attacks – Attackers hijack active sessions for unauthorized access; DDoS overwhelms systems, causing downtime.
Customer & Client Databases	Data Breach, SQL Injection – Unauthorized access or exposure of sensitive data; attackers manipulate SQL queries to access client data.
Employee Laptops and Workstations	Malware and Ransomware, Credential Theft – Malicious software compromises systems; phishing or keylogging leads to stolen employee credentials.
Company Website and Digital Platforms	Cross-Site Scripting (XSS), Account Takeover – Malicious code injected into websites; attackers take control of user accounts.
Enterprise Software & Proprietary Tools	Privilege Escalation, Insider Threats – Exploiting system vulnerabilities to gain elevated privileges; employees misuse access for malicious intent.

Cybersecurity Infrastructure	Social Engineering, Zero-Day Exploits – Manipulating employees to bypass security; exploiting unpatched vulnerabilities in cybersecurity systems.
Training and Development Platforms	Phishing Attacks, Unauthorized Access – Fake portals steal credentials; weak access control lets unauthorized users access sensitive material.
Office Buildings & Physical Locations	Unauthorized Physical Entry, Theft of Hardware – Malicious individuals bypass physical security; sensitive data is compromised through stolen devices.
Client Contracts and Legal Agreements	Document Tampering, Data Loss – Unauthorized modification of legal documents; loss of important files due to inadequate security measures.
Digital Marketing & Branding Assets	Account Takeover, Phishing Campaigns – Attackers hijack marketing platforms or assets; phishing schemes target employees for platform access.
Network Infrastructure Security	
National Security & Government Projects	State-sponsored cyber espionage targeting unprotected classified data
Secured Government Communications	Man-in-the-middle (MITM) attacks intercepting unencrypted or weakly encrypted classified data
Software Source Code	Exploitation via remote code execution through integer overflow vulnerabilities
Legacy or Custom Applications	Attackers injecting malicious code through format string vulnerabilities
Embedded or Real-Time Systems	Buffer overflow attacks leading to system crashes or unauthorized code execution
Internal Development Tools & Environments	Installation of backdoors by malicious insiders or compromised third-party tools
Network Routers and Core Infrastructure	Route hijacking or BGP spoofing attacks causing traffic misrouting or surveillance
Router Hardware & Configurations	Unauthorized reconfiguration or exploitation of router firmware due to lack of hardening
National Security & Government Projects	State-sponsored cyber espionage targeting unprotected classified data
Secured Government Communications	Man-in-the-middle (MITM) attacks intercepting unencrypted or weakly encrypted classified data
Software Source Code	Exploitation via remote code execution through integer overflow vulnerabilities
Legacy or Custom Applications	Attackers injecting malicious code through format string vulnerabilities
Embedded or Real-Time Systems	Buffer overflow attacks leading to system crashes or unauthorized code execution
Internal Development Tools & Environments	Installation of backdoors by malicious insiders or compromised third-party tools
Network Routers and Core Infrastructure	Route hijacking or BGP spoofing attacks causing traffic misrouting or surveillance

Router Hardware & Configurations	Unauthorized reconfiguration or exploitation of router firmware due to lack of hardening
Network Infrastructure Management	
Network Infrastructure	Denial of Service (DoS) Attack: Potential service disruptions that affect client applications and internal systems.
Inter-office Communication & Client Data	Man-in-the-Middle (MitM) Attack: Sensitive data can be intercepted or altered during communication between offices or remote access.
Internal Network & Client Data	Insider Threat (Malicious or Negligent Employee) : Employees with malicious intent or negligence can access sensitive project data, leading to intellectual property theft.
Internal Network & Client Data	Unauthorized Network Access (External Attacker) : External attackers could gain access to Capgemini's network, accessing client data or proprietary information.
Database Security	
Cloud Infrastructure & Data Centers	Unauthorized Access, Advanced Persistent Threats (APT), Man-in-the-Middle (MITM) Attacks
Customer & Client Databases	Data Breaches, Insider Threats
Employee Laptops and Workstations	Credential Stuffing, Phishing Attacks
Company Website and Digital Platforms	SQL Injection, Exploitation of Web Vulnerabilities
Enterprise Software & Proprietary Tools	Advanced Persistent Threats (APT), Ransomware
Cybersecurity Infrastructure	Social Engineering Attacks, Delayed Patching Exploitation
Training and Development Platforms	Phishing Attacks, Insider Threats
Applications Development Security	
Cloud Infrastructure & Data Centers	1. Cloud data breach due to lack of strong encryption or misconfigured access controls.
	2. Insider threat from employees or third-party vendors with access to critical systems.
	3. DDoS attacks disrupting cloud services and data availability.
Customer & Client Databases	1. SQL Injection attacks targeting unvalidated inputs in customer databases.
	2. Data exfiltration due to weak access controls or lack of encryption on sensitive data.
	3. Cyber extortion or ransomware attacks exploiting vulnerabilities in database management systems.
Employee Laptops and Workstations	1. Phishing attacks to steal user credentials and gain unauthorized access to corporate systems.

	2. Malware infections from unpatched vulnerabilities or malicious downloads.
	3. Device theft leading to data exposure due to inadequate device encryption or lost credentials.
Company Website and Digital Platforms	1. Cross-site scripting (XSS) attacks exploiting vulnerabilities in web applications.
	2. Distributed Denial-of-Service (DDoS) attacks disrupting online services and customer access.
	3. Data breaches through insecure API endpoints or weak authentication mechanisms.
Enterprise Software & Proprietary Tools	1. Exploitation of software vulnerabilities (e.g., buffer overflows) leading to unauthorized access.
	2. Insider threats from disgruntled employees or contractors exploiting software vulnerabilities.
	3. Attacks targeting unpatched vulnerabilities in proprietary applications, causing data breaches.
Cybersecurity Infrastructure (Firewalls, IDS/IPS, VPN)	1. Bypassing firewalls or IDS/IPS systems using advanced evasion techniques.
	2. VPN compromise through man-in-the-middle (MITM) attacks or weak encryption settings.
	3. Insider attacks exploiting vulnerabilities in monitoring tools, disabling security features.
Training and Development Platforms	1. Social engineering attacks targeting employees through training materials or platforms.
	2. Exploitation of vulnerabilities in training applications or learning management systems.
	3. Compromise of employee credentials via phishing, enabling unauthorized access to training resources.
Wireless Security	
Cloud Infrastructure & Data Centers	Man-in-the-Middle (MITM) Attacks: Interception of sensitive data transmitted over unsecured wireless networks could result in data leakage or manipulation.
	Denial-of-Service (DoS) Attacks: Attackers may overwhelm cloud services with traffic, causing downtime and disrupting business operations.

	Data Breaches: Exploiting vulnerabilities in cloud systems to access sensitive company data or customer information.
Customer & Client Databases	SQL Injection: Exploiting unprotected web applications to inject malicious SQL queries, potentially exposing client data.
	Unauthorized Access: Exploiting weak access controls to gain unauthorized access to sensitive customer and client data.
Employee Laptops and Workstations	Phishing Attacks: Employees could be tricked into disclosing sensitive information or credentials, leading to system compromise.
	Malware Infections: Malware could be introduced through unsecured networks or downloads, compromising employee devices and stealing data.
Company Website and Digital Platforms	Cross-Site Scripting (XSS) Attacks: Malicious scripts executed on the website could steal session cookies or sensitive user data.
	Distributed Denial-of-Service (DDoS) Attacks: Overloading the website with traffic, causing it to crash and become unavailable to customers.
Enterprise Software & Proprietary Tools	Insider Threats: Employees or contractors with access to proprietary software could misuse their privileges to steal intellectual property.
	Exploitation of Software Vulnerabilities: Attackers could exploit vulnerabilities in outdated or unpatched software to gain unauthorized access.
Cybersecurity Infrastructure (Firewalls, IDS/IPS, VPN)	Configuration Errors: Misconfigurations in firewalls or IDS/IPS could allow unauthorized traffic, leaving systems vulnerable to attacks.
	Zero-Day Exploits: Unknown vulnerabilities in security systems could be exploited by attackers to bypass defenses.
Training and Development Platforms	Credential Stuffing: Using stolen or leaked credentials to gain access to employee training platforms and disrupt operations.
	Data Theft: Exploiting gaps in access controls to steal sensitive training content or personal data from users.

f) List of potential risks for critical assets where Cybersecurity Implementation Controls are missing

Missing Cybersecurity Control	Potential Risk
--------------------------------------	-----------------------

Access Control	
Continuous Authentication	Unauthorized access due to the absence of continuous authentication, leading to data breaches or misuse of sensitive cloud resources.
Behavioral Biometrics	Inability to detect anomalous user behavior, which can lead to unauthorized access or data manipulation by malicious insiders or external actors
Physical Token Authentication	Increased risk of credential theft via compromised tokens or lack of physical token authentication, leading to unauthorized system access and data theft.
Voice Recognition	Susceptibility to unauthorized access through voice recognition spoofing, allowing attackers to bypass authentication and exploit the platform.
Hand Geometry Recognition	Limited biometric authentication options (e.g., hand geometry recognition absence), making it easier for unauthorized users to gain access.
Facial Recognition	Vulnerability to social engineering attacks due to the lack of facial recognition and other advanced biometrics for stronger identification.
Iris Scanning	Weak identity verification due to the absence of iris scanning, potentially leading to unauthorized access to sensitive employee training data.
Smart Biometric ID Cards	Reduced security for physical entry points due to the absence of smart biometric ID cards, increasing the risk of unauthorized physical access.
Biometric & PIN-Based Authentication	Higher chances of unauthorized modifications or data exfiltration due to weak biometric and PIN-based authentication mechanisms.
Continuous Authentication	Increased risk of unauthorized account takeovers due to the absence of continuous authentication, leading to potential reputation damage or unauthorized content changes.
Network Infrastructure Security	
Cryptography for Classified Systems	Leakage of highly sensitive government or defense-related data; national security implications.
Encryption for Classified Systems	Interception of classified information during communication or storage, leading to espionage risk.
Integer Overflows Handling	Unauthorized code execution, system manipulation, or application crashes compromising integrity.
Format String Vulnerabilities Minimization	Data leaks or system control via crafted input, enabling attackers to exploit internal application logic.
Buffer Overflows Handling	Full system compromise or denial of service due to memory corruption and privilege escalation.
Backdoor Connection Prevention	Stealthy, persistent access for threat actors, bypassing conventional security controls.
Route Table Integrity & Authentication	Malicious rerouting of traffic, network segmentation failure, or denial of service attacks.
Access Control and Router Hardening	Unauthorized router access allowing network disruption, data interception, or rogue configuration.
Network Infrastructure Management	

Unicast Reverse Path Forwarding (uRPF)	Network disruptions due to routing loops or DoS attacks
IEEE 802.1X	Unauthorized network access or insider threats
VMPS for Dynamic VLAN Allocation	VLAN misconfigurations or unauthorized access to VLANs
Gate-to-Gate VPN	Data interception or Man-in-the-Middle attacks
Host-to-Gate VPN	Data leakage or interception of sensitive information
Endpoint Detection and Response (EDR)	Malware, ransomware, and data exfiltration
Patch Management Systems	Exploitation of unpatched vulnerabilities
Database Security	
Biometric Authentication	Unauthorized access due to reliance on weaker authentication methods.
Database Activity Monitoring (DAM)	Undetected malicious or unauthorized database operations.
Data Integrity Verification for Backups	Restoration of corrupted, outdated, or tampered backup data.
Data Retention Policies	Legal non-compliance, data sprawl, and accidental retention of sensitive information.
Access Control for APIs	Exploitation of unsecured APIs leading to data leaks or system manipulation.
Data Classification	Inadequate protection of sensitive data due to improper labeling and handling.
Incident Simulation and Drills	Poor response to real-world security incidents due to lack of preparation.
Database Encryption for Data at Rest	Exposure of sensitive data if physical or logical access to storage is gained.
Cross-Region Data Replication Security	Data leakage or compromise during inter-region transfers or replication processes.
Federation Protocols (e.g., SAML, OpenID)	Insecure authentication across federated services, leading to account compromise.
Cloud Backup Integration	Incomplete or failed recovery during disasters or outages due to ineffective cloud backup strategy.
Vulnerability Scanning for Web Applications	Delayed detection of exploitable web app flaws such as XSS or SQL injection.
Security Patch Testing	System instability or vulnerabilities caused by unverified patches.
Security Awareness for Developers	Introduction of security flaws during development due to lack of secure coding knowledge.
Zero Trust for All Access Points	Lateral movement by attackers once inside the network, increasing breach impact.
Cloud Security Posture Management (CSPM)	Misconfigurations in cloud environments going unnoticed, leading to breaches.
Segmentation for Cloud Environments	Broad attack surface enabling compromise of multiple systems at once.
Behavioral Analytics for Network Traffic	Failure to detect unusual or malicious activity patterns in real-time.
Endpoint Detection and Response (EDR)	Missed detection and delayed response to endpoint-level attacks or malware.

Automated Threat Intelligence Integration	Slow threat recognition and response, increasing risk from evolving attacks.
Privileged Access Workstations (PAWs)	Elevated account compromise resulting in full network access or data theft.
DNS Security	DNS spoofing or hijacking leading to traffic redirection and credential theft.
AI-Based Threat Detection	Missed subtle or advanced attack patterns due to reliance on manual threat hunting.
User and Entity Behavior Analytics (UEBA)	Inability to detect insider threats or account misuse through behavior anomalies.
Automated Incident Response Workflow	Slow or ineffective responses to incidents due to manual processes.
Extended Detection and Response (XDR)	Disconnected threat data leading to delayed or missed correlations across endpoints and systems.
Artificial Intelligence for Threat Hunting	Reduced ability to proactively uncover sophisticated threats.
Cloud Access Security Broker (CASB)	Unmonitored shadow IT or unsanctioned cloud usage posing data loss or compliance risks.
Applications Development Security	
Cryptography for Classified Systems	Risk of unauthorized access to classified data, leading to data theft or manipulation.
Encryption for Classified Systems	Risk of data breaches or exposure of sensitive classified information due to lack of encryption.
Integer Overflows Handling	Risk of exploitation by attackers using unpatched vulnerabilities, potentially causing system crashes or unauthorized code execution.
Buffer Overflows Handling	Risk of buffer overflow attacks that could lead to arbitrary code execution or system compromise.
Encryption for Unclassified Systems	Risk of sensitive data being intercepted or accessed by unauthorized users, as data might not be sufficiently encrypted.
Encryption for Classified Systems	Risk of untrusted communication or man-in-the-middle attacks due to the lack of strong encryption protocols.
Minimize Format String Vulnerabilities	Risk of attackers exploiting format string vulnerabilities to execute arbitrary code or compromise system integrity.
FIPS 140-2-certified Algorithms	Risk of weak cryptographic operations allowing attackers to bypass data protection or manipulate critical data.
Testing for Code Reviews	Risk of SQL injection attacks, enabling attackers to access or manipulate sensitive data in databases due to insufficient code scrutiny.
Testing for Canonical Representation	Risk of accepting untrusted or malicious input that could lead to security flaws, such as injection attacks or incorrect data processing.
Wireless Security	
Encryption for Wireless LAN Security	Unauthorized access or data breaches due to lack of encryption on wireless networks.
Authentication for Wireless LAN (WPA3)	Risk of unauthorized access to sensitive systems over unprotected Wi-Fi networks.
Encryption for Wireless PAN (Bluetooth, BLE)	Data exfiltration or unauthorized access due to lack of encryption in Bluetooth communications.
Reader Authentication for RFID Systems	Unauthorized scanning and theft of sensitive data from RFID tags due to absence of authentication measures.

Secure Bluetooth Usage (Disabling Bluetooth when not in use)	Exploitation of Bluetooth vulnerabilities for unauthorized access or data theft.
Encryption for Wireless WAN Communication	Interception or unauthorized access to data during transmission over wireless WAN.
Cellular Digital Packet Data (CDPD) Encryption	Interception of sensitive data over CDPD networks due to lack of encryption.
Encryption for Employee Laptops and Workstations	Data breaches or leaks due to missing encryption for employee devices storing sensitive data.
Mobile Device Management (MDM) for PEDs	Loss of sensitive data and unauthorized access to systems due to unencrypted or poorly managed personal devices.
Secure Email Solutions for PEDs (Wireless Email Security)	Potential email compromise or data leaks due to unsecured email communication on personal devices.

g) List of recommended Hardening Prevention controls and policies for each recommended control that should be created to reduce vulnerability probabilities and thus mitigate the identified risks (it is not required to write detailed policies) – Risk Prevention Strategy

Access Control Security Risk

Policy: Enforce identity verification throughout all active user sessions.

Control: Implement Continuous Authentication using time-based and behavioral triggers.

Policy: Monitor user behavior for early detection of insider threats or anomalous activities.

Control: Deploy Behavioral Biometrics integrated with access management systems.

Policy: Require multi-factor authentication with physical components for all endpoint logins.

Control: Distribute and manage Physical Token Authentication devices to employees.

Policy: Enhance access controls on voice-activated systems.

Control: Use Voice Recognition with spoof detection and liveness verification.

Policy: Secure software access with biometric identification.

Control: Install Hand Geometry Recognition scanners at critical access points.

Policy: Strengthen identity checks in security operations.

Control: Deploy Facial Recognition systems with AI validation for secure area access.

Policy: Restrict access to training platforms based on biometric identity.

Control: Use Iris Scanning for high-assurance user validation.

Policy: Control physical access to sensitive locations.

Control: Implement Smart Biometric ID Cards integrated with access logs.

Policy: Protect legal documentation with multi-layer authentication.

Control: Enable Biometric & PIN-Based Authentication for document editing and access.

Policy: Prevent account hijacking on marketing platforms.

Control: Enforce Continuous Authentication using session behavior and re-authentication prompts.

Network Infrastructure Security

Policy: Enforce session-wide authentication for all sensitive systems.

Control: Apply continuous authentication using behavioral and time-based triggers.

Policy: Require behavioral biometrics for users accessing sensitive systems.

Control: Integrate typing patterns and anomaly detection into user authentication flows.

Policy: Mandate physical tokens for system access by authorized personnel.

Control: Distribute, manage, and revoke smartcards or USB tokens securely.

Policy: Use voice authentication with anti-spoofing protocols.

Control: Deploy voice verification with liveness detection and secure access workflows.

Policy: Enforce biometric authentication for high-value software tools.

Control: Employ hand geometry/fingerprint scanners with secure biometric data storage.

Policy: Use facial recognition for high-privilege cybersecurity system access.

Control: Store and transmit biometric data securely, ensuring compliance with data privacy laws.

Policy: Require iris scanning for entry into secure physical/digital environments.

Control: Integrate iris-based identity verification into access control systems.

Policy: Issue smart biometric ID cards for physical access to company premises.

Control: Track, deactivate, and audit all ID cards to prevent unauthorized use.

Policy: Protect legal document access with layered authentication.

Control: Use PIN + biometric verification and document activity tracking.

Policy: Enforce continuous verification for digital marketing accounts.

Control: Monitor session activity and audit content changes in real-time.

Network Infrastructure Management Security

Policy: Enforce strict uRPF configuration across all routing devices.

Control: Implement full Unicast Reverse Path Forwarding (uRPF) to verify the source of incoming packets and block IP spoofing.

Policy: Require IEEE 802.1X authentication for all wired and wireless network access.

Control: Deploy IEEE 802.1X across all network switches and access points to ensure only authenticated users and devices connect.

Policy: Implement VLAN Management Policy to control access based on business requirements.

Control: Enable VMPS for dynamic VLAN assignment based on MAC addresses, restricting access to appropriate network segments.

Policy: Enforce secure remote access protocols for inter-office communication.

Control: Use Gate-to-Gate VPN with full encryption and strong authentication protocols to protect traffic between office networks.

Policy: Enforce strong encryption and multi-factor authentication for all remote connections.

Control: Deploy Host-to-Gate VPN solutions with secure VPN protocols (e.g., IPSec, SSL) for individual remote users.

Policy: Require EDR deployment on all endpoints accessing corporate resources.

Control: Install and configure Endpoint Detection and Response (EDR) tools to monitor, detect, and respond to endpoint threats.

Policy: Enforce centralized and automated patch management procedures.

Control: Use a centralized Patch Management System to ensure timely software and system updates across the organization.

Database Security

Policy: Enforce password complexity requirements, mandate password changes every 90 days, and require MFA for all critical systems and remote access

Control: Implement strong password policies, enforce MFA for all remote and privileged accounts, and regularly audit inactive accounts to maintain proper access control

Policy: Review access permissions periodically to ensure roles align with job responsibilities and enforce least privilege access to sensitive systems

Control: Implement role-based access control (RBAC), restrict permissions based on business needs, and monitor access to critical systems

Policy: Encrypt all sensitive personal and business-critical data and enforce strict access controls with regular audits

Control: Use encryption for data at rest and in transit, apply ACLs, and utilize data anonymization for sensitive information

Policy: Conduct regular integrity checks and ensure system logs and transactional data are properly validated

Control: Apply strong hashing algorithms, enforce input validation, and maintain accurate transactional logging

Policy: Retain user and system logs for a minimum of 12 months, perform quarterly log reviews, and secure logs from unauthorized access

Control: Enable activity logging and audit trails, and periodically review and protect logs to detect and prevent breaches

Policy: Encrypt all data replicated between systems and use federated identity systems for secure authentication

Control: Secure replication channels with encryption, ensure data consistency, and implement secure federation protocols for identity management

Policy: Test failover systems regularly and monitor clustered environments for performance and security anomalies

Control: Use secure clustering technologies with load balancing, ensure automatic failover, and monitor system availability

Policy: Establish a secure backup schedule and verify the integrity of stored backups quarterly

Control: Encrypt backup files, store them securely, and conduct regular backup restoration tests

Policy: Apply all critical OS patches within 24 hours, disable unused services, and enforce firewall policies

Control: Regularly update operating systems, disable unnecessary features, and configure host-based firewalls and intrusion detection systems

Policy: Follow secure coding standards and schedule regular vulnerability scans and code reviews

Control: Implement secure development practices, deploy web application firewalls (WAF), and conduct frequent penetration testing

Policy: Require VPN use for remote access and enforce network segmentation policies

Control: Deploy firewalls, VPNs, IDS/IPS, and segment networks to isolate critical infrastructure

Policy: Apply security configuration baselines and update configurations in response to changing threats

Control: Use defense-in-depth strategies, apply secure system configurations, and continuously review settings for compliance

Policy: Restrict privileged system access to authorized roles only and label critical data according to sensitivity

Control: Enforce strict RBAC for sensitive systems, use data classification, and implement DoS protection mechanisms

Policy: Update and test business continuity and disaster recovery plans regularly and ensure redundant systems are operational

Control: Maintain recovery procedures, implement data redundancy, and run continuity drills to validate preparedness

Policy: Perform vulnerability scans every 30 days and test incident response plans annually

Control: Continuously monitor for vulnerabilities, maintain an updated incident response plan (IRP), and conduct post-incident reviews to enhance defenses

Applications Development Security

Policy: Enforce least privilege access, ensuring only authorized users can access classified data. Regularly review and update user access permissions

Control: Implement Role-Based Access Control (RBAC) to restrict access based on user roles and responsibilities

Policy: Encrypt classified data both in transit and at rest to ensure data remains unreadable without decryption keys

Control: Apply AES-256 encryption for protecting sensitive data from breaches

Policy: Implement a robust patch management process to keep all systems updated with the latest security patches

Control: Use centralized patch management systems to mitigate risks from unpatched vulnerabilities

Policy: Enforce secure coding standards and conduct regular code reviews and testing

Control: Avoid unsafe functions and apply secure coding practices to prevent buffer overflow attacks

Policy: Require TLS encryption for all data transmissions to protect against interception and unauthorized access

Control: Use Transport Layer Security (TLS) for securing communication channels

Policy: Implement mutual authentication to ensure all parties in communication are verified and trusted

Control: Use certificate validation and mutual authentication to prevent man-in-the-middle attacks

Policy: Validate and sanitize all user inputs to prevent the execution of malicious format strings

Control: Enforce strict input validation and sanitization mechanisms to defend against format string vulnerabilities

Policy: Ensure all cryptographic operations use FIPS 140-2 compliant algorithms for secure data processing

Control: Apply only validated and secure cryptographic standards to avoid weak cryptographic practices

Policy: Mandate the use of parameterized queries in all database operations

Control: Use prepared statements and parameterized queries to protect against SQL injection

Policy: Apply strict input validation and filtering to detect and block malicious inputs

Control: Enforce input validation controls to prevent security flaws such as XSS and command injection

Wireless Security

Control: Multi-Factor Authentication (MFA)

Policy: Enforce MFA across all systems, applications, and remote access points. Ensure MFA is required for privileged access to sensitive data and systems

Policy Statement: "All systems and applications shall require multi-factor authentication to prevent unauthorized access, with exceptions requiring explicit approval from the security team."

Control: Encryption at Rest and in Transit

Policy: Implement encryption for all sensitive data both at rest (on servers, databases, etc.)

and in transit (over networks)

Policy Statement: "Sensitive data shall be encrypted both at rest and during transmission using AES-256 encryption or stronger to ensure confidentiality and integrity."

Control: Bluetooth Device Management and Encryption

Policy: Enforce the disabling of Bluetooth when not required and mandate encryption for Bluetooth communications

Policy Statement: "Bluetooth devices must be disabled on all devices when not in use, and Bluetooth communication shall be encrypted with AES-128 or stronger when enabled."

Control: RFID Shielding and Secure Tagging

Policy: Use RFID shielding for sensitive areas and secure RFID tags with encryption and authentication features to prevent unauthorized access

Policy Statement: "Sensitive locations should utilize RFID shielding, and all RFID tags used shall be encrypted and require authentication before access is granted."

Control: Regular Bluetooth Security Updates and Patch Management

Policy: Mandate regular security updates for Bluetooth devices to address vulnerabilities and maintain compliance with the latest security standards

Policy Statement: "Bluetooth-enabled devices must be patched regularly to mitigate known vulnerabilities, with patches applied within 30 days of release by the vendor."

Control: Use of Secure VPN (Virtual Private Network)

Policy: Ensure that all communications over Wireless WAN are routed through secure VPNs using strong encryption (e.g., IPSec, SSL/TLS)

Policy Statement: "All communications over wireless WAN connections must be encrypted using an approved VPN solution to ensure confidentiality and security."

Control: Full Disk Encryption on All Devices

Policy: Require full disk encryption for all devices (laptops, desktops, mobile devices) that access or store sensitive company data

Policy Statement: "All devices that store or access sensitive data must implement full disk encryption (e.g., BitLocker, FileVault) to ensure protection in case of theft or loss."

Control: Mobile Device Management (MDM)

Policy: Implement MDM solutions to enforce security policies like encryption, remote wipe, and app restrictions for personal devices used for work

Policy Statement: "All personal devices used to access company resources must be registered and secured through the Mobile Device Management system, enforcing encryption and other security policies."

Control: Secure Email Gateways and Anti-Phishing Solutions

Policy: Deploy secure email gateways and anti-phishing solutions to detect and block phishing attacks and malicious email attachments

Policy Statement: "All incoming and outgoing emails must be scanned for phishing attempts and malware, using automated filters and manual review as necessary, to prevent email-based attacks."

Control: Disabling Bluetooth and Limiting Wireless Connectivity

Policy: Restrict the usage of wireless peripherals (e.g., wireless mice and keyboards) unless

necessary, and ensure they adhere to strict security protocols

Policy Statement: "Wireless peripherals (mice, keyboards, etc.) must be minimized in use and encrypted when utilized for critical tasks, with devices limited to approved models only."

h) List of recommended Hardening Response controls and policies for critical assets that should be implemented to reduce asset risk impact and thus mitigate the identified risks and increase resilience (it is not required to write detailed policies) – Risk

Response Strategy

Access Control Security Risk

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Enforce continuous authentication using contextual and risk-based access mechanisms to ensure ongoing session validation

Control: Implement Continuous Authentication to dynamically verify user identity throughout active sessions

Critical Asset: Customer & Client Databases

Policy: Monitor and analyze user behavior patterns to detect anomalies and prevent insider threats

Control: Deploy Behavioral Biometrics to identify irregular access behavior and flag potential compromises

Critical Asset: Employee Laptops and Workstations

Policy: Enforce physical token-based multi-factor authentication for endpoint devices accessing sensitive data

Control: Use Physical Token Authentication (e.g., USB security keys) for strong user verification

Critical Asset: Company Website and Digital Platforms

Policy: Require layered authentication and anti-spoofing checks for voice-activated access systems

Control: Integrate Voice Recognition with liveness detection and encryption to secure voice-based authentication

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Enhance authentication with diverse biometrics to prevent unauthorized usage of internal systems

Control: Implement Hand Geometry Recognition as a secondary biometric control to verify users

Critical Asset: Cybersecurity Infrastructure

Policy: Apply biometric-based access to security platforms to prevent impersonation and social engineering

Control: Use Facial Recognition with anti-spoofing mechanisms for identity validation at security layers

Critical Asset: Training and Development Platforms

Policy: Strengthen user identity verification in training platforms, especially for role-based

learning content

Control: Deploy Iris Scanning systems for high-assurance user authentication

Critical Asset: Office Buildings & Physical Locations

Policy: Require biometric access cards for entry to physical facilities to prevent unauthorized physical access

Control: Use Smart Biometric ID Cards that integrate fingerprint or facial recognition with secure ID chips

Critical Asset: Client Contracts and Legal Agreements

Policy: Mandate the use of dual-authentication methods for accessing or modifying legal documentation

Control: Implement Biometric & PIN-Based Authentication to protect sensitive legal data

Critical Asset: Digital Marketing & Branding Assets

Policy: Enforce session-aware authentication and monitor access behavior to prevent unauthorized changes

Control: Utilize Continuous Authentication to secure branding platforms against session hijacking or misuse

Network Infrastructure Security

Critical Asset: Office Buildings & Physical Locations

Policy: Require biometric access cards for entry to physical facilities to prevent unauthorized physical access

Control: Use Smart Biometric ID Cards that integrate fingerprint or facial recognition with secure ID chips

Critical Asset: Client Contracts and Legal Agreements

Policy: Mandate the use of dual-authentication methods for accessing or modifying legal documentation

Control: Implement Biometric & PIN-Based Authentication to protect sensitive legal data

Critical Asset: Digital Marketing & Branding Assets

Policy: Enforce session-aware authentication and monitor access behavior to prevent unauthorized changes

Control: Utilize Continuous Authentication to secure branding platforms against session hijacking or misuse

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Require real-time identity verification during critical operations in cloud environments

Control: Implement Continuous Authentication mechanisms to ensure ongoing verification of user identity

Critical Asset: Customer & Client Databases

Policy: Monitor and analyze user behavior patterns to detect and block anomalous access

Control: Deploy Behavioral Biometrics to detect and respond to abnormal or fraudulent activity

Critical Asset: Employee Laptops and Workstations

Policy: Require physical token authentication for high-privilege logins and critical data access

Control: Use Physical Token Authentication (e.g., smart cards, USB tokens) to reinforce identity verification

Critical Asset: Company Website and Digital Platforms

Policy: Authenticate access using biometric verification resistant to spoofing attacks

Control: Implement Advanced Voice Recognition systems with liveness detection

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Enhance identity verification options with multimodal biometrics for internal tools

Control: Introduce Hand Geometry Recognition to add a biometric layer for high-security environments

Critical Asset: Cybersecurity Infrastructure

Policy: Strengthen system access with biometrics to reduce reliance on passwords

Control: Deploy Facial Recognition for secure and efficient access control to cybersecurity systems

Critical Asset: Training and Development Platforms

Policy: Ensure user identity verification in remote and online training environments

Control: Implement Iris Scanning technology for accurate user authentication

Network Infrastructure Management Security

Critical Asset: Cybersecurity Infrastructure

Policy: Strengthen system access with biometrics to reduce reliance on passwords

Control: Deploy **Facial Recognition** for secure and efficient access control to cybersecurity systems

Critical Asset: Training and Development Platforms

Policy: Ensure user identity verification in remote and online training environments

Control: Implement **Iris Scanning** technology for accurate user authentication

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Ensure continuous monitoring and verification of cloud access and resource usage

Control: Implement **Continuous Authentication** for ongoing validation of users accessing sensitive cloud resources

Critical Asset: Customer & Client Databases

Policy: Protect sensitive data from unauthorized access and manipulation by monitoring behavioral patterns

Control: Utilize **Behavioral Biometrics** to detect anomalies and prevent unauthorized access or data manipulation

Critical Asset: Employee Laptops and Workstations

Policy: Strengthen access controls to prevent unauthorized system access from lost or stolen devices

Control: Use **Physical Token Authentication** to require secure, multi-factor authentication for device access

Critical Asset: Company Website and Digital Platforms

Policy: Enhance website and platform security to prevent unauthorized account access and content modification

Control: Deploy **Voice Recognition** technology to prevent access through spoofed or hijacked voice commands

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Enhance user authentication mechanisms to ensure that only authorized personnel access critical enterprise tools

Control: Implement **Hand Geometry Recognition** to complement traditional access methods and strengthen security

Critical Asset: Office Buildings & Physical Locations

Policy: Ensure physical access security to company premises to prevent unauthorized entry

Control: Use **Smart Biometric ID Cards** for secure entry, integrating fingerprint or facial recognition with secure ID chips

Critical Asset: Client Contracts and Legal Agreements

Policy: Mandate the use of dual-authentication methods for accessing or modifying legal documentation

Control: Implement **Biometric & PIN-Based Authentication** to protect sensitive legal data

Critical Asset: Digital Marketing & Branding Assets

Policy: Enforce session-aware authentication and monitor access behavior to prevent unauthorized changes

Control: Utilize **Continuous Authentication** to secure branding platforms against session hijacking or misuse

Database Security

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Implement regular backups and ensure secure offsite data storage.

Control: Deploy Automated Backup Systems with offsite replication to secure critical data.

Critical Asset: Customer & Client Databases

Policy: Enforce strict access control mechanisms based on user roles and least privilege principles.

Control: Implement Multi-Factor Authentication (MFA) and Role-Based Access Control (RBAC).

Critical Asset: Company Website and Digital Platforms

Policy: Regularly monitor website traffic and detect potential security vulnerabilities.

Control: Deploy Web Application Firewalls (WAF) and Continuous Authentication.

Critical Asset: Cybersecurity Infrastructure

Policy: Ensure that all cybersecurity measures comply with industry standards and regulatory requirements.

Control: Implement Compliance Management Tools and conduct regular Compliance Audits.

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Secure proprietary tools and software with advanced access controls and encryption.

Control: Deploy Encryption and Tokenization methods, combined with Biometric Authentication.

Critical Asset: Financial Systems and Databases

Policy: Implement robust protection against ransomware and unauthorized access to financial data.

Control: Use Endpoint Detection and Response (EDR) solutions and Data Loss Prevention (DLP).

Critical Asset: Office Buildings & Physical Locations

Policy: Strengthen physical security to prevent unauthorized access to critical infrastructure.

Control: Deploy Smart Biometric ID Cards and implement Smart Locks for physical access control.

Critical Asset: Client Contracts and Legal Agreements

Policy: Implement strong authentication measures for accessing and modifying legal documents.

Control: Use Biometric Authentication and Audit Trails for all access to legal agreements.

Critical Asset: Training and Development Platforms

Policy: Ensure the availability of training data and systems in case of incidents.

Control: Use Cloud-Based Backup Systems and Disaster Recovery Plans.

Critical Asset: Third-Party Vendor Systems

Policy: Assess and monitor third-party vendors for compliance with security standards.

Control: Implement Vendor Risk Management Solutions and enforce Third-Party Security Audits.

Applications Development Security

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Implement continuous authentication and access controls for cloud resources

Control: Deploy multi-factor authentication and use secure access management tools

Critical Asset: Customer & Client Databases

Policy: Enforce strong encryption and access control measures for customer and client data

Control: Implement data encryption at rest and in transit using AES-256 and TLS

Critical Asset: Employee Laptops and Workstations

Policy: Mandate endpoint security protocols, including encryption and remote wipe capabilities

Control: Implement endpoint protection tools and data encryption at the device level

Critical Asset: Company Website and Digital Platforms

Policy: Ensure web applications are secured against unauthorized access and data breaches

Control: Use Web Application Firewalls (WAF) and enforce multi-factor authentication for administrative access

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Protect proprietary software and enterprise tools through strict access control and encryption

Control: Implement role-based access controls (RBAC) and enforce encryption for software data storage

Critical Asset: Cybersecurity Infrastructure (Firewalls, IDS/IPS, VPN)

Policy: Regularly update and harden all cybersecurity infrastructure components

Control: Perform periodic security patches and configure firewalls, IDS/IPS to block unauthorized traffic

Critical Asset: Training and Development Platforms

Policy: Implement identity verification and access control to protect employee training data

Control: Use secure login methods like multi-factor authentication for access to training platforms

Critical Asset: Office Buildings & Physical Locations

Policy: Deploy biometric access systems to restrict physical access to secure areas

Control: Use Smart Biometric ID Cards for physical security access

Critical Asset: Client Contracts and Legal Agreements

Policy: Enforce the use of strong authentication methods to access and modify legal documents

Control: Implement Biometric & PIN-Based Authentication for access to legal documents

Critical Asset: Digital Marketing & Branding Assets

Policy: Secure digital marketing platforms with continuous authentication

Control: Use Continuous Authentication mechanisms to prevent unauthorized changes or misuse of branding assets

Wireless Security

Critical Asset: Cloud Infrastructure & Data Centers

Policy: Ensure cloud infrastructure is protected by a multi-layered security architecture, including firewalls, intrusion detection systems, and encryption.

Control: Implement Cloud Security Solutions to protect cloud environments and data centers from unauthorized access and attacks.

Critical Asset: Customer & Client Databases

Policy: Encrypt sensitive customer and client data both in transit and at rest to prevent unauthorized access.

Control: Deploy Advanced Encryption Methods for Data Protection to safeguard sensitive information stored in databases.

Critical Asset: Employee Laptops and Workstations

Policy: Require full disk encryption and endpoint security solutions for all employee laptops and workstations accessing critical company data.

Control: Implement Endpoint Protection to prevent data theft and malware attacks on employee devices.

Critical Asset: Company Website and Digital Platforms

Policy: Secure website and digital platforms by applying regular security updates and using secure coding practices.

Control: Deploy Web Application Firewalls (WAF) and Regular Security Audits to prevent unauthorized access and data leaks.

Critical Asset: Enterprise Software & Proprietary Tools

Policy: Apply strict access control policies to ensure that only authorized users have access to enterprise software and proprietary tools.

Control: Implement Role-Based Access Control (RBAC) and Regular Security Reviews for software access management.

Critical Asset: Cybersecurity Infrastructure (Firewalls, IDS/IPS, VPN)

Policy: Ensure continuous monitoring and regular updates of cybersecurity infrastructure to maintain defense against evolving threats.

Control: Deploy SIEM and Automated Patch Management for real-time monitoring and patching of security infrastructure.

Critical Asset: Training and Development Platforms

Policy: Ensure that training platforms are secure and that user credentials are protected using multi-factor authentication.

Control: Implement Identity and Access Management (IAM) for secure access to training and development resources.

8. Applicable Government Regulations and Industry Standards

General Data Protection Regulation (GDPR)

A European Union regulation that mandates strict data privacy and protection requirements for organizations handling EU citizens' personal data.

Capgemini, operating globally and processing personal data for clients, ensures GDPR compliance through robust data protection policies and practices.

California Consumer Privacy Act (CCPA)

A U.S. state law that grants California residents rights over their personal information and imposes obligations on businesses regarding data collection and sharing.

Capgemini adheres to CCPA by implementing data handling procedures that respect consumer privacy rights in its U.S. operations.

ISO/IEC 27001

An international standard for information security management systems (ISMS), providing a framework for managing sensitive company and customer information.

Capgemini leverages ISO/IEC 27001 to establish and maintain a secure information environment across its services.

ISO/IEC 27002

Provides guidelines for organizational information security standards and information security management practices.

Capgemini utilizes ISO/IEC 27002 to implement and manage security controls aligned with its ISMS.

National Institute of Standards and Technology (NIST) Cybersecurity Framework

A voluntary framework consisting of standards, guidelines, and best practices to manage cybersecurity-related risk.

Capgemini adopts NIST guidelines to enhance its cybersecurity posture and protect client data.

Sarbanes-Oxley Act (SOX)

A U.S. federal law that mandates strict reforms to improve financial disclosures and prevent accounting fraud.

Capgemini ensures SOX compliance by maintaining accurate financial records and implementing internal controls.

Health Insurance Portability and Accountability Act (HIPAA)

A U.S. law that sets standards for protecting sensitive patient health information.

Capgemini complies with HIPAA when providing services to healthcare clients, ensuring the confidentiality and security of health data.

Payment Card Industry Data Security Standard (PCI DSS)

A set of security standards designed to ensure that all companies that accept, process, store, or transmit credit card information maintain a secure environment.

Capgemini adheres to PCI DSS to protect cardholder data in its payment processing services.

Federal Risk and Authorization Management Program (FedRAMP)

A U.S. government program that provides a standardized approach to security assessment for cloud products and services.

Capgemini ensures FedRAMP compliance when offering cloud services to U.S. federal agencies.

International Organization for Standardization (ISO) 9001

Specifies requirements for a quality management system (QMS) and demonstrates the ability to consistently provide products and services that meet customer and regulatory requirements.

Capgemini implements ISO 9001 to enhance customer satisfaction through effective quality management processes.

United Nations Global Compact

A voluntary initiative based on CEO commitments to implement universal sustainability principles and take steps to support UN goals.

Capgemini, as a signatory since 2004, aligns its operations with principles on human rights, labor, environment, and anti-corruption.

Capgemini's Code of Business Ethics

An internal framework outlining the company's commitment to ethical conduct, including integrity, fairness, and compliance with laws.

Capgemini's Code of Business Ethics guides employee behavior and decision-making across all levels of the organization.

9. Ranking Asset risks and Vulnerability risks for Capgemini across Access Control, Network Infrastructure, Network Infrastructure Management, Database, Applications, and Wireless.

Control Type	Top 3 Asset Risks from each Control Type
Access Control Security	Unauthorized access due to the absence of continuous authentication, leading to data breaches or misuse of sensitive cloud resources.
	Inability to detect anomalous user behavior, which can lead to unauthorized access or data manipulation by malicious insiders or external actors.
	Vulnerability to social engineering attacks due to the lack of facial recognition and other advanced biometrics for stronger identification.
Network Infrastructure Security	Full system compromise or denial of service due to memory corruption and privilege escalation (Buffer Overflows Handling).
	Stealthy, persistent access for threat actors, bypassing conventional security controls (Backdoor Connection Prevention).
	Malicious rerouting of traffic, network segmentation failure, or denial of service attacks (Route Table Integrity & Authentication).
Network Infrastructure Management	Unauthorized network access or insider threats due to missing IEEE 802.1X.
	Malware, ransomware, and data exfiltration due to lack of Endpoint Detection and Response (EDR).
	Exploitation of unpatched vulnerabilities due to absence of Patch Management Systems.
Database Security	Undetected malicious or unauthorized database operations due to missing Database Activity Monitoring (DAM).
	Exposure of sensitive data if physical or logical access to storage is gained due to lack of Database Encryption for Data at Rest.
	Insecure authentication across federated services, leading to account compromise (Federation Protocols e.g., SAML, OpenID).
Applications Development Security	Risk of buffer overflow attacks that could lead to arbitrary code execution or system compromise (Buffer Overflows Handling).
	Risk of attackers exploiting format string vulnerabilities to execute arbitrary code or compromise system integrity.

	Risk of SQL injection attacks due to insufficient code scrutiny (Testing for Code Reviews).
Wireless Security	Unauthorized access or data breaches due to lack of encryption on wireless networks (Encryption for Wireless LAN Security).
	Potential email compromise or data leaks due to unsecured email communication on personal devices (Secure Email Solutions for PEDs).
	Data exfiltration or unauthorized access due to lack of encryption in Bluetooth communications (Encryption for Wireless PAN).

Control Type	Top 3 Asset Risk (All Categories)
Access Control Security	Unauthorized access due to the absence of continuous authentication, leading to data breaches or misuse of sensitive cloud resources.
Network Infrastructure Security	Full system compromise or denial of service due to memory corruption and privilege escalation (Buffer Overflows Handling).
Database Security	Exposure of sensitive data if physical or logical access to storage is gained due to lack of Database Encryption for Data at Rest.

Control Type	Top 3 Asset Vulnerability from each Control Type
Access Control Security	Continuous Authentication – Unauthorized access due to session hijacking or account takeover.
	Behavioral Biometrics – Difficulty detecting anomalous user behavior.
	Biometric & PIN-Based Authentication – Higher chances of unauthorized modifications.
Network Infrastructure Security	Buffer Overflows Handling – System crashes or escalated privileges via buffer exploits.
	Cryptography for Classified Systems – Inadequate encryption for sensitive data.
	Route Table Integrity & Authentication – Risk of spoofing and traffic redirection.
Network Infrastructure Management	Endpoint Detection and Response (EDR) – Malware, ransomware, data exfiltration.
	Patch Management Systems – Exploitation of unpatched vulnerabilities.
	Gate-to-Gate VPN – Man-in-the-middle attacks, data interception.
Database Security	Database Encryption for Data at Rest – Unauthorized access to sensitive data.
	Access Control for APIs – Manipulation of services, data breaches.
	Vulnerability Scanning for Web Applications – Exploits compromising platforms and customer data.
Application Development	Buffer Overflows Handling – Remote code execution, system compromise.
	Integer Overflows Handling – Memory manipulation, integrity loss.
	Format String Vulnerabilities – Information leakage, arbitrary code execution.

Wireless Security	WPA3 Encryption – Unauthorized access via weak wireless security.
	Bluetooth CIA Triad – Data alteration or device misuse.
	Encryption for RFID Systems – Intercepted or manipulated RFID data.

Control Type	Top 3 Vulnerability Risk (All Categories)
Database Security	Database Encryption for Data at Rest – Exposure of sensitive business/customer data in case of a breach.
Network Infrastructure Security	Buffer Overflows Handling – Full system compromise via memory manipulation and privilege escalation.
Access Control Security	Continuous Authentication – Unauthorized access and account takeover risks due to lack of session enforcement.

10. Cybersecurity Workforce Risk Management Implementation

a) list of Cybersecurity Specialty Areas that exist in Capgemini

- **Risk Management (RSK)**
- **Software Development (DEV)**
- **Systems Architecture (ARC)**
- **Technology R&D (TRD)**
- **Systems Requirements Planning (SRP)**
- **Test and Evaluation (TST)**
- **Systems Development (SYS)**
- **Data Administration (DTA)**
- **Knowledge Management (KMG)**
- **Customer Service and Technical Support (STS)**
- **Network Services (NET)**
- **Systems Administration (ADM)**
- **Systems Analysis (ANA)**
- **Legal Advice and Advocacy (LGA)**
- **Training, Education, and Awareness (TEA)**
- **Cybersecurity Management (MGT)**
- **Strategic Planning and Policy (SPP)**
- **Executive Cyber Leadership (EXL)**
- **Program/Project Management and Acquisition (PMA)**
- **Cyber Defense Analysis (CDA)**
- **Cyber Defense Infrastructure Support (INF)**
- **Incident Response (CIR)**
- **Vulnerability Assessment and Management (VAM)**
- **Threat Analysis (TWA)**
- **Digital Forensics (FOR)**
- **Cyber Investigation (INV)**

b) Cybersecurity Work Roles That Exist in Capgemini

- SP-RSK-001: Authorizing Official/Designating Representative
- SP-RSK-002: Security Control Assessor
- SP-DEV-001: Software Developer

- SP-DEV-002: Secure Software Assessor
- SP-ARC-001: Enterprise Architect
- SP-ARC-002: Security Architect
- SP-SRP-001: Systems Requirements Planner
- SP-TST-001: System Testing and Evaluation Specialist
- SP-SYS-001: Information Systems Security Developer
- OM-ADM-001: System Administrator
- OM-DTA-001: Database Administrator
- OM-KMG-001: Knowledge Manager
- OM-STS-001: Technical Support Specialist
- OM-NET-001: Network Operations Specialist
- OM-ANA-001: Systems Security Analyst
- OV-MGT-001: Information Systems Security Manager
- OV-MGT-002: Communications Security (COMSEC) Manager
- OV-PMA-001: Program Manager
- OV-PMA-002: IT Project Manager
- OV-PMA-003: Product Support Manager
- OV-SPP-001: Cyber Workforce Developer and Manager
- PR-CDA-001: Cyber Defense Analyst
- PR-INF-001: Network Operations Specialist (Defensive Infra)
- PR-CIR-001: Incident Responder
- PR-VAM-001: Vulnerability Analyst
- IN-FOR-001: Forensics Analyst
- IN-FOR-002: Cyber Defense Forensics Analyst
- IN-INV-001: Cyber Crime Investigator

c) List of Cybersecurity Tasks that exist in Capgemini

Task ID	Task Description
T0001	Acquire and manage the necessary resources, including leadership support, financial resources, and key security personnel, to support IT security goals and reduce organizational risk.
T0010	Analyze organization's cyber defense policies and configurations and evaluate compliance with regulations and organizational directives.
T0013	Apply coding and testing standards, apply security testing tools including “fuzzing,” static-analysis code scanning tools, and conduct code reviews.
T0016	Apply security policies to meet security objectives of the system.
T0018	Assess the effectiveness of cybersecurity measures utilized by system(s).
T0019	Assess threats to and vulnerabilities of computer system(s) to develop a security risk profile.
T0020	Develop content for cyber defense tools.
T0022	Capture security controls used during the requirements phase to integrate security within the process, identify key security objectives, and maximize software security while minimizing disruption to plans and schedules.
T0023	Characterize and analyze network traffic to identify anomalous activity and potential threats to network resources.

T0027	Conduct analysis of log files, evidence, and other information to determine best methods for identifying the perpetrator(s) of a network intrusion.
T0028	Conduct and/or support authorized penetration testing on enterprise network assets.
T0041	Coordinate and provide expert technical support to enterprise-wide cyber defense technicians to resolve cyber defense incidents.
T0042	Coordinate with Cyber Defense Analysts to manage and administer the updating of rules and signatures (e.g., intrusion detection/protection systems, antivirus, and content blacklists) for specialized cyber defense applications.
T0047	Correlate incident data to identify specific vulnerabilities and make recommendations that enable expeditious remediation.
T0048	Create a forensically sound duplicate of the evidence (i.e., forensic image) that ensures the original evidence is not unintentionally modified, to use for data recovery and analysis processes.
T0053	Design and develop cybersecurity or cybersecurity-enabled products.
T0163	Perform cyber defense incident triage, to include determining the scope, urgency, and potential impact; identify the specific vulnerability and make recommendations for remediation.
T0166	Perform event correlation from multiple sources to identify attack vectors and recommend countermeasures.
T0176	Perform secure programming and identify potential flaws in code.
T0177	Perform security reviews, identify gaps, and develop a risk management plan.
T0184	Plan and conduct security authorization reviews and assurance case development for systems and networks.
T0197	Provide an accurate technical evaluation of the software application, system, or network, documenting the security posture, capabilities, and vulnerabilities.
T0215	Recognize a possible security violation and take appropriate action to report the incident, as required.
T0254	Translate security policies into specific security processes enabled in the hardware/software and identify system and software-specific security implementation gaps.
T0301	Develop and implement independent audit processes and oversight of ongoing audits and assessments.
T0502	Monitor and report client-level computer system performance.
T0503	Monitor external data sources to maintain currency of cyber defense threat condition and determine which security issues may have an impact on the enterprise.
T0507	Oversee installation, implementation, configuration, and support of system components.
T0509	Perform an information security risk assessment.
T0994	Ensure that continuous monitoring tools and technologies access control is managed adequately.
T1002	Using scores and grades to motivate and assess performance while addressing concerns to support continuous monitoring.
T0648	Determine indicators (e.g., measures of effectiveness) that are best suited to specific cyber operation objectives.

T0649	Determine organizations and/or echelons with collection authority over all accessible collection assets.
T0650	Determine what technologies are used by a given target.
T0651	Develop a method for comparing collection reports to outstanding requirements to identify information gaps.
T0652	Develop all-source intelligence targeting materials.
T0653	Apply analytic techniques to gain more target information.
T0603	Communicate new developments, breakthroughs, challenges and lessons learned to leadership, and internal and external customers.
T0604	Compare allocated and available assets to collection demand as expressed through requirements.
T0605	Compile lessons learned from collection management activity's execution of organization collection objectives.
T0606	Compile, integrate, and/or interpret all-source data for intelligence or vulnerability value with respect to specific targets.
T0607	Identify and conduct analysis of target communications to identify information essential to support operations.
T0731	Initiate requests to guide tasking and assist with collection management.
T0732	Integrate cyber planning/targeting efforts with other organizations.
T0733	Interpret environment preparations assessments to determine a course of action.
T0734	Issue requests for information.
T0735	Lead and coordinate intelligence support to operational planning.
T0736	Lead or enable exploitation operations in support of organization objectives and target requirements.
T0737	Link priority collection requirements to optimal assets and resources.
T0738	Maintain awareness of advancements in hardware and software technologies (e.g., attend training or conferences, reading) and their potential implications.
T0806	Request discipline-specific processing, exploitation, and disseminate information collected using discipline's collection assets and resources in accordance with approved guidance and/or procedures.
T0807	Research communications trends in emerging technologies (in computer and telephony networks, satellite, cable, and wireless) in both open and classified sources.
T0808	Review and comprehend organizational leadership objectives and guidance for planning.
T0809	Review capabilities of allocated collection assets.
T0810	Review intelligence collection guidance for accuracy/applicability.
T0811	Review list of prioritized collection requirements and essential information.
T0812	Review and update overarching collection plan, as required.
T0806	Request discipline-specific processing, exploitation, and disseminate information collected using discipline's collection

	assets and resources in accordance with approved guidance and/or procedures.
T0807	Research communications trends in emerging technologies (in computer and telephony networks, satellite, cable, and wireless) in both open and classified sources.
T0834	Work closely with planners, intelligence analysts, and collection managers to ensure intelligence requirements and collection plans are accurate and up-to-date.
T0835	Work closely with planners, analysts, and collection managers to identify intelligence gaps and ensure intelligence requirements are accurate and up-to-date.
T0836	Document lessons learned that convey the results of events and/or exercises.
T0837	Advise managers and operators on language and cultural issues that impact organization objectives.
T0838	Analyze and process information using language and/or cultural expertise.
T0834	Work closely with planners, intelligence analysts, and collection managers to ensure intelligence requirements and collection plans are accurate and up-to-date.
T0898	Establish an internal privacy audit program
T0899	Periodically revise the privacy program considering changes in laws, regulatory or company policy
T0900	Provide development guidance and assist in the identification, implementation and maintenance of organization information privacy policies and procedures in coordination with organization management and administration and legal counsel
T0901	Assure that the use of technologies maintains, and does not erode, privacy protections on use, collection and disclosure of personal information
T0902	Monitor systems development and operations for security and privacy compliance
T0903	Conduct privacy impact assessments of proposed rules on the privacy of personal information, including the type of personal information collected and the number of people affected
T0904	Conduct periodic information privacy impact assessments and ongoing compliance monitoring activities in coordination with the organization's other compliance and operational assessment functions
T0998	Establish liaison with scoring and metrics working group to support continuous monitoring.
T0999	Establish and operate a process to manage introduction of new risk to support continuous monitoring.
T1000	Establish continuous monitoring configuration settings issues and coordination sub-group.
T1001	Establish continuous monitoring tools and technologies performance measurement/management requirements.
T1002	Using scores and grades to motivate and assess performance while addressing concerns to support continuous monitoring
T1003	Work with security managers (i.e., system owners, information system security managers, information system security officers, etc.) to establish appropriate reporting requirements for continuous monitoring at the system level.

T1004	Use continuous monitoring tools to assess risk on an ongoing basis.
T1005	Use the continuous monitoring data to make information security investment decisions to address persistent issues.

d. Comparison of the NCWF recommended Cybersecurity Specialty Areas with Capgemini's existing Cybersecurity Specialty Areas

Cybersecurity Specialty Area	Present / Absent
Risk Management (RSK)	Present
Software Development (DEV)	Present
Systems Architecture (ARC)	Present
Technology R&D (TRD)	Present
Systems Requirements Planning (SRP)	Present
Test and Evaluation (TST)	Present
Systems Development (SYS)	Present
Data Administration (DTA)	Present
Knowledge Management (KMG)	Present
Customer Service and Technical Support (STS)	Present
Network Services (NET)	Present
Systems Administration (ADM)	Present
Systems Analysis (ANA)	Present
Legal Advice and Advocacy (LGA)	Present
Training, Education, and Awareness (TEA)	Present
Cybersecurity Management (MGT)	Present
Strategic Planning and Policy (SPP)	Present
Executive Cyber Leadership (EXL)	Present
Program/Project Management and Acquisition (PMA)	Present
Cyber Defense Analysis (CDA)	Present
Cyber Defense Infrastructure Support (INF)	Present
Incident Response (CIR)	Present
Vulnerability Assessment and Management (VAM)	Present
Threat Analysis (TWA)	Present
Digital Forensics (FOR)	Present
Cyber Investigation (INV)	Present
Language Analysis (LNG)	Absent
All-Source Analysis (ASA)	Absent
Exploitation Analysis (EXP)	Absent
Targets (TGT)	Absent
Collection Operations (CLO)	Absent
Cyber Operational Planning (OPL)	Absent
Cyber Operations (OPS)	Absent

e. Comparison of the NCWF recommended Cybersecurity Work Roles with Capgemini's existing Cybersecurity Work Roles

Cybersecurity Work Role	Present / Absent
SP-RSK-001: Authorizing Official/Designating Representative	Present
SP-RSK-002: Security Control Assessor	Present
SP-DEV-001: Software Developer	Present

SP-DEV-002: Secure Software Assessor	Present
SP-ARC-001: Enterprise Architect	Present
SP-ARC-002: Security Architect	Present
SP-SRP-001: Systems Requirements Planner	Present
SP-TST-001: System Testing and Evaluation Specialist	Present
SP-SYS-001: Information Systems Security Developer	Present
OM-ADM-001: System Administrator	Present
OM-DTA-001: Database Administrator	Present
OM-KMG-001: Knowledge Manager	Present
OM-STS-001: Technical Support Specialist	Present
OM-NET-001: Network Operations Specialist	Present
OM-ANA-001: Systems Security Analyst	Present
OV-MGT-001: Information Systems Security Manager	Present
OV-MGT-002: Communications Security (COMSEC) Manager	Present
OV-PMA-001: Program Manager	Present
OV-PMA-002: IT Project Manager	Present
OV-PMA-003: Product Support Manager	Present
OV-SPP-001: Cyber Workforce Developer and Manager	Present
PR-CDA-001: Cyber Defense Analyst	Present
PR-INF-001: Network Operations Specialist (Defensive Infra)	Present
PR-CIR-001: Incident Responder	Present
PR-VAM-001: Vulnerability Analyst	Present
IN-FOR-001: Forensics Analyst	Present
IN-FOR-002: Cyber Defense Forensics Analyst	Present
IN-INV-001: Cyber Crime Investigator	Present
AN-LNG-001: Language Analyst	Absent
AN-ASA-001: All-Source Analyst	Absent
AN-TGT-001: Target Developer	Absent
CO-CLO-001: Collection Manager	Absent
CO-CLO-002: All Source Collection Requirements Manager	Absent
CO-OPL-001/002/003: Operational/Integration Planners	Absent
CO-OPS-001: Cyber Operator	Absent

f. Comparison the NCWF recommended Cybersecurity Tasks with your company's existing Cybersecurity Tasks

Task Id	Description	
T0007	Analyze and define data requirements and specifications.	Absent
T0008	Analyze and plan for anticipated changes in data capacity requirements.	Absent
T0009	Analyze information to determine, recommend, and plan the development of a new application or modification of an existing application.	Absent
T0011	Analyze user needs and software requirements to determine feasibility of design within time and cost constraints.	Absent
T0012	Analyze design constraints, analyze trade-offs and detailed system and security design, and consider life cycle support.	Absent
T0014	Apply secure code documentation.	Absent
T0015	Apply security policies to applications that interface with one another, such as Business-to-Business (B2B) applications.	Absent

T0017	Apply service-oriented security architecture principles to meet organization's confidentiality, integrity, and availability requirements.	Absent
T0021	Build, test, and modify product prototypes using working models or theoretical models.	Absent
T0024	Collect and maintain data needed to meet system cybersecurity reporting.	Absent
T0025	Communicate the value of information technology (IT) security throughout all levels of the organization stakeholders.	Absent
T0026	Compile and write documentation of program development and subsequent revisions, inserting comments in the coded instructions so others can understand the program.	Absent
T0029	Conduct functional and connectivity testing to ensure continuing operability.	Absent
T0030	Conduct interactive training exercises to create an effective learning environment.	Absent
T0031	Conduct interviews of victims and witnesses and conduct interviews or interrogations of suspects.	Absent
T0032	Conduct Privacy Impact Assessments (PIAs) of the application's security design for the appropriate security controls, which protect the confidentiality and integrity of Personally Identifiable Information (PII).	Absent
T0033	Conduct risk analysis, feasibility study, and/or trade-off analysis to develop, document, and refine functional requirements and specifications.	Absent
T0034	Confer with systems analysts, engineers, programmers, and others to design application and to obtain information on project limitations and capabilities, performance requirements, and interfaces.	Absent
T0035	Configure and optimize network hubs, routers, and switches (e.g., higher-level protocols, tunneling).	Absent
T0036	Confirm what is known about an intrusion and discover new information, if possible, after identifying intrusion via dynamic analysis.	Absent
T0037	Construct access paths to suites of information (e.g., link pages) to facilitate access by end-users.	Absent
T0038	Develop threat model based on customer interviews and requirements.	Absent
T0039	Consult with customers to evaluate functional requirements.	Absent
T0040	Consult with engineering staff to evaluate interface between hardware and software.	Absent
T0043	Coordinate with enterprise-wide cyber defense staff to validate network alerts.	Absent
T0044	Collaborate with stakeholders to establish the enterprise continuity of operations program, strategy, and mission assurance.	Absent
T0045	Coordinate with systems architects and developers, as needed, to provide oversight in the development of design solutions.	Absent
T0046	Correct errors by making appropriate changes and rechecking the program to ensure that desired results are produced.	Absent
T0049	Decrypt seized data using technical means.	Absent
T0089	Ensure that security improvement actions are evaluated, validated, and implemented as required.	Absent

T0090	Ensure that acquired or developed system(s) and architecture(s) are consistent with organization's cybersecurity architecture guidelines.	Absent
T0091	Ensure that cybersecurity inspections, tests, and reviews are coordinated for the network environment.	Absent
T0092	Ensure that cybersecurity requirements are integrated into the continuity planning for that system and/or organization(s).	Absent
T0093	Ensure that protection and detection capabilities are acquired or developed using the IS security engineering approach and are consistent with organization-level cybersecurity architecture.	Absent
T0094	Establish and maintain communication channels with stakeholders.	Absent
T0095	Establish overall enterprise information security architecture (EISA) with the organization's overall security strategy.	Absent
T0096	Establish relationships, if applicable, between the incident response team and other groups, both internal (e.g., legal department) and external (e.g., law enforcement agencies, vendors, public relations professionals).	Absent
T0097	Evaluate and approve development efforts to ensure that baseline security safeguards are appropriately installed.	Absent
T0098	Evaluate contracts to ensure compliance with funding, legal, and program requirements.	Absent
T0099	Evaluate cost/benefit, economic, and risk analysis in decision-making process.	Absent
T0100	Evaluate factors such as reporting formats required, cost constraints, and need for security restrictions to determine hardware configuration.	Absent
T0101	Evaluate the effectiveness and comprehensiveness of existing training programs.	Absent
T0102	Evaluate the effectiveness of laws, regulations, policies, standards, or procedures.	Absent
T0103	Examine recovered data for information of relevance to the issue at hand.	Absent
T0104	Fuse computer network attack analyses with criminal and counterintelligence investigations and operations.	Absent
T0105	Identify components or elements, allocate security functions to those elements, and describe the relationships between the elements.	Absent
T0106	Identify alternative information security strategies to address organizational security objective.	Absent
T0107	Identify and direct the remediation of technical problems encountered during testing and implementation of new systems (e.g., identify and find work-arounds for communication protocols that are not interoperable).	Absent
T0108	Identify and prioritize critical business functions in collaboration with organizational stakeholders.	Absent
T0109	Identify and prioritize essential system functions or sub-systems required to support essential capabilities or business functions for restoration or recovery after a system failure or during a system recovery event based on overall system requirements for continuity and availability.	Absent
T0110	Identify and/or determine whether a security incident is indicative of a violation of law that requires specific legal action.	Absent
T0111	Identify basic common coding flaws at a high level.	Absent

T0112	Identify data or intelligence of evidentiary value to support counterintelligence and criminal investigations.	Absent
T0113	Identify digital evidence for examination and analysis in such a way as to avoid unintentional alteration.	Absent
T0114	Identify elements of proof of the crime.	Absent
T0115	Identify information technology (IT) security program implications of new technologies or technology upgrades.	Absent
T0116	Identify organizational policy stakeholders.	Absent
T0117	Identify security implications and apply methodologies within centralized and decentralized environments across the enterprise's computer systems in software development.	Absent
T0118	Identify security issues around steady state operation and management of software and incorporate security measures that must be taken when a product reaches its end of life.	Absent
T0183	Perform validation steps, comparing actual results with expected results and analyze the differences to identify impact and risks.	Absent
T0185	Plan and manage the delivery of knowledge management projects.	Absent
T0186	Plan, execute, and verify data redundancy and system recovery procedures.	Absent
T0187	Plan and recommend modifications or adjustments based on exercise results or system environment.	Absent
T0188	Prepare audit reports that identify technical and procedural findings, and provide recommended remediation strategies/solutions.	Absent
T0189	Prepare detailed workflow charts and diagrams that describe input, output, and logical operation, and convert them into a series of instructions coded in a computer language.	Absent
T0190	Prepare digital media for imaging by ensuring data integrity (e.g., write blockers in accordance with standard operating procedures).	Absent
T0191	Prepare use cases to justify the need for specific information technology (IT) solutions.	Absent
T0192	Prepare, distribute, and maintain plans, instructions, guidance, and standard operating procedures concerning the security of network system(s) operations.	Absent
T0193	Process crime scenes.	Absent
T0221	Review authorization and assurance documents to confirm that the level of risk is within acceptable limits for each software application, system, and network.	Absent
T0222	Review existing and proposed policies with stakeholders.	Absent
T0223	Review or conduct audits of information technology (IT) programs and projects.	Absent
T0224	Review training documentation (e.g., Course Content Documents [CCD], lesson plans, student texts, examinations, Schedules of Instruction [SOI], and course descriptions).	Absent
T0225	Secure the electronic device or information source.	Absent
T0226	Serve on agency and interagency policy boards.	Absent
T0227	Recommend policy and coordinate review and approval.	Absent
T0228	Store, retrieve, and manipulate data for analysis of system capabilities and requirements.	Absent
T0229	Supervise or manage protective or corrective measures when a cybersecurity incident or vulnerability is discovered.	Absent

T0305	Performs configuration management, problem management, capacity management, and financial management for databases and data management systems.	Absent
T0306	Supports incident management, service-level management, change management, release management, continuity management, and availability management for databases and data management systems.	Absent
T0307	Analyze candidate architectures, allocate security services, and select security mechanisms.	Absent
T0308	Analyze incident data for emerging trends.	Absent
T0309	Assess the effectiveness of security controls.	Absent
T0310	Assist in the construction of signatures which can be implemented on cyber defense network tools in response to new or observed threats within the network environment or enclave.	Absent
T0311	Consult with customers about software system design and maintenance.	Absent
T0312	Coordinate with intelligence analysts to correlate threat assessment data.	Absent
T0313	Design and document quality standards.	Absent
T0431	Check system hardware availability, functionality, integrity, and efficiency.	Absent
T0432	Collect and analyze intrusion artifacts (e.g., source code, malware, and system configuration) and use discovered data to enable mitigation of potential cyber defense incidents within the enterprise.	Absent
T0433	Conduct analysis of log files, evidence, and other information to determine best methods for identifying the perpetrator(s) of a network intrusion or other crimes.	Absent
T0434	Conduct framing of pleadings to properly identify alleged violations of law, regulations, or policy/guidance.	Absent
T0435	Conduct periodic system maintenance including cleaning (both physically and electronically), disk checks, routine reboots, data dumps, and testing.	Absent
T0436	Conduct trial runs of programs and software applications to ensure that the desired information is produced and instructions and security levels are correct.	Absent
T0437	Correlate training and learning to business or mission requirements.	Absent
T0438	Create, edit, and manage network access control lists on specialized cyber defense systems (e.g., firewalls and intrusion prevention systems).	Absent
T0439	Detect and analyze encrypted data, stenography, alternate data streams and other forms of concealed data.	Absent
T0440	Capture and integrate essential system capabilities or business functions required for partial or full system restoration after a catastrophic failure event.	Absent
T0567	Analyze target operational architecture for ways to gain access.	Absent
T0568	Analyze plans, directives, guidance and policy for factors that would influence collection management's operational structure and requirements (e.g., duration, scope, communication requirements, interagency/international agreements).	Absent
T0569	Answer requests for information.	Absent
T0570	Apply and utilize authorized cyber capabilities to enable access to targeted networks.	Absent

T0571	Apply expertise in policy and processes to facilitate the development, negotiation, and internal staffing of plans and/or memorandums of agreement.	Absent
T0629	Contribute to the development, staffing, and coordination of cyber operations policies, performance standards, plans and approval packages with appropriate internal and/or external decision makers.	Absent
T0630	Incorporate intelligence equities into the overall design of cyber operations plans.	Absent
T0631	Coordinate resource allocation of collection assets against prioritized collection requirements with collection discipline leads.	Absent
T0632	Coordinate inclusion of collection plan in appropriate documentation.	Absent
T0633	Coordinate target vetting with appropriate partners.	Absent
T0634	Re-task or re-direct collection assets and resources.	Absent
T0635	Coordinate with intelligence and cyber defense partners to obtain relevant essential information.	Absent
T0708	Identify threat tactics, and methodologies.	Absent
T0709	Identify all available partner intelligence capabilities and limitations supporting cyber operations.	Absent
T0710	Identify and evaluate threat critical capabilities, requirements, and vulnerabilities.	Absent
T0711	Identify, draft, evaluate, and prioritize relevant intelligence or information requirements.	Absent
T0712	Identify and manage security cooperation priorities with external partners.	Absent
T0713	Identify and submit intelligence requirements for the purposes of designating priority information requirements.	Absent
T0708	Identify threat tactics, and methodologies.	Absent
T0742	Maintain situational awareness of partner capabilities and activities.	Absent
T0743	Maintain situational awareness to determine if changes to the operating environment require review of the plan.	Absent
T0744	Maintain target lists (i.e., RTL, JTL, CTL, etc.).	Absent
T0745	Make recommendations to guide collection in support of customer requirements.	Absent
T0746	Modify collection requirements as necessary.	Absent
T0792	Provide intelligence analysis and support to designated exercises, planning activities, and time sensitive operations.	Absent
T0793	Provide effectiveness support to designated exercises, and/or time sensitive operations.	Absent
T0794	Provide operations and reengagement recommendations.	Absent
T0829	Test internal developed tools and techniques against target tools.	Absent
T0830	Track status of information requests, including those processed as collection requests and production requirements, using established procedures.	Absent
T0831	Translate collection requests into applicable discipline-specific collection requirements.	Absent
T0832	Use feedback results (e.g., lesson learned) to identify opportunities to improve collection management efficiency and effectiveness.	Absent
T0833	Validate requests for information according to established criteria.	Absent

T0839	Assess, document, and apply a target's motivation and/or frame of reference to facilitate analysis, targeting and collection opportunities.	Absent
T0829	Test internal developed tools and techniques against target tools.	Absent
T0858	Identify foreign language terminology within computer programs (e.g., comments, variable names).	Absent
T0859	Provide near-real time language analysis support (e.g., live operations).	Absent
T0860	Identify cyber/technology-related terminology in the target language.	Absent
T0861	Work with the general counsel, external affairs and businesses to ensure both existing and new services comply with privacy and data security obligations.	Absent
T0862	Work with legal counsel and management, key departments and committees to ensure the organization has and maintains appropriate privacy and confidentiality consent, authorization forms and information notices and materials reflecting current organization and legal practices and requirements.	Absent
T0906	Work with all organization personnel involved with any aspect of release of protected information to ensure coordination with the organization's policies, procedures and legal requirements	Absent
T0907	Account for and administer individual requests for release or disclosure of personal and/or protected information	Absent
T0908	Develop and manage procedures for vetting and auditing vendors for compliance with the privacy and data security policies and legal requirements	Absent
T0909	Participate in the implementation and ongoing compliance monitoring of all trading partner and business associate agreements, to ensure all privacy concerns, requirements and responsibilities are addressed	Absent
T0910	Act as, or work with, counsel relating to business partner contracts	Absent
T0959	Determine if the risk from the operation or use of the system or the provision or use of common controls, is acceptable.	Absent
T0960	Monitor changes to a system and its environment of operation.	Absent
T0961	Assess the security controls employed within and inherited by the system in accordance with an organization-defined monitoring strategy.	Absent
T0962	Respond to risk based on the results of ongoing monitoring activities, assessment of risk, and outstanding items in a plan of action and milestones.	Absent
T0963	Update a security plan, security assessment report, and plan of action and milestones based on the results of a continuous monitoring process.	Absent
T0964	Report the security status of a system (including the effectiveness of security controls) to an authorizing official on an ongoing basis in accordance with the monitoring strategy.	Absent
T0980	Designate a qualified person to be responsible for the management and implementation of the continuous monitoring program.	Absent
T0981	Identify the continuous monitoring stakeholders and establish a process to keep them informed about the program.	Absent
T0982	Identify security oriented organization reporting requirements that are fulfilled by the continuous monitoring program.	Absent

T0983	Use the continuous monitoring data to make information security investment decisions to address persistent issues.	Absent
T0989	Use non-automated assessment methods where the data from the continuous monitoring tools and technologies is not yet of adequate sufficiency or quality.	Absent
T0990	Develop processes with the external audit group on how to share information regarding the continuous monitoring program and its impact on security control assessment.	Absent
T0991	Identify reporting requirements for use in automated control assessment to support continuous monitoring.	Absent
T0992	Determine how the continuous monitoring results will be used in ongoing authorization.	Absent
T0993	Establish continuous monitoring tools and technologies access control process and procedures.	Absent
T0995	Establish a process to provide technical help to continuous monitoring mitigators.	Absent
T0996	Coordinate continuous monitoring reporting requirements across various users.	Absent
T0997	Establish responsibilities for supporting implementation of each continuous monitoring tool or technology.	Absent
T1006	Respond to issues flagged during continuous monitoring, escalate and coordinate a response.	Absent

g. List of potential threats to your company that could exploit vulnerabilities of critical assets due to missing Cybersecurity Specialty Areas, Cybersecurity Work Roles, and Cybersecurity Tasks

Advanced Persistent Threats (APT) & Nation-State Actors

- **Why:** Absence of roles like **Cyber Operator (CO-OPS-001)** and **All-Source Analyst (AN-ASA-001)** compromises threat detection, intelligence gathering, and response coordination.
- **Threat impact:** Undetected infiltration, prolonged presence in systems, data exfiltration.

Insider Threats

- **Why:** Lack of **Language Analysts** and **Target Developers** limits social engineering pattern recognition and behavior anomaly detection.
- **Threat impact:** Intellectual property theft, unauthorized access, policy violations.

Supply Chain Attacks

- **Why:** Missing tasks like **T0099 (evaluate cost/benefit and risk)** and **T0089 (validate security improvements)** mean third-party software and partners might introduce unvetted vulnerabilities.
- **Threat impact:** Compromised services, software tampering, operational disruptions.

Data Breaches Involving PII

- **Why:** Lack of roles and tasks for **Privacy Impact Assessments (T0032)** and **data protection procedures (e.g., T0862, T0909)**.
- **Threat impact:** Legal and compliance risks, customer trust loss, regulatory fines.

Ineffective Incident Response

- **Why:** Absence of **Cyber Operational Planning (OPL)** and **Collection Operations (CLO)** hampers creation of realistic cyber defense strategies and execution playbooks.
- **Threat impact:** Slower response time, escalation of attacks, poor recovery.

Malware and Ransomware

- **Why:** No one responsible for **malware analysis (T0432)** or **threat modeling (T0038)** means Capgemini might miss zero-day indicators and attack paths.
- **Threat impact:** Lockouts, data loss, extortion.

Network Intrusions

- **Why:** Without tasks like **T0433 (log analysis)** or **T0438 (access control)**, suspicious network activity can go unnoticed.
- **Threat impact:** Unauthorized data access, infrastructure compromise.

Policy and Legal Non-Compliance

- **Why:** Roles related to **legal integration, privacy obligations, and compliance (e.g., T0861–T0910)** are missing.
- **Threat impact:** Breach of international laws, financial penalties, audits.

h. List of potential risks for critical assets where Cybersecurity Specialty Areas, Cybersecurity Work Roles, and Cybersecurity Tasks are missing

1. Risk: Unauthorized Access to Client and Internal Systems

- **Missing Work Roles/Tasks:** Cyber Operator (CO-OPS-001), T0438 (manage network access control)
- **Asset at Risk:** Client IT infrastructure, internal enterprise network
- **Risk Description:** Without access control and monitoring specialists, systems may be vulnerable to brute-force attacks, privilege escalation, or lateral movement by attackers.

2. Risk: Compromised Client Data and Intellectual Property

- **Missing Specialty Areas:** Exploitation Analysis (EXP), Cyber Operational Planning (OPL)
- **Asset at Risk:** Client data, proprietary tools, analytics platforms
- **Risk Description:** Lack of threat exploitation and operational analysis makes it harder to anticipate or detect APTs and malware targeting valuable data.

3. Risk: Failure to Meet Privacy Compliance (GDPR, HIPAA, etc.)

- **Missing Tasks:** T0032 (Privacy Impact Assessments), T0906–T0910 (privacy and disclosure handling)
- **Asset at Risk:** PII, legal standing, client trust
- **Risk Description:** No formal roles or tasks ensure privacy laws are enforced, risking regulatory violations and fines.

4. Risk: Ineffective or Delayed Incident Response

- **Missing Roles/Tasks:** Operational Planner (CO-OPL-001), T0444 (continuity strategy planning)
- **Asset at Risk:** Business continuity, security infrastructure
- **Risk Description:** Lack of planning and communication roles weakens ability to coordinate real-time defenses and recovery during incidents.

5. Risk: Unvetted Software or Architecture Introduced into Production

- **Missing Tasks:** T0097 (approve development security), T007 (analyze data requirements)
- **Asset at Risk:** Internal applications, client-facing platforms
- **Risk Description:** Security may not be built into the SDLC, allowing vulnerabilities to enter critical systems undetected.

6. Risk: Loss of Competitive Edge Due to Weak Intelligence Capabilities

- **Missing Roles:** All-Source Analyst (AN-ASA-001), Target Developer (AN-TGT-001)
- **Asset at Risk:** Strategic planning capabilities, business decision-making
- **Risk Description:** Lack of threat intelligence could cause Capgemini to lag in market readiness and responsiveness to emerging cyber trends.

7. Risk: Inability to Accurately Audit or Monitor System Security Posture

- **Missing Tasks:** T0960–T0992 (continuous monitoring and audit)
- **Asset at Risk:** Compliance reports, audit trails, configuration management systems
- **Risk Description:** No continuous monitoring means security drift can go unnoticed, increasing attack surface over time.

i. List of recommended policies (Hiring new Cybersecurity staff, educating current staff, outsourcing) for each recommended Cybersecurity Specialty Area, Cybersecurity Work Role, or Cybersecurity Task that should be created to mitigate the identified risks (it is not required to write detailed policies)

1. Language Analysis (LNG), Language Analyst (AN-LNG-001)

- **Policy Recommendation:**
 - **Outsource** multilingual threat intelligence to language-specialized vendors.
 - **Hire** at least 1–2 language analysts for high-risk geopolitical clients.
- **Why:** To detect foreign language threats in malware code, threat forums, and phishing campaigns.

2. All-Source Analysis (ASA), All-Source Analyst (AN-ASA-001)

- **Policy Recommendation:**
 - **Hire or train internal staff** in cyber threat intelligence aggregation.
 - **Establish a threat intelligence team** that fuses internal logs with third-party intel.
- **Why:** To improve proactive defense and APT detection.

3. Exploitation Analysis (EXP), Tasks like T0432, T0433, T0436

- **Policy Recommendation:**
 - **Train existing SOC/IR staff** in malware reverse engineering and forensic analysis.
 - **Outsource** initial setup to specialized vendors if internal capability is weak.
- **Why:** To analyze cyber incidents beyond surface-level logs.

4. Cyber Operational Planning (OPL) and Cyber Operations (OPS)

- **Policy Recommendation:**
 - **Hire** cybersecurity strategists to develop playbooks and response frameworks.
 - **Educate** current incident response and architecture teams on operational planning.
- **Why:** For effective preparation, coordination, and action during incidents.

5. Collection Operations (CLO), e.g., Collection Manager (CO-CLO-001)

- **Policy Recommendation:**
 - **Outsource** to cyber threat intel firms or cloud security providers with strong telemetry.
 - **Educate internal teams** on telemetry analysis tools.
- **Why:** To ensure timely and relevant threat data collection from client environments.

6. Missing Secure Development Tasks (e.g., T0014–T0017, T0095)

- **Policy Recommendation:**
 - **Mandatory secure coding training** for all developers.
 - **Hire** an application security engineer with experience in DevSecOps.
- **Why:** To ensure security is integrated into the software development life cycle (SDLC).

7. Missing Risk/Compliance Tasks (e.g., T0099, T0909, T0961)

- **Policy Recommendation:**
 - **Hire or designate** a dedicated GRC (Governance, Risk, and Compliance) lead.
 - **Educate** product owners and project managers on privacy laws and risk management.
- **Why:** To avoid non-compliance with data protection regulations and ensure risk-informed decisions.

8. Absent Monitoring and Audit Tasks (e.g., T0960–T0992)

- **Policy Recommendation:**
 - **Invest in SIEM tools** and assign dedicated continuous monitoring personnel.
 - **Establish internal audit rotations** or partner with compliance audit firms.
- **Why:** To ensure Capgemini's security posture is continuously validated and aligned with client requirements.

9. Training & Awareness (e.g., T0030, T0437)

- **Policy Recommendation:**
 - **Develop internal cybersecurity training tracks** for IT and business staff.
 - **Incorporate cyber drills and tabletop exercises** quarterly.
- **Why:** To raise organization-wide cyber awareness and readiness.

Part C

Security Risk Management Recommendations

C1. Security Risk Management Recommendations: Provide the list of recommended Prevention and Response controls, methods and policies and their implementation costs and benefits based on your risk management analysis in Part A for HGA and Part B for Capgemini.

Security Risk Management Recommendations for HGA

Proposed Prevention Controls for HGA:

- **New CISO Controls**
- **Missing MOT Controls**
- **2-Factor Authentication**
- **VPN**
- **DMZ**

Risk Prevention Budget: \$20000

VPN- <https://nordvpn.com/blog/how-much-does-a-vpn-cost/>

DMZ- <https://itprice.com/cisco-gpl/dmz>

New CISO

A Chief Information Security Officer (CISO) will be appointed to design and implement a cohesive security strategy aligned with HGA's operational objectives.

The CISO will ensure proactive identification and management of cybersecurity threats and will lead the implementation of both preventive and responsive security measures. This role centralizes responsibility for security governance and drives compliance with security frameworks and standards, reducing the likelihood of risk exposure due to uncoordinated controls.

Missing MOT Controls

MOT (Management, Operational, and Technical) controls strengthen the organization's foundation for secure IT governance.

By implementing missing MOT controls—such as asset classification, user training, system lifecycle planning, risk management procedures, and audit capabilities—HGA can close critical security gaps. These controls improve detection, accountability, and policy enforcement, which are essential in maintaining a strong security posture and regulatory compliance.

2-Factor Authentication

2-Factor Authentication (2FA) adds a secondary verification step (e.g., an OTP or biometric scan) to user logins, making unauthorized access significantly harder.

By securing accounts against brute-force, credential stuffing, and phishing attacks, 2FA protects critical systems and sensitive data. It is especially effective for safeguarding remote logins, privileged user accounts, and high-value resources.

VPN

A Virtual Private Network (VPN) encrypts communications between remote users and the HGA network, shielding sensitive data from interception.

VPNs are critical for protecting traffic in hybrid work environments, especially for staff accessing systems from outside secure networks. Implementing a reliable VPN service helps prevent data leakage, eavesdropping, and man-in-the-middle attacks, thereby ensuring confidentiality and integrity of government data in transit.

DMZ (Demilitarized Zone)

A DMZ is a segregated section of the network that hosts public-facing services while isolating the internal network from direct exposure.

Deploying a DMZ at HGA allows email servers, web services, and other internet-accessible applications to operate securely without exposing internal systems. If an external service is compromised, the damage remains contained within the DMZ, significantly reducing the attack surface and safeguarding mission-critical infrastructure.

Proposed Response Controls for HGA:

- **New CISO**
- **Missing MOT Controls**
- **Redundant server**
- **Mirror Site**

Risk Prevention Budget: \$30000

Redundant Server: <https://www.itsasap.com/blog/server-cost>

Mirror Site: <https://www.mirrorweb.com/pricing>

New CISO

The Chief Information Security Officer (CISO) plays a critical role in leading HGA's incident response strategy.

The CISO ensures that incidents are swiftly detected, contained, and resolved through clearly defined procedures and **communication** protocols. Their leadership guarantees structured

coordination during crises, minimizes operational disruption, and ensures compliance with legal and regulatory incident handling requirements. This significantly reduces potential financial and reputational damage following a security breach.

Missing MOT Controls

Incorporating missing Management, Operational, and Technical (MOT) controls directly improves HGA's incident handling capabilities.

Operational controls like incident reporting procedures, audit logging, and role-based response protocols ensure that breaches are detected and responded to in a timely and effective manner. These controls support a well-documented response process, facilitate post-incident analysis, and contribute to stronger legal defensibility in the event of a cyber incident.

Redundant Server

A redundant server acts as a failover system, automatically taking over if the primary server becomes compromised or fails.

This continuity mechanism ensures uninterrupted access to applications and services during cyberattacks, outages, or system crashes. By maintaining a backup server, HGA can prevent downtime, maintain productivity, and ensure critical data and systems remain available under adverse conditions.

Mirror Site

A mirror site is a geographically separate, synchronized replica of HGA's core systems and data.

In the event of a major cyber incident or disaster (e.g., ransomware attack or server failure), the mirror site can be activated to ensure continued operations with minimal delay. This significantly reduces recovery time objectives (RTO) and data loss, while also supporting regulatory requirements for data continuity and disaster recovery.

BUDGET ESTIMATION (per annum) = \$20000+\$30000 = \$50,0000

Security Risk Management Recommendations for Capgemini

Proposed Prevention Controls for Capgemini:

- **New CISO Controls**
- **Missing MOT Controls**
- **2-Factor Authentication**
- **Biometric & Behavioral Authentication (Advanced IAM)**
- **Gate-to-Gate VPN**
- **Database Encryption for Data at Rest**
- **WPA3 Wireless Encryption**

Risk Prevention Budget: \$1,000,000

- VPN: <https://nordvpn.com/blog/how-much-does-a-vpn-cost/> \$20,000 per year
- IAM & Biometric Tools: Vendor-dependent (Okta, Duo, Azure AD) \$50,000 per year
 - **Okta Adaptive MFA:** <https://www.okta.com/>
 - **Duo Security MFA:** <https://duo.com/>

- **Azure Active Directory:** <https://azure.microsoft.com/services/active-directory/>
- **Wireless/WPA3 & Data Encryption:** [Cisco, Fortinet, AWS KMS] - \$ 30000 per year
 - **Cisco Security Solutions:** <https://www.cisco.com/c/en/us/products/security/index.html>
 - **Fortinet Wireless Security:** <https://www.fortinet.com/solutions/enterprise-midsize-business/wireless-security>
 - **AWS Key Management Service (KMS):** <https://aws.amazon.com/kms/>

New CISO Controls

The appointment of a Chief Information Security Officer (CISO) will establish centralized leadership for cybersecurity governance, risk management, and compliance.

The CISO will develop and maintain Capgemini's security framework, aligning controls with business needs and emerging threats. Their role ensures security measures are proactive, policy-driven, and strategically prioritized.

Missing MOT Controls

Integrating missing Management, Operational, and Technical (MOT) controls will address critical gaps in Capgemini's security framework.

These include incident documentation, risk lifecycle planning, access audit trails, and continuous employee training. MOT controls increase resilience by standardizing procedures across IT, HR, and cloud operations.

2-Factor Authentication (2FA)

2FA requires users to verify identity using a second method, such as a one-time code or biometric scan.

It prevents unauthorized access due to compromised credentials and is especially critical for protecting privileged accounts and remote workers in the cloud environment.

Biometric & Behavioral Authentication

This advanced IAM solution introduces facial recognition, fingerprint scanning, and behavioral biometrics.

These controls protect against social engineering and insider threats by detecting anomalous access behavior in real time. They are essential in high-trust environments dealing with sensitive customer and business data.

Gate-to-Gate VPN

Gate-to-Gate VPN ensures end-to-end encrypted communication from internal nodes to external resources.

It prevents data interception, supports hybrid work, and helps comply with encryption standards for classified or customer-sensitive projects.

Database Encryption for Data at Rest

Encrypting databases prevents unauthorized data access in the event of a breach or internal misuse.

This is **especially** important for customer data, HR records, and intellectual property hosted on local and cloud-based platforms. Encryption ensures regulatory compliance and limits the impact of credential compromise.

WPA3 Wireless Encryption

WPA3 secures wireless LANs against brute-force attacks and passive eavesdropping. It is crucial for protecting internal communications, especially in shared or open office spaces. Implementing WPA3 safeguards access to corporate systems via wireless devices and prevents lateral movement by attackers.

Proposed Response Controls for Capgemini:

- **New CISO**
- **Missing MOT Controls**
- **Redundant Servers (Failover Infrastructure)**
- **Cloud-Based Mirror Site**
- **Endpoint Detection and Response (EDR)**
- **Incident Response (IR) Playbooks and Automation**
- **Behavioral Intrusion Detection/Prevention Systems (IDS/IPS)**

Risk Response Budget: \$1,500,000

- EDR/IDS Tools: CrowdStrike, SentinelOne, - \$40000 per year
 - **CrowdStrike Falcon:** <https://www.crowdstrike.com/>
 - **SentinelOne Platform:** <https://www.sentinelone.com/>
- Mirror Site: <https://www.mirrorweb.com/pricing> - \$60000 per year
- IR Automation: Mandiant, Splunk SOAR - \$50000 per year
 - **Mandiant:** <https://www.mandiant.com/>
 - **Splunk SOAR:** https://www.splunk.com/en_us/software/splunk-soar.html

New CISO

The CISO will oversee response planning, threat monitoring, and incident containment. This executive role ensures Capgemini's responses to breaches are swift, compliant, and minimize financial or legal fallout.

Missing MOT Controls

In response scenarios, MOT controls include structured incident documentation, escalation procedures, and regulatory reporting standards.

These ensure incident accountability, support forensic analysis, and enable faster recovery.

Redundant Servers

Redundant servers provide immediate failover capacity during outages or ransomware incidents.

By replicating critical services, Capgemini ensures business continuity and minimizes downtime.

Cloud-Based Mirror Site

The mirror site functions as a live backup of Capgemini's core systems and data. In case of a severe breach or infrastructure failure, operations can seamlessly switch to the mirror site with minimal disruption and data loss.

Endpoint Detection and Response (EDR)

EDR tools continuously monitor endpoints to detect and neutralize malware, ransomware, and zero-day exploits.

They support fast containment, rollback, and remediation, which are essential in defending against modern threats.

Incident Response (IR) Playbooks and Automation

Automated IR processes ensure consistent, rapid responses to breaches, minimizing manual errors.

Using tools like Splunk SOAR or Palo Alto Cortex, Capgemini can automatically isolate threats, alert relevant teams, and initiate recovery.

Behavioral IDS/IPS

These systems monitor traffic and detect unusual activity patterns across internal networks. They offer early warnings for insider threats and novel attacks by identifying deviations from expected behavior.

BUDGET ESTIMATION (per annum) = \$100000 + \$150000 = \$250,000

C2. Provide the total cost and total risk reduction benefit in \$ due to the recommended controls, methods and policies based on your security risk management analysis in Parts A and B.

HGA:

Total Cost of Recommended Control Implementation = Prevention Control + Response Control

$$\rightarrow \$30,000 + \$20,000 = \$50,000$$

Reduction = Initial Risk Impact – Risk After Implementing Strategy

Risk Reduction Benefits from Prevention Controls = \$331,500

Risk Reduction Benefits from Response Controls = \$627,020

Based on the comprehensive risk assessment and ROI analysis, the **Risk Response Strategy** emerges as the most cost-effective and impactful choice. With a moderate budget of **\$30,000**, it delivers the **highest risk reduction of \$627,020**, making it highly effective for organizations that prioritize **operational resilience** and rapid recovery from security incidents. This strategy enhances capabilities in incident detection, response, and recovery, thereby minimizing business disruption.

Alternatively, the **Risk Prevention Strategy**, with a lower budget of **\$20,000**, offers a substantial **risk reduction of \$331,500**. It is best suited for organizations focused on **proactively minimizing vulnerabilities** and preventing incidents before they occur.

Recommendation:

Choose the **Risk Response Strategy** if ensuring business continuity and minimizing the impact of incidents is a top priority. Opt for the **Risk Prevention Strategy** if the goal is to reduce the likelihood of breaches through strong preventive controls and if financial resources are more limited.

Capgemini:

Total Cost of Recommended Control Implementation = Prevention Control + Response Control

$$\rightarrow \$100,000 + \$150,000 = \$250,000$$

Total Risk Reduction Benefit = \$400,000 – \$500,000

Based on Capgemini's top asset and vulnerability risks—unauthorized access, buffer overflow exploits, and unencrypted sensitive data—it is evident that the organization faces high-impact threats requiring both proactive defense and rapid response capabilities. With a total security investment of \$250,000 (\$100,000 in prevention and \$150,000 in response), the projected risk reduction benefit ranges from \$400,000 to \$500,000, indicating a positive return on investment. The **Risk Response Strategy** emerges as the most critical component, as it supports business continuity through swift incident detection, containment, and recovery—essential in a delivery-driven environment like Capgemini. However, key **preventive controls** such as database encryption, buffer overflow handling, and continuous authentication are also necessary to mitigate the most exploitable vulnerabilities. Therefore, while response capabilities should be prioritized due to their high impact on organizational resilience, selective investment in high-value prevention measures will significantly strengthen Capgemini's security posture. This dual-focus strategy ensures maximum risk reduction, aligns with Capgemini's operational needs, and provides the most effective security ROI.

C3. Compare your proposed security controls, methods and policies budget for HGA (which is based on security risk assessment in Part A) with the proposed security controls, methods and policies budget for Capgemini (which is based on security risk implementation plan in Part B), comparing the two companies at a high level on the following security risk management areas:

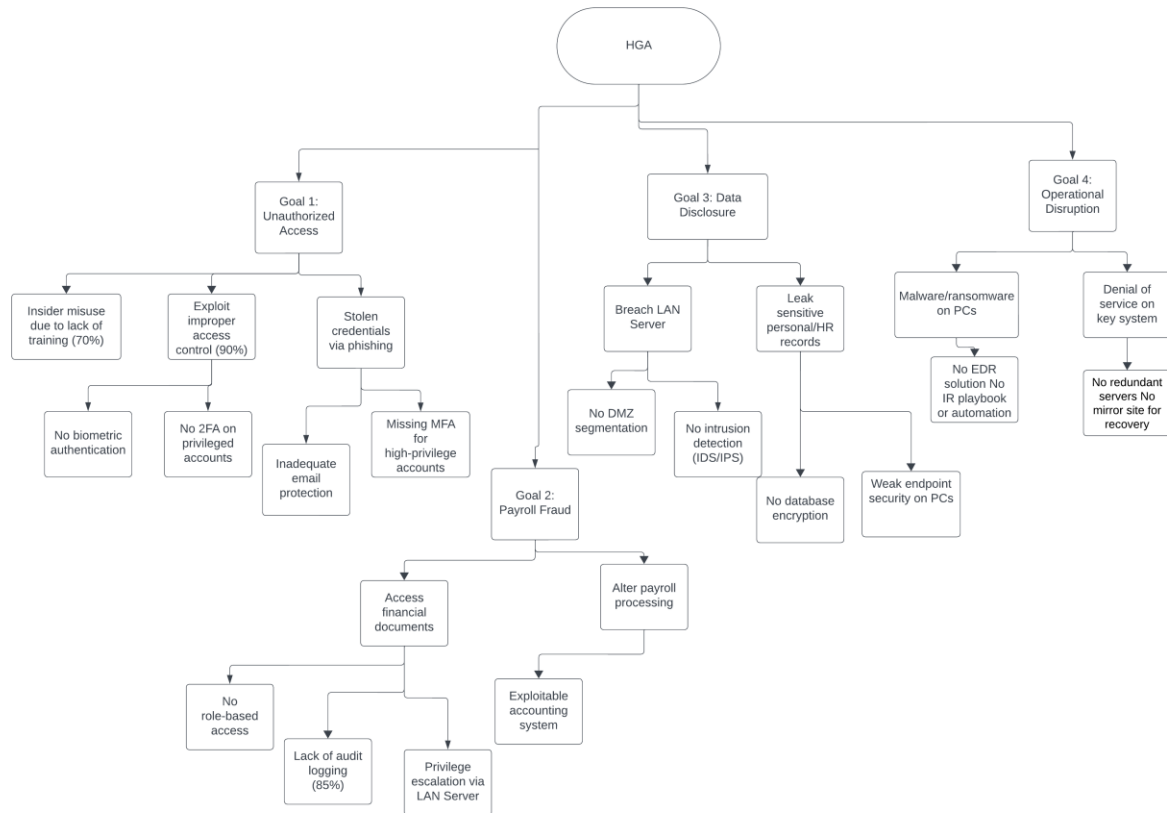
	HGA	Capgemini
Industry	Government Finance & Accounting	Consulting & IT Services
Mission	Securely transfer govt. funds & protect sensitive financial/personnel data	To create and deliver business and technology solutions that fit clients' needs and drive results.
Geographic Presence	Nationwide	Global (50+ countries)
No of Employees	1,000	~340,000
Network Topology	Provided in Appendix	Provided in Appendix
Critical Assets in \$	\$400,000	\$12,800,000

Threat Agents	Insider Threat	Insider & external cyber-attackers
Attack Tree Scenarios	Provided Below	Provided Below
Top 3 Vulnerabilities and Exploitation Probabilities	Improper access control (90%); Insufficient audit logging (85%); Lack of training (70%)	Unauthorized access; Buffer overflows; Unencrypted data
Assets with Vulnerabilities	Financial docs; PCs; LAN Server	Cloud & data centers; Customer databases; Laptops; Software; Cyber-infra; etc
Recommended Prevention Controls	New CISO Appointing a CISO centralizes security leadership, aligns strategy with operations, and ensures proactive threat management. The role enhances governance, compliance, and coordination of controls to reduce risk exposure. Missing MOT Controls Implementing Management, Operational, and Technical (MOT) controls addresses gaps in areas like asset classification, training, risk procedures, and audits. These controls strengthen governance, detection, and policy enforcement. 2-Factor Authentication (2FA) 2FA adds a secondary verification step to logins, making unauthorized access much harder. It's effective against phishing, credential stuffing, and secures high-value accounts and remote access. VPN A VPN encrypts communication between users and the internal network, preventing data interception. It's essential for remote access, protecting sensitive information in hybrid work environments. DMZ (Demilitarized Zone) A DMZ isolates public-facing services from internal networks, containing potential breaches. It protects internal systems by reducing exposure and limiting damage if external services are compromised.	New CISO Controls Appointing a CISO provides centralized cybersecurity leadership at Capgemini. The CISO aligns security strategy with business goals, ensures policy-driven controls, and proactively addresses emerging threats. Missing MOT Controls MOT controls fill operational and governance gaps across departments. They standardize incident handling, risk planning, access audits, and training—enhancing overall resilience and compliance. 2-Factor Authentication (2FA) 2FA adds a second layer of verification, reducing the risk of unauthorized access. It's vital for protecting privileged accounts and cloud-based remote access. Biometric & Behavioral Authentication These controls use biometrics and behavior analytics to verify identity. They defend against insider threats and social engineering by detecting abnormal access patterns. Gate-to-Gate VPN This VPN model ensures encrypted, end-to-end communication across internal and external systems. It supports hybrid work and secures sensitive project data. Database Encryption for Data at Rest Encrypting stored data protects it from breaches or insider misuse. It's essential for securing HR records, client data, and IP on-premises and in the cloud. WPA3 Wireless Encryption WPA3 protects corporate Wi-Fi

		from brute-force attacks and eavesdropping. It's key for securing internal traffic, especially in shared workspaces.
Assets with Risk Impacts	Financial Documents – payroll fraud Pcs- Disruption of Operations Lan Server – Data Disclosure	Customer & Client Databases – Data Breach / Confidential Information Disclosure Enterprise Software & proprietary Tools – Business Disruption / Operational Downtime Employee Laptops & Workstations – Credential Theft / Lateral Movement
Recommended Response Controls	New CISO The CISO leads HGA's incident response strategy, ensuring quick detection, containment, and resolution of security events. Their leadership minimizes disruption and ensures compliance with legal and regulatory requirements. Missing MOT Controls MOT controls like audit logging and incident reporting strengthen response readiness. They ensure timely detection, structured handling, and better post-incident analysis and legal defensibility. Redundant Server A redundant server provides automatic failover during failures or cyberattacks. It ensures service continuity, reduces downtime, and maintains access to critical applications and data. Mirror Site A mirror site is a live backup of systems at a different location, ready to take over in case of disaster. It enables rapid recovery, reduces data	New CISO The CISO leads incident response planning, threat monitoring, and containment efforts. This role ensures breaches are handled swiftly, with minimal legal and financial impact. Missing MOT Controls MOT controls enforce structured response protocols like incident documentation, escalation workflows, and compliance reporting. They enhance accountability and speed up recovery. Redundant Servers Redundant servers act as failover systems to ensure continuity during outages or cyber incidents. They help Capgemini avoid downtime and maintain service availability. Cloud-Based Mirror Site A cloud mirror site replicates Capgemini's core systems and enables seamless switch-over during breaches. It ensures quick recovery and minimal data loss. Endpoint Detection and Response (EDR) EDR tools monitor and contain threats on endpoints in real time. They provide rapid rollback and remediation against malware and zero-day exploits. Incident Response Playbooks & Automation Automated IR playbooks standardize and accelerate breach responses. Tools like Splunk SOAR trigger threat isolation and

	loss, and supports business continuity and compliance.	alert teams with minimal manual effort. Behavioral IDS/IPS Behavioral IDS/IPS detect anomalies in network traffic, offering early alerts for insider threats and unknown attacks. They enhance real-time visibility and proactive defense.
Residual Asset Risk in \$ (post control)	\$927580	\$700,000
Risk Prevention Budget	\$20,000	\$100,000
Risk Response Budget	\$30,000	\$150,000
Total Security Budget	\$50,000	\$250,000
ROI (Total Security Risk Improvement)	5.73 (286,425 / 50,000)	2.8 (700 K / 250 K)
ROA (Budget /Critical Assets) \$	12.5 % (50 K / 400 K)	1.95 % (250 K / 12,800 K)
ROHC(Budget /Employee) \$	\$50 per employee (50 K / 1,000)	\$0.74 per employee (250 K / 340 K)
Cybersecurity Workforce Recommendations	For HGA, a lean cybersecurity team of four dedicated specialists is advised: a Risk Management Analyst to perform regular risk assessments and maintain the organization's risk register; a Privileged Access Manager to deploy and govern a PAM solution and enforce least-privilege policies; a Security Auditor to conduct internal audits, verify control effectiveness, and identify compliance gaps; and a Security Awareness Trainer to develop and deliver ongoing training programs and phishing simulations to all staff	At Capgemini's global scale, a more extensive security workforce is needed: one Chief Information Security Officer (CISO) to define and oversee the enterprise security strategy and align it with business objectives; three SOC Analysts to continuously monitor SIEM alerts, triage incidents, and perform initial forensic analysis; two Threat Hunters to proactively search for adversaries in logs and telemetry and refine detection rules; two IR Automation Engineers to build and maintain SOAR playbooks and integrate threat-intelligence feeds into automated response workflows; and one IAM Specialist to architect and manage identity solutions such as MFA, SSO, and PAM, as well as to conduct regular privilege reviews

Attack Tree for HGA



Attack Tree for Capgemini



Budget Calculations for HGA

Initial Risk (Before Controls): \$1,244,250

Risk Reduction(Post Controls): \$286,425

Residual Asset Risk = Initial Risk – Risk Reduction

Residual Risk = \$ 1,244,250 - \$286,425 = \$957,825

Risk Prevention Budget - \$20,000

Risk Response Budget - \$30,000

Total Security Budget = Prevention Budget + Response Budget

$$\Rightarrow 20,000 + 30,000 = \$50,000$$

Return on Investment (ROI) = Risk Reduction / Total Security Budget

$$\Rightarrow 286,425 / 50,000 = 5.73\%$$

Return on Assets (ROA) = Total Security Budget / Total Critical Assets

$$\Rightarrow 50,000/400,000 = 12.5\%$$

Return on Human Capital (ROHC) = Total Security Budget / Number of Employees

$$\Rightarrow 50,000 / 1,000 = \$50 \text{ per employee}$$

Budget Calculations for Capgemini

Initial Risk (Before Controls): \$1,000,000

Risk Reduction(Post Controls): \$300,000

Residual Asset Risk = Initial Risk – Risk Reduction

Residual Risk = \$ 1,000,000 - \$300,000 = \$700,000

Risk Prevention Budget - \$100,000

Risk Response Budget - \$150,000

Total Security Budget = Prevention Budget + Response Budget

$$\Rightarrow 100,000 + 150,000 = \$250,000$$

Return on Investment (ROI) = Risk Reduction / Total Security Budget

$$\Rightarrow 700000 / 250,000 = 1.2\%$$

Return on Assets (ROA) = Total Security Budget / Total Critical Assets

$$\Rightarrow 250,000/12,800,000 = 1.95\%$$

Return on Human Capital (ROHC) = Total Security Budget / Number of Employees

$$\Rightarrow 250,000 / 340,000 = \$0.74 \text{ per employee}$$

	HGA	Capgemini
Initial Risk (Before Controls)	\$1,244,250	\$1,000,000
Risk Reduction (Post Controls)	\$286,425	\$300,000
Residual Risk	\$957,825	\$700,000
Prevention Budget	\$20,000	\$100,000
Response Budget	\$30,000	\$150,000
Total Security Budget	\$50,000	\$250,000
ROI (Risk Reduction / Budget)	5.73%	1.20% (<i>corrected</i>)
ROA (Budget / Total Assets)	12.5% (based on \$400K assets)	1.95% (based on \$12.8M assets)
ROHC (Per Employee Cost)	\$50 (1,000 employees)	\$0.74 (340,000 employees)

Conclusion and Recommendations to Capgemini

Capgemini’s comprehensive Security Risk Management Implementation Plan demonstrates a robust, layered approach to protecting its diverse global operations. By integrating advanced access control measures—such as continuous authentication, multi-factor authentication (MFA), and biometric systems—with hardened network infrastructure (including enclave segmentation, stateful firewalls, and intrusion detection/prevention), the organization has laid a strong foundation for both **preventing** and **responding** to cyber threats. Database security controls—ranging from encryption at rest and in transit to rigorous audit logging and role-based access control—further safeguard sensitive client and corporate data, aligning with stringent regulatory requirements across regions. Moreover, the deployment of redundant servers, mirror sites, and disaster recovery procedures ensures high availability and rapid restoration of critical services in the event of an incident, thereby bolstering operational resilience .

Despite these strengths, several areas warrant ongoing focus and enhancement:

- 1. Advanced Threat Detection & Analytics**

Capgemini should invest in Security Information and Event Management (SIEM) platforms augmented with User and Entity Behavior Analytics (UEBA) to detect anomalous activity—especially insider threats and advanced persistent threats (APTs)—in real time.

- 2. Third-Party & Supply Chain Risk Management**

With an extensive ecosystem of partners and vendors, Capgemini must enforce continuous monitoring and standardized security assessments for third parties, ensuring that all suppliers adhere to its security baseline and contractual SLAs.

- 3. Automation & Orchestration**

The complexity of Capgemini’s global environment can be managed more effectively through Security Orchestration, Automation, and Response (SOAR) platforms, which streamline routine tasks (patch management, incident triage) and improve response times.

- 4. Zero Trust Architecture (ZTA)**

Accelerate the transition to a Zero Trust model by implementing strict “never-trust, always-verify” principles across all network segments, applications, and data stores—

leveraging micro-segmentation, just-in-time (JIT) access, and continuous device posture checks.

5. **Continuous Training & Phishing Simulations**

Building on mandatory awareness programs, Capgemini should conduct regular, simulated phishing campaigns and tabletop exercises to reinforce a security-first culture and validate incident response workflows.

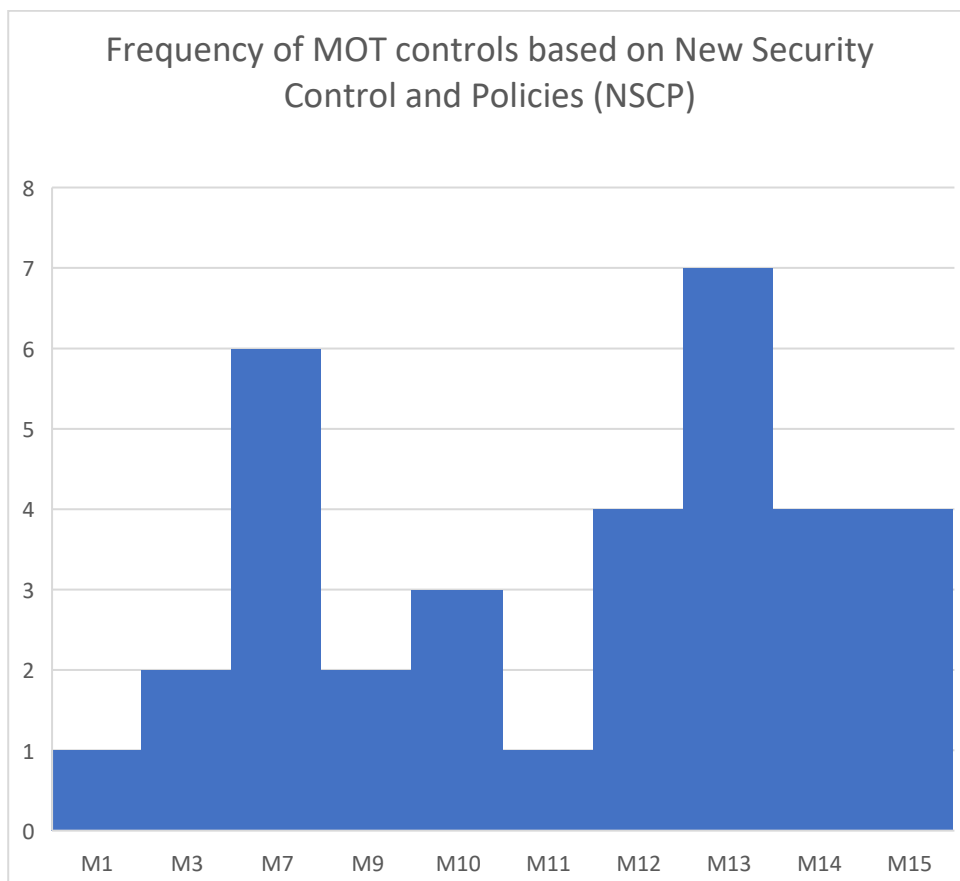
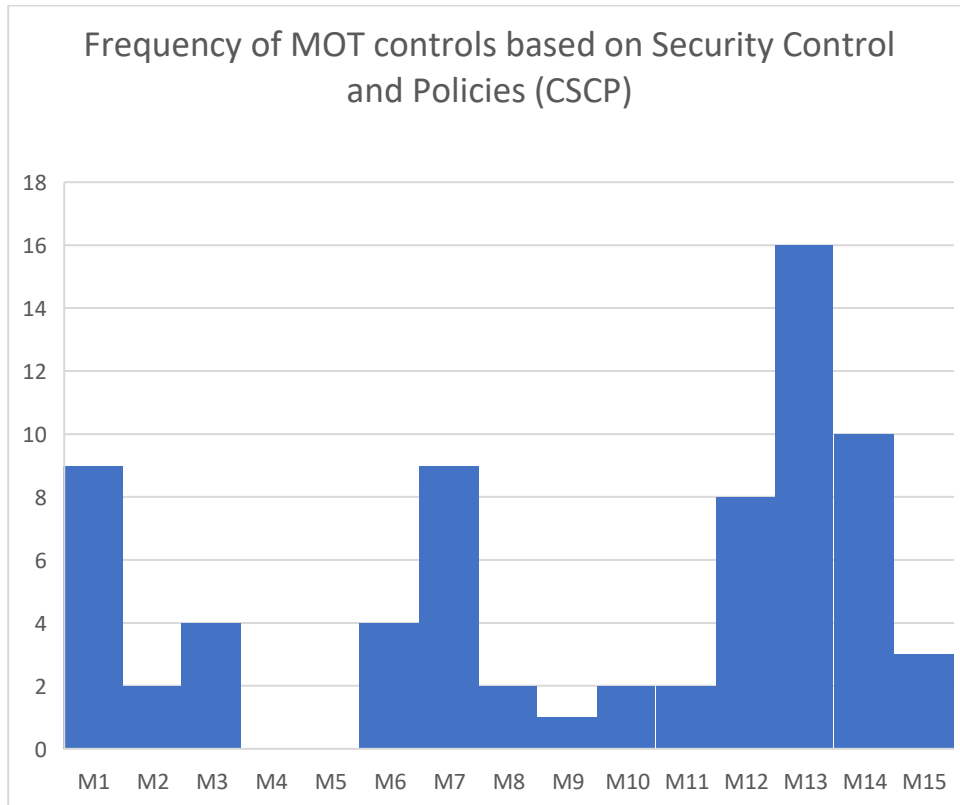
6. **Cloud & DevSecOps Integration**

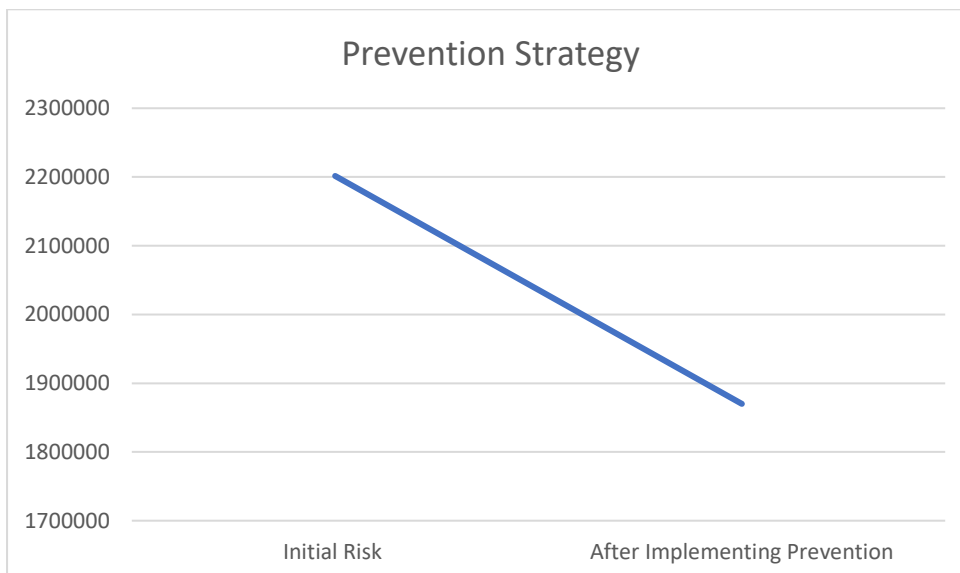
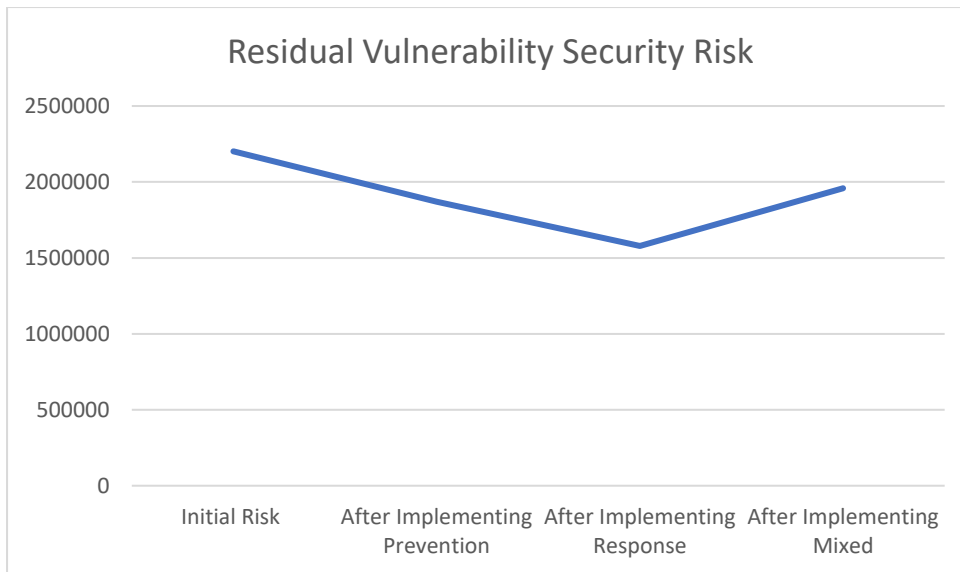
As cloud adoption and DevOps practices grow, embed security controls into CI/CD pipelines—automated code scanning, container security, and infrastructure as code (IaC) validation—to shift security left and reduce vulnerabilities earlier in the development lifecycle.

By prioritizing these enhancements alongside its existing Management, Operational, and Technical controls, Capgemini can maintain a dynamic, risk-adaptive posture that not only mitigates current threats but also anticipates emerging challenges—ensuring sustained trust with clients and a competitive edge in security services.

Part D

Appendix 1: All MS-Excel spreadsheet models







P	Z	ConfidenceLevel	Margin of Error(%) due to Sampling				
			1200	1400	1600	1800	4000
0.5	2.575829	0.99	3.717889	3.442097	3.219787	3.035644	2.036372
0.5	1.959964	0.95	2.828964	2.619112	2.449955	2.30984	1.549488
0.5	1.644854	0.9	2.374142	2.198028	2.056067	1.938479	1.300371
P=0.5							
n= samplesize							
Z=-NORM.S.INV(cell value (0.5*(1-confidence level)))							
Margin of Error(%) due to Sampling = Z*SQRT(P*(1-P)/n)*100							
Hence the Calculations are proved to be correct.							

Appendix 2: Any data, analysis, controls or policies not included above

- List of Assets in HGA**

Asset Number	Asset Name	Asset Value	Description
A1	Financial Resources	95	Represents government funds managed by HGA, critical for payroll and other financial disbursements.
A2	System Components	75	Includes the infrastructure supporting HGA's operations.(Printers,router, etc)
A3	Personal Computers	90	Used by staff for everyday tasks like data processing, word processing, and accessing applications.
A4	LAN Server	85	Central system managing shared storage, access control, and execution of critical applications.
A5	Personnel Information	80	Includes sensitive employee data like leave balances, salary, and W-2

			information, vital for privacy and operations.
A6	Company Documents	85	Essential documents related to financial and operational dealings with vendors and contractors.(Contracting and Procurement Documents)
A7	Draft Regulations	75	Early-stage regulatory documents, significant for governance but less operationally critical.
A8	Internal Correspondence	80	Covers emails and other communication records within HGA, important but medium priority.
A9	Business Documents	85	Critical day-to-day operational records stored on the server, sensitive to unauthorized access or loss.(Memos , Reports, etc)
A10	Reputation	70	Intangible but critical for maintaining trust and operational credibility.
A11	Employee Trust	90	Confidence in secure handling of personal information and reliable wage payments is fundamental.
A12	Mainframe	85	Service Provider For HGA and other agencies operated by the federal agency
A13	Modem Pool	90	Provides dial-up services (via the public switched network) to HGA employees on Travel

- List of Threats**

Threat Number	Threat Name	Description
T1	Payroll Fraud	Financial embezzlement and fraud: comprises submitting false timesheets after being fired or overstating compensatory hours worked in order to receive more compensation, as well as fabricating service tenure in order to receive early retirement benefits. generating timesheets and employee records for fraudulent employees in order to receive more payments
T2	Payroll Errors	Errors in the time and attendance data entering Failure to promptly enter information about new hire terminations and transfers, inadvertent corruption or loss of time and attendance records, or mistakes in interagency coordination and personal transfer procedures

T3	Interruption of Operations	Disruptions to HGA's activities caused by power outages, hardware failures, or malicious actions, delaying processes like payroll or communication.
T4	Information Disclosure or Brekening	Unauthorized access or sharing of sensitive data, such as employee records or internal communications, either internally or externally.
T5	Network-related	Risks from external networks, including unauthorized access, data tampering, or eavesdropping during transmission.
T6	Natural Disasters	Environmental events like floods or storms causing damage to infrastructure, resulting in downtime or data loss.
T7	Misuse of System Resources	Improper use of HGA's systems for unauthorized purposes, affecting performance or security.
T8	Unauthorized access to Telecommunication Services	Exploitation of HGA's telecom systems, such as unauthorized calls, data access, or eavesdropping.

- List of Security Vulnerabilities**

Threat ID	Vulnerability ID	Description
T1	V1	Falsified (Date & Time Sheet) Data manipulation By workers.
	V2	Unauthorized Personnel access to modifying Employee records
	V3	Bogus time and attendance applications
	V4	Employee negligence to update information on time
T2	V5	Degrading building facilities and resources
T3	V6	Improper access control management
	V7	Exposure to external Network
	V8	Lack of Secure storage and encryption mechanisms
	V9	Improper or insufficient audit logging
T4	V10	Lack of proper Virus Detection and Prevention Mechanisms
+T5	V11	Lack of sufficient personnel training and awareness

• **List of Current Security Control and Policies(CSCP)**

CSCP ID	Category	Description
CSCP1	General Purpose	Only System administrators are authorized to establish login IDs and credentials on multiuser HGA systems
CSCP2		Access to the HGA system is restricted to HGA employees and contract personnel only after obtaining a written authorization from the department supervisor.
CSCP3		Mandatory security awareness and training course or an interactive computer-aided-instruction training session along with signed acknowledgement that they understand their security responsibilities.
CSCP4		Compliance with password selection and security procedures.
CSCP5		Use of automated access control mechanisms to protect data from risk of exposure to unauthorized individuals.
CSCP6		Restrictions on access to disclosure sensitive information to only authorized personnel who need it.
CSCP7		Compliance with the Privacy Act to protect personnel information
CSCP8		Verification of employee date and time sheet by Time and attendance clerk using the I&A application on the LAN server.
CSCP9		Review of date and time sheets, along with the corrections by at least two authorized individuals
CSCP10	Protection against Unauthorized execution	Only Time and Attendance supervisors can approve and submit data or subsequent corrections to the mainframe.
CSCP11		Supervisors are restricted from approving their own time and attendance data.
CSCP12		Only the system administrator holds privilege to assign special access control privilege to server programs
CSCP13		Restrictions on administrators to access or execute anything other than those related to configuring the accounts, passwords, and access permissions for clerks and supervisors
CSCP14		Prohibition by policy imposed on administrators to enter, modify or submit time and attendance data via the time and attendance application or other mechanisms
CSCP15		Execution of commands on server, restricting the PC to be used only as a terminal relaying commands to server to protect against unauthorized access

CSCP16	Protection Against Payroll Errors	Verification of time and attendance entries by double entry of T&A clerks
CSCP17		Sanity checks on the attendance entries
CSCP18		Assignment of duties and responsibilities to Director of Personnel to overview and handle payroll related issues

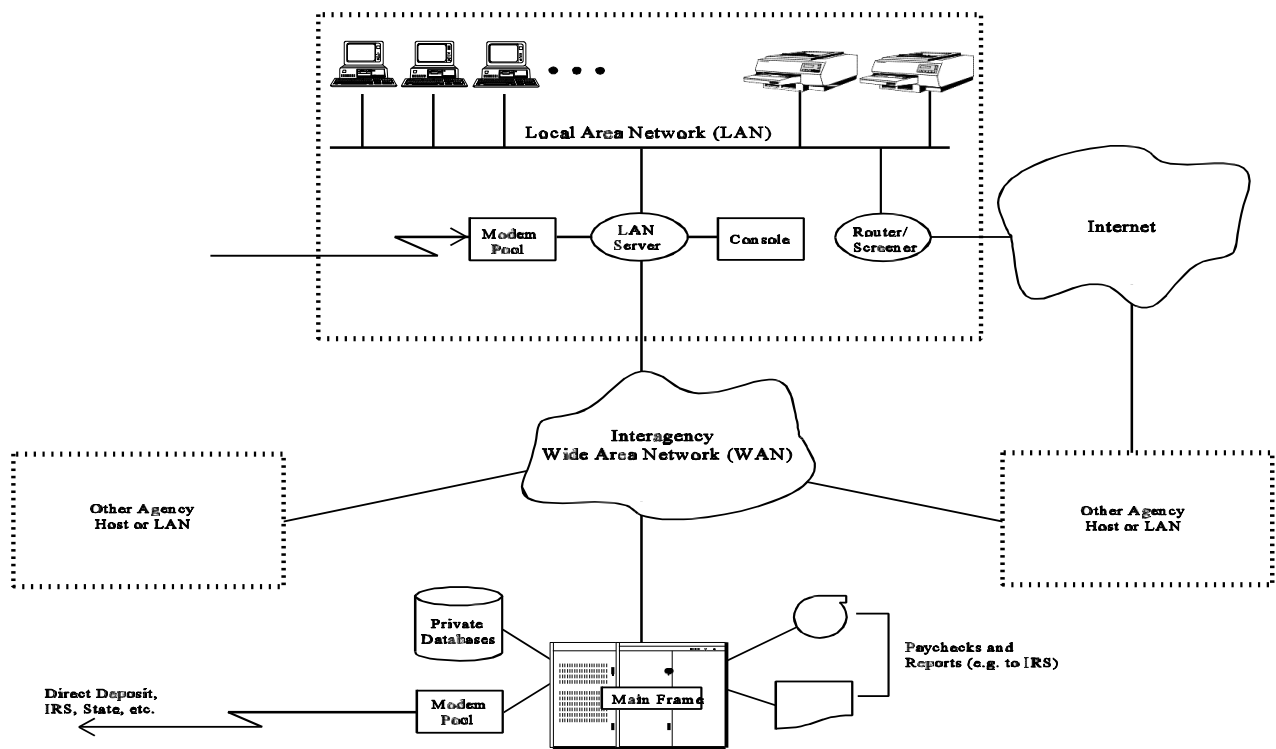
• **List of New Security Control and Policies(NCSP) proposed by CISOs team**

NCSP ID	Category	Description
NCSP1	Payroll Fraud	Use of Stronger authentication mechanisms based on smart tokens to generate OTPs that cannot be used for subsequent sessions
NCSP2		Improving server's administrative procedures and fixing security related bugs by applying patches provided by the vendor
NCSP3		Improve monitoring of Server's access control configuration
NCSP4		Integrating the use of digital signatures into smart tokens to verify and maintain integrity and non-repudiation
NCSP5	Payroll error	Necessity to establish incentive and penalty based compliance approach
NCSP6		Quarterly compliance audit report
NCSP7	Continuity of Operations	Periodic internal training and awareness sessions for COG personnel
NCSP8		Improve adherence to its virus prevention procedures
NCSP9		Regular backup services provided by COG to about 5% of HGA's PCs along with quarterly reminder to every PC user to perform system backup
NCSP10	Information Disclosure	Improvement in security awareness trainings
NCSP11		Installation of screen-locks software on PCs to automatically lock any PC after specific period of idle time
NCSP12		Maintaining and reviewing an activity log on the server
NCSP13		Use of hard-disk encryption utilities
NCSP14	Network Related Threats	Require Stronger I&A for dial-in access
NCSP15		Restricted version of the mail utility be provided for dial-in, which would prevent a user from including files in outgoing mail messages.

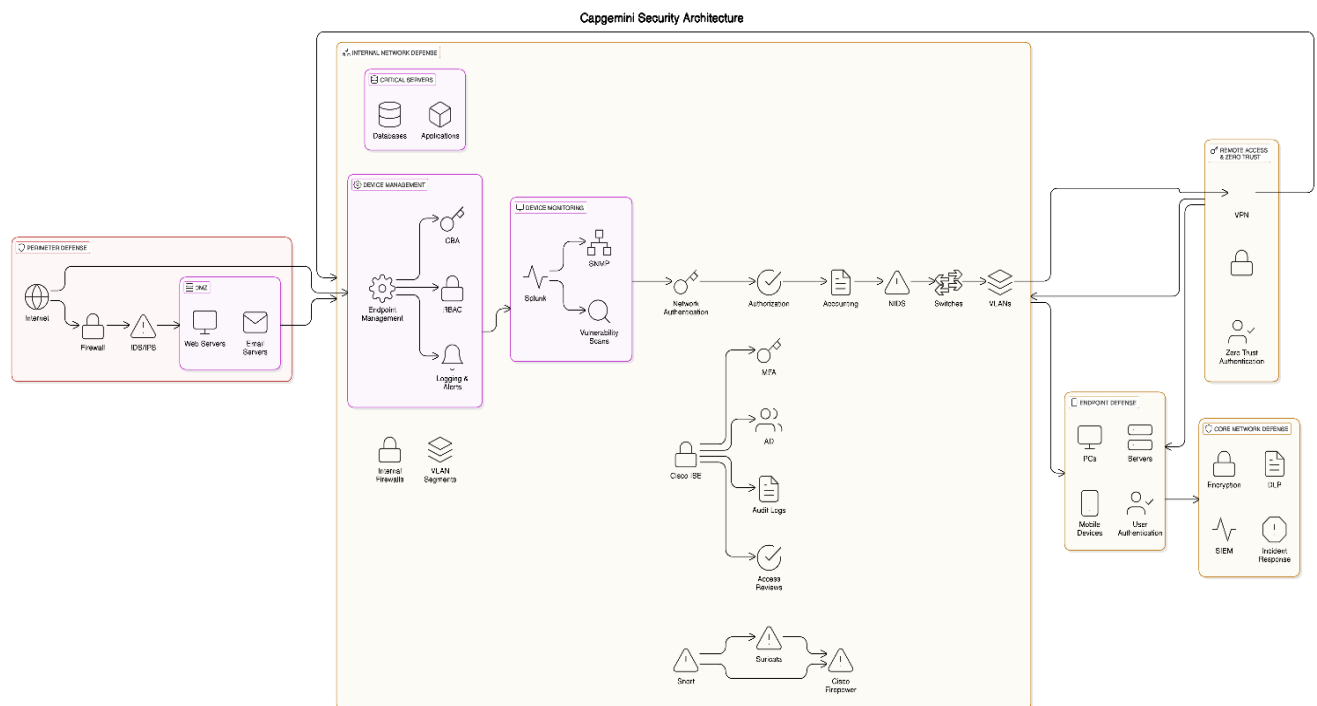
NSCP16	replace its current modem pool with encrypting modems
NSCP17	Implementing an encrypted channel for communication between server and mainframe over the WAN.

Appendix 3: Detailed Network Topology for HGA

HGA maintains a robust security posture across management, operational, and technical controls, though some areas require improvement. Regular risk assessments and compliance with federal guidelines ensure system certification and accreditation, yet delays in corrective actions and incomplete adherence to security plans pose challenges. Operationally, HGA enforces duty separation, background checks, and contingency planning but needs to enhance disaster recovery testing, virus scanning compliance, and mobile data protection. Technically, strong authentication and access restrictions are in place, with plans to implement one-time passwords, encrypting modems, and digital signatures. However, unencrypted LAN and WAN transmissions present a vulnerability requiring immediate attention. The system topology comprises a distributed computing environment with interconnected PCs, a central LAN server, external WAN access, Internet connectivity through secured routers, a remote access modem pool, and a centralized mainframe for interagency data exchanges. Strengthening encryption, monitoring, and compliance measures will further secure HGA's critical operations and sensitive information.



Appendix 4: Detailed Network Topology (defense-in-depth) for Capgemini



1. Introduction:

Defense-in-depth is a robust cybersecurity strategy designed to safeguard Capgemini's IT infrastructure by implementing multiple layers of defense. If one layer fails, others will act as backup, minimizing the risk of successful attacks. This layered defense approach enhances protection for Capgemini's sensitive data, applications, and systems. The strategy incorporates a multi-tiered framework focusing on network perimeter, internal systems, endpoints, applications, data, and remote access, ensuring that vulnerabilities are mitigated at every possible level.

2. Network Layers and Functionality:

2.1 Perimeter Defense (Outer Layer)

- Firewall:** The firewall serves as the first line of defense by filtering incoming and outgoing network traffic according to predefined security rules. At Capgemini, firewalls are deployed at both the external perimeter and within internal network segments to create multiple defensive barriers, safeguarding applications and sensitive systems from external threats.
- Intrusion Detection and Prevention Systems (IDS/IPS):** IDS is used to detect suspicious activities by monitoring traffic patterns, while IPS takes proactive steps to block malicious traffic. This two-fold mechanism is crucial for protecting applications from targeted attacks like buffer overflow exploits and DDoS attacks.
- Web Application Firewall (WAF):** Capgemini uses WAFs to filter and monitor HTTP traffic, specifically designed to protect web applications from common exploits such as SQL injection, cross-site scripting (XSS), and other vulnerabilities that can compromise application integrity.

- **Demilitarized Zone (DMZ):** A strategically isolated zone housing publicly accessible servers (such as web servers or email servers) protects internal networks. By placing the DMZ between the external internet and Capgemini's internal network, it acts as a buffer that prevents direct attacks on critical internal systems and applications.
- **Network Intrusion Detection System (NIDS):** Tools such as Snort or Suricata are employed to detect and alert security teams about any suspicious traffic patterns, such as malware communication attempts or SQL injection probes targeting web applications.

2.2 Internal Network Defense (Middle Layer)

- **Internal Firewalls:** Firewalls within the internal network segment departments and applications, creating boundaries that limit lateral movement by attackers. These firewalls help isolate sensitive systems, reducing the risk of compromising other internal resources.
- **Virtual Local Area Networks (VLANs):** Logical segmentation of Capgemini's internal networks (Finance, HR, IT, etc.) restricts attackers from easily spreading across the network. Each department's applications and systems are isolated through VLANs, strengthening security by limiting access to authorized users.
- **Network Access Control (NAC):** Ensures that only devices meeting security compliance requirements (e.g., updated OS, security patches, etc.) can connect to the internal network. This control is vital to prevent unauthorized or vulnerable devices from compromising the security of applications.
- **Network Authentication, Authorization, and Accounting (AAA):** Using centralized systems like Microsoft NPS, Capgemini ensures that users are properly authenticated before accessing network resources. This is coupled with Multi-Factor Authentication (MFA) for privileged accounts to further secure application access.
- **Periodic Access Reviews:** Regular access reviews are conducted to ensure users have the minimal required privileges necessary for their roles, thereby minimizing the risk of insider threats or unauthorized access to sensitive applications.

2.3 Endpoint Defense (Device Level)

- **Endpoint Protection Platforms (EPP):** Capgemini deploys EPP solutions to protect all endpoints from malware, viruses, and other malicious software. These platforms also offer application-specific protections, reducing the attack surface for client-side applications.
- **Mobile Device Management (MDM):** MDM solutions enforce security policies on mobile devices, such as encryption and app restrictions, to prevent the exploitation of mobile vulnerabilities and ensure secure access to applications.
- **User Authentication and Authorization:** Strong user authentication mechanisms (including MFA) are enforced on endpoints, ensuring that access to critical applications and data is tightly controlled and that unauthorized access is minimized.

- **Device Management Services:** Tools such as SCCM and Intune are used to centrally manage devices, ensuring that all endpoints are securely configured, up-to-date, and free from vulnerabilities that could compromise application security.
- **Device Monitoring:** Real-time device monitoring through tools like Splunk or SolarWinds helps detect abnormal activities, such as unauthorized changes to configurations or unusual application access patterns, that could indicate a potential breach.

2.4 Data Defense (Core Layer)

- **Encryption:** Capgemini ensures that sensitive data within applications is encrypted both at rest and during transmission. AES-256 encryption is implemented to protect critical information from interception or unauthorized access.
- **Data Loss Prevention (DLP):** DLP tools are used to monitor and prevent unauthorized data exfiltration, ensuring that sensitive application data (e.g., customer information, financial records) is not leaked or improperly transferred.

2.5 Monitoring and Response (Core Layer)

- **Security Information and Event Management (SIEM):** A centralized SIEM platform aggregates logs from various layers (network, endpoint, application) for real-time analysis and alerts. It provides early detection of security incidents that might target applications or systems.
- **Incident Response Plan (IRP):** Capgemini has a well-defined Incident Response Plan to quickly and effectively contain, mitigate, and recover from security breaches targeting applications or critical infrastructure.
- **NIDS Integration:** Integration of NIDS with SIEM systems enhances the detection of potential attacks, particularly those targeting networked applications. Regular rule updates ensure evolving threats, including zero-day vulnerabilities, are promptly detected.
- **Penetration Testing:** Regular penetration tests simulate real-world attacks on applications to identify potential vulnerabilities, enabling Capgemini to fix weaknesses before attackers can exploit them.

2.6 Access Management and Remote Connectivity

1. **Virtual Private Network (VPN):** VPNs are used to securely encrypt communication between remote workers and Capgemini's network, ensuring that sensitive applications are protected even when accessed from outside the corporate network. MFA is enforced to ensure that only authorized users can access critical resources.
2. **Zero Trust Security Model:** Capgemini employs a Zero Trust model, where every access request—whether internal or external—is treated as untrusted until verified. Strict access controls, including MFA, are enforced to ensure that only authorized users can access sensitive applications.

3. Network Topology Overview

The updated network topology incorporates multiple layers of defense to protect Capgemini's systems and applications:

1. **Perimeter Security:** Firewalls, IDS/IPS, WAFs, and DMZ act as barriers to prevent external threats from compromising sensitive systems and applications.
2. **Internal Segmentation:** Internal firewalls, VLANs, and NAC provide segmentation and access control within the organization, ensuring applications and systems remain isolated to reduce the risk of lateral attacks.
3. **Endpoint Protection:** Endpoint security, MDM, and robust authentication policies are in place to secure devices and protect applications from potential vulnerabilities.
4. **Data Security:** Encryption, DLP, and AAA mechanisms ensure sensitive data remains protected during storage, processing, and transfer.
5. **Monitoring & Response:** The SIEM system, NIDS, and real-time monitoring tools provide continuous vigilance, detecting and responding to security events before they escalate.
6. **Secure Remote Access:** VPNs and the Zero Trust model ensure that remote workers can securely access Capgemini's applications and resources without compromising security.

4. Conclusion

Capgemini's updated Defense-in-Depth strategy strengthens its cybersecurity framework, protecting its network and application infrastructure with robust layers of security. The new implementations and technologies significantly enhance the company's resilience against evolving cyber threats, ensuring that applications remain available, secure, and compliant with industry standards. By applying these measures, Capgemini enhances its defense posture and ensures business continuity while safeguarding sensitive data and applications from potential threats.

Resources

NIST Special Publication 800-53: Security and Privacy Controls for Information Systems and Organizations

<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5>

NIST Special Publication 800-181: NICE Cybersecurity Workforce Framework

<https://doi.org/10.6028/NIST.SP.800-181>

ISO/IEC 27001: Information Security Management Systems Requirements

<https://www.iso.org/isoiec-27001-information-security.html>

GDPR – EU General Data Protection Regulation

<https://gdpr.eu/>

CIS Critical Security Controls

<https://www.cisecurity.org/controls/>

Cybersecurity Services

<https://www.capgemini.com/us-en/services/cybersecurity/>

Define Your Security Roadmap

<https://www.capgemini.com/us-en/services/cybersecurity/define/>

Protect Your Data, Systems & Users

<https://www.capgemini.com/us-en/services/cybersecurity/protect/>

Defend Your Business: Threat Detection & Response

<https://www.capgemini.com/us-en/services/cybersecurity/defend/>

Cybersecurity & Data Protection (Responsible Business)

<https://www.capgemini.com/us-en/about-us/management-and-governance/a-responsible-business/cybersecurity-and-data-protection/>